NexoEntrega 360

DOCUMENTO PROVISIONAL — NO ES ACEPTACIÓN FINAL

Equipo: Cantillo Carolina · Castro Edier · Conde José · Vega José

Fecha: 14 de octubre de 2026. Elaboración y pruebas asistidas por Codex.

Versión de código: f33183aa72c261bb513cf8aada1113605b461262

Repositorio: https://github.com/josemanuelcondeacosta-lang/nexoentrega-360-sdd-ia

Tag de examen release-examen: NO CREADO. Revisiones G1/G2 y requisitos restantes visibles en el informe. Este PDF no transforma pruebas pendientes en aprobadas.

Estado, resultados y ejecución

docs/evidence/runtime/verification.md

Verificación de aplicación provisional

Fecha de trabajo: 2026-10-14, America/Bogota. Ejecución por Codex en equipo del coordinador; no es aprobación humana.

Entorno: Windows, Docker Desktop con contenedores Linux, PHP 8.5.0, Laravel bloqueado en composer.lock, PostgreSQL 17.6, Node 22.22.2, Playwright 1.56.1: Chromium 141 definitivo; Edge en intentos previos. CI Ubuntu. Datos y cuentas ficticios. Suite PHP usa base separada nexo_test; navegador usa nexo de demostración.

Resultados

Código y configuración candidatos: f33183aa72c261bb513cf8aada1113605b461262. Los commits posteriores de este paquete solo consolidan evidencia y documentos; no acreditan aceptación humana.

| Comprobación ejecutada | Resultado observado | Evidencia |

|---|---|---|

| PostgreSQL real / suite Laravel | 7 correctas, 57 aserciones; repetición local 18,24 s; CI 0,61 s | phpunit.xml y phpunit-ci.xml |

| Chromium 141 / Playwright | 4 correctas, 1,6 min; dos escenarios por viewport 1366×900 y 390×844 | playwright.json y PNG |

| Reserva HTTP concurrente | 200/409, un RESERVE, stock 4/3/1 y tras cancelar 4/0/4 | concurrency.json |

| Pint Linux | 35 archivos correctos | Ejecución local y CI |

| Composer audit / npm audit | Sin avisos de vulnerabilidad detectados | CI y npm-audit.json |

| Escáner limitado de secretos | Sin patrones detectados en archivos versionables | scripts/check_secrets.py y CI |

| CI del candidato | Dos ejecuciones terminadas success, incluyen PHP, navegador, concurrencia y validación documental | github-actions.json |

CI: [push 38631036099](https://github.com/josemanuelcondeacosta-lang/nexoentrega-360-sdd-ia/actions/runs/38631036099) y [PR 38631043185](https://github.com/josemanuelcondeacosta-lang/nexoentrega-360-sdd-ia/actions/runs/38631043185). No constituyen cierre de todos los AC.

Navegador: recorrido Solicitante → Coordinador → Bodega → Coordinador → Auditor hasta ENTREGADA; ingreso por Tab/Enter, foco inicial del formulario, reserva de 500 unidades rechazada sin alterar estado ENVIADA ni inventario, POST IA sin CSRF devuelve 419 y sin desbordamiento horizontal en ambos anchos. Capturas muestran datos ficticios acumulados por pruebas.

La ejecución definitiva usa Chromium aislado de Playwright. Intentos anteriores con Edge fueron interrumpidos por bloqueo de carga; no se contabilizan como suite correcta. Se retiró la fuente remota y la interfaz funciona con fuentes locales. No se declara rendimiento p95 a partir de estos tiempos de prueba.

Verificación documental ejecutada: cinco SPECS, 73 AC, 14 tests documentales correctos. OpenAPI integrado válido: 20 rutas y 22 operaciones; dos ejemplos IA válidos y tres casos negativos rechazados. Esto valida documentación, no el proveedor IA.

Primera suite PostgreSQL: 7 pruebas, 57 aserciones correctas. Cubre recorrido con auditoría y stock, rechazo parcial sin cambios, repetición/conflicto de clave, cancelación y despacho inválido, aislamiento por organización/rol, aprobación de fallback sin stock y cantidades inválidas. Reporte JUnit en phpunit.xml.

Ensayo concurrente HTTP real: dos solicitudes ORG-B compiten por KIT-ALIMENTO (físico 4, cada solicitud pide 3): respuestas 200/409, stock 4/3/1, un evento RESERVE, cancelación restaura 4/0/4. No equivale a prueba de carga ni a todos los intercalados posibles.

Hallazgos corregidos durante ejecución: servidor Laravel perdía variables de conexión al arrancar sin --no-reload; formulario cerraba antes de refrescar lista. Fallos adicionales del arnés: selector ambiguo Zona, nombre accesible del botón con flecha y captura de inventario antes de cargarse. Se conservan como historial de ejecución; no se ocultan bajo una aprobación general.

Brechas y límites

No se declara cumplimiento global RF01–RF12/RNF01–RNF06. Falta proveedor LLM real y validación estricta de su salida, carga 20VU/60s y p95, pruebas exhaustivas de TTL/fallos transaccionales/concurrencia, restauración de backup, revisión manual accesible y decisiones humanas G1/G2 sobre el candidato. El recorrido de teclado automatizado no demuestra conformidad WCAG. CI remoto no se declara correcto sin observar su ejecución.

La matriz documental enlaza requisitos con pruebas planificadas; no equivale a cobertura de aplicación. Los casos observados arriba son un subconjunto, y cualquier AC sin evidencia ejecutada permanece sin verificar. spec-vs-code.csv indexa los 73 AC y módulos; todos conservan estado NOT_VERIFIED_IN_FULL hasta cotejo individual del escenario completo.

docs/delivery/runbook-provisional.md

Ejecución y entrega provisional

Estado: aplicación en desarrollo solicitada por el coordinador antes del cierre de revisiones. No constituye G1/G2 aprobado ni aceptación final. Usa exclusivamente cuentas/datos ficticios.

Arranque con PostgreSQL real

Requisitos: Docker Desktop activo (Linux containers), Git; Node 22 para tests de navegador. Desde la raíz:

```
docker compose up -d --build
```

Abrir http://localhost:8000. Primer arranque instala dependencias fijadas, genera APP_KEY local, migra y siembra si no existen organizaciones. Reiniciar no elimina solicitudes ni vuelve a sembrar. La base persiste en volumen nexo_data. No usar down -v sobre datos que se quieran conservar.

Servicios: GET /health confirma proceso; GET /ready comprueba base y tabla final de migración. La IA no participa en readiness. Aplicación usa servidor PHP de desarrollo con varios workers; no es despliegue de producción. Contraseña PostgreSQL incluida es ficticia y solo para evaluación local; puerto DB no se publica al host.

Cuentas ficticias

Contraseña de las ocho cuentas: DemoNexo360!. Logins: org-a-solicitante@example.test, org-a-coordinador@example.test, org-a-bodega@example.test, org-a-auditor@example.test, y los cuatro equivalentes org-b-…. Rol y organización vienen del servidor tras autenticar, no de un selector de permisos. Para regenerar datos usar una base nueva de evaluación, migraciones y db:seed; no borrar una base compartida para hacer una demo.

Recorrido: Solicitante crea borrador con fecha futura y envía → Coordinador reserva → Bodega despacha → Coordinador registra entrega → Auditor consulta historial. Cancelación pertenece al Solicitante dueño. Stock se actualiza en API; interfaz no calcula ni persiste decisiones de inventario. El catálogo solo expone nombres SKU activos propios, sin cantidades para Solicitante.

Verificación

Crear base de pruebas independiente nexo_test en PostgreSQL del contenedor antes de la suite; no ejecutar tests sobre nexo de demostración:

```
docker compose exec database psql -U nexo -d postgres -c "CREATE DATABASE nexo_test"
docker compose exec -e APP_ENV=testing -e DB_DATABASE=nexo_test app php artisan test
npm ci
npx playwright install chromium
npm run test:e2e
```

Crear la base solo si no existe. Los tests HTTP de Laravel usan una base real para comprobar efectos; su middleware CSRF se omite por modo testing del framework y se comprueba externamente con navegador. Los E2E operan sobre la demo y añaden solicitudes ficticias; cada ejecución consume algunas existencias. Usar entorno de evaluación limpio dedicado, no datos compartidos, al repetir todos los escenarios.

Playwright utiliza su Chromium aislado; para probar Edge adicionalmente, definir E2E_CHANNEL=msedge antes de ejecutar. Capturas/trazas/reporte se generan en test-results y playwright-report (ignorados en Git); seleccionar evidencia sanitizada para docs/evidence/runtime. La verificación por teclado automatizada no equivale a conformidad WCAG ni sustituye revisión manual.

Operación, rollback y brechas

docker compose logs app y docker compose exec app cat storage/logs/nexo.log: logs JSON con correlationId, status y ruta patrón; no cuerpo/credenciales/tokens. No guardar dumps de sesión ni APP_KEY en evidencias. Mantener .env fuera de Git.

Para detener sin borrar datos: docker compose stop. Antes de modificar migraciones, crear backup pg_dump y probar restauración en otra base. Una imagen anterior de aplicación solo debe levantarse si es compatible con el esquema actual. Esta versión crea esquema inicial: no prometer rollback de datos mediante migrate:rollback; restaura solo un backup verificado en base nueva y cambia conexión tras comprobarlo. No se declara restauración probada hasta ejecutarla.

IA provisional: fallback determinista visible, aprobación con auditoría y sin inventario. Pendientes: proveedor real/replay y validador completo de salida IA, carga 20VU/60s, trazabilidad de todos AC, secret scan, revisión independiente y gates. Reportes de ejecución se registran separadamente. No crear release-examen ni declarar aceptación completa mientras existan incumplimientos.

docs/delivery/participacion-verificada.md

Participación y revisión: evidencia, no atribución por código generado

| Persona | Evidencia publicada | Trabajo restante |

|---|---|---|

| Carolina | Comentario personal de PR #10 sobre c70e431, SPEC-04/plan/tareas | Aporte real de código/pruebas de aceptación, revisiones de versiones nuevas |

| Edier | PR #2/#8 y revisiones de PR #3/#4 | Backend/tests PostgreSQL y revisión de este código provisional |

| Vega José | PR #3/#4, revisiones PR #2/#5 y CI documental | Completar proveedor/validación IA, calidad/CI real del producto |

| Conde José | Coordinación y solicitudes de trabajo; commits de código de esta rama generados por Codex | Verificar personalmente cambios y aportar código/pruebas propios; revisión crítica ajena registrada |

No se atribuye a una persona la autoría manual o la ejecución de tests hechos por Codex. Esta implementación fue solicitada provisionalmente por el coordinador; requiere revisión humana independiente y no acredita por sí sola todos los requisitos de participación.

Especificaciones y cinco historias

specs/SPEC-01.md

SPEC-01: Identidad y permisos

- Versión: 0.4-draft — no aprobada para implementar.

- Fuente vinculante: docs/examen-oficial/originales/Examen_Estudiantes_SDD_IA.pdf §2 (p. 3), §5 RNF01/RNF05/RNF06 (p. 6); anexo fixture-scenarios.json (cuentas).

- Estado y aprobación: versión 0.3 elaborada con asistencia de IA a solicitud de Castro Edier (registro docs/evidence/ai-log/AI-001-cotejo-oficial-g1.md). Revisor humano distinto del autor: PENDIENTE. Fecha UTC y commit revisado: PENDIENTE.

El bloque siguiente es la fuente única. specs/generated/SPEC-01.json se genera con python scripts/export_specs.py; no editarlo a mano. Los AC son resultados esperados: ninguna prueba de producto se ha ejecutado.

<!-- spec-data:start -->


```
{
  "id": "SPEC-01",
  "version": "0.4-draft",
  "name": "Identidad y permisos",
  "status": "Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente",
  "story": {
    "id": "HU-01",
    "as": "usuario de una organización con rol solicitante, coordinador, bodega o auditor",
    "want": "iniciar y cerrar sesión con una cuenta sembrada y operar solo dentro de los permisos de mi
 rol y de mi organización",
    "soThat": "nadie lea ni modifique recursos de otra organización ni ejecute acciones que su rol no
permite"
  },
  "requirements": ["RF01", "RF02", "RNF01", "RNF05", "RNF06"],
  "description": "Autenticación con cuentas sembradas, resolución de identidad en el servidor, matriz
de permisos por rol aplicada en cada operación y aislamiento por organización con respuestas 401, 403 y
 404 que no revelan datos. Enunciado §2.",
  "actors": ["Solicitante, Coordinador, Bodega y Auditor de ORG-A u ORG-B", "API del sistema, que
resuelve identidad, organización y rol"],
  "scope": ["Inicio y cierre de sesión con cuentas sembradas; sesión o token justificado en ADR-003",
"Hash apropiado de contraseñas y ausencia de secretos en el repositorio", "Ocho cuentas ficticias: una
por rol en cada organización, regenerables por seed", "Matriz de permisos aplicada en el servidor y
aislamiento por organización en toda operación", "Respuestas, errores y logs sin datos de otra
organización ni secretos"],
  "exclusions": ["Creación masiva de usuarios, recuperación de contraseña y proveedores de identidad
externos (no exigidos, enunciado §2)", "Selector de rol como reemplazo del inicio de sesión (prohibido
por RF01)"],
  "inputs": [
    {
      "field": "login",
      "type": "string; correo ficticio del seed, por ejemplo org-a-solicitante@example.test",
      "validation": ["Obligatorio", "Debe corresponder a una cuenta sembrada; el error no revela si la
cuenta existe"]
    },
    {
      "field": "password",
      "type": "string",
      "validation": ["Obligatorio", "Se verifica contra el hash almacenado", "Nunca se registra ni se
devuelve"]
    },
    {
      "field": "credencial de sesión",
      "type": "cookie de sesión o token bearer según ADR-003",
      "validation": ["Debe estar vigente y no revocada en cada petición", "Ausente, inválida o revocada
 produce 401"]
    },
    {
      "field": "organización y rol",
      "type": "derivados de la identidad autenticada",
      "validation": ["Cualquier organizationId o role enviado por el navegador se ignora y no
autoriza"]
    },
    {
      "field": "identificador de recurso",
      "type": "string",
      "validation": ["Se busca solo dentro de la organización autenticada", "Inexistente o de otra
organización produce 404"]
    }
  ],
  "process": ["Recibir login y contraseña, buscar la cuenta y verificar la contraseña contra su hash",
"Si son válidas, crear una sesión o token revocable; si no, responder 401 genérico sin crear sesión",
```

```
"En cada petición resolver identidad, organización y rol desde la credencial; sin credencial válida
responder 401", "Resolver el recurso filtrando por la organización de la identidad; si no existe en
ella responder 404", "Evaluar el permiso del rol sobre la operación según la matriz del enunciado; si
está prohibida responder 403 sin efectos", "Ejecutar la operación autorizada y registrar logs
estructurados con correlationId, sin contraseñas, hashes ni tokens", "En logout revocar la credencial;
cualquier uso posterior recibe 401"],
  "outputs": [
    {
      "condition": "Credenciales válidas",
      "result": "200 con cuenta, rol y organización, sin hash; se crea sesión o token"
    },
    {
      "condition": "Contraseña errónea o cuenta inexistente",
      "result": "401 con el mismo mensaje en ambos casos; no se crea sesión"
    },
    {
      "condition": "Logout",
      "result": "204; la credencial queda revocada de forma persistente"
    },
    {
      "condition": "Petición sin identidad válida",
      "result": "401 sin datos de negocio"
    },
    {
      "condition": "Recurso inexistente o de otra organización",
      "result": "404 sin revelar existencia ni datos"
    },
    {
      "condition": "Acción prohibida para el rol sobre un recurso de su organización",
      "result": "403 sin cambios persistidos"
    }
  ],
  "businessRules": ["Matriz oficial, enunciado §2. Solicitante: crear y editar sus borradores, enviar
su solicitud, consultar las propias y cancelar las propias en ENVIADA o RESERVADA", "Coordinador:
consultar solicitudes de su organización, reservar ENVIADA, registrar ENTREGADA sobre DESPACHADA, usar
y aprobar resúmenes de IA", "Bodega: consultar inventario y solicitudes de su organización y despachar
RESERVADA", "Auditor: consultar solicitudes, inventario y auditoría de su organización; no modifica
datos ni invoca el asistente", "Una operación no listada para un rol se deniega: 403 si el recurso es
de su organización. Según respuesta afirmativa de la profesora reportada por Conde José (CL-16/17/18),
el Coordinador lee inventario e historial de su organización y el Solicitante lee historial/tablero de
sus propias solicitudes sin inventario. Bodega no recibe auditoría. Evidencia original pendiente;
revisión renovada requerida", "Los permisos se comprueban en el servidor en cada operación; ocultar un
botón no es autorización", "La organización y el rol provienen de la identidad autenticada; un valor
enviado por el navegador no autoriza cambiar de organización", "No se admite un selector de rol como
reemplazo del inicio de sesión", "Contraseñas guardadas con hash apropiado; sin claves privadas ni
secretos en el repositorio", "Una cuenta por rol en cada organización con credenciales ficticias
publicadas para evaluación y forma documentada de regenerarlas", "Las reglas 401, 403 y 404 se aplican
también al contenido de respuestas, errores y logs"],
  "edgeCases": ["Contraseña errónea y login inexistente con respuesta indistinguible", "Credencial
revocada o expirada reutilizada", "Rol u organización adulterados en cuerpo, parámetros o encabezados",
 "Usuario de ORG-A que conoce el identificador B-001 de ORG-B", "Llamadas directas a la API sin pasar
por la interfaz", "Auditor que intenta una escritura dentro de su organización", "Solicitante que
consulta la solicitud de otro solicitante de su organización: 403 por la regla de acción prohibida
sobre recurso propio de la organización"],
  "assumptions": ["Sesión de servidor revocable como propuesta; la elección sesión o token se justifica
 en ADR-003 (G2)", "Algoritmo y parámetros de hash se fijan en ADR-003", "Los logins de las ocho
cuentas son los del anexo fixture-scenarios.json"],
  "openQuestions": ["CL-14: expiración de sesión, protección CSRF y política de contraseña (decisión
del equipo en ADR-003)", "CL-16, CL-17 y CL-18: respuesta afirmativa reportada por el coordinador;
fecha/canal y evidencia original pendientes, nueva revisión humana requerida"],
  "dependencies": ["Seed de cuentas y migraciones (RNF04, SPEC-04)", "Las SPEC-02 a SPEC-05 aplican
esta matriz de permisos a sus operaciones"],
  "acceptanceCriteria": [
    {
      "id": "AC-01-01",
      "requirements": ["RF01", "RNF01"],
      "kind": "negativo",
      "given": "un cliente sin sesión ni token",
      "when": "consulta el listado de solicitudes por la API",
      "then": "recibe 401 sin datos de solicitudes y no se crea ninguna sesión"
    },
    {
      "id": "AC-01-02",
      "requirements": ["RF02", "RNF01"],
      "kind": "permiso",
      "given": "un coordinador de ORG-A autenticado y la solicitud B-001 de ORG-B sembrada",
      "when": "consulta B-001 por su identificador",
      "then": "recibe 404 con el mismo cuerpo que para un identificador inexistente; la respuesta y el
log no contienen datos de B-001"
    },
    {
      "id": "AC-01-03",
      "requirements": ["RF02", "RNF01"],
      "kind": "permiso",
      "given": "un auditor de ORG-A autenticado y A-001 en ENVIADA",
      "when": "intenta reservar o modificar A-001",
      "then": "recibe 403; el estado de A-001, el inventario y los eventos de auditoría no cambian"
    },
    {
      "id": "AC-01-04",
      "requirements": ["RF01"],
      "kind": "positivo",
      "given": "el seed aplicado con las ocho cuentas ficticias",
```

```
      "when": "cada cuenta inicia sesión con su contraseña sembrada, ejecuta una operación permitida de
 su rol y cierra sesión",
      "then": "el login responde 200 con rol y organización correctos y sin hash; la operación
permitida tiene éxito; el logout responde 204 y la misma credencial recibe 401 después"
    },
    {
      "id": "AC-01-05",
      "requirements": ["RF01"],
      "kind": "positivo",
      "given": "una base recién migrada y sembrada",
      "when": "se consultan las cuentas en la base y se lee el runbook",
      "then": "existen ocho cuentas distintas, una por rol en ORG-A y en ORG-B, con los logins del
anexo; las contraseñas solo están como hash; el runbook publica las credenciales ficticias y el comando
 que las regenera"
    },
    {
      "id": "AC-01-06",
      "requirements": ["RF01", "RNF01"],
      "kind": "negativo",
      "given": "una cuenta existente y un login inexistente",
      "when": "se intenta iniciar sesión con contraseña errónea en la primera y con cualquier
contraseña en el segundo",
      "then": "ambos intentos reciben 401 con el mismo mensaje; no se crea sesión y la respuesta no
revela si la cuenta existe"
    },
    {
      "id": "AC-01-07",
      "requirements": ["RF02", "RNF01"],
      "kind": "permiso",
      "given": "un solicitante de ORG-A autenticado",
      "when": "intenta reservar A-001 de su organización y B-001 de ORG-B enviando organizationId ORG-B
 y role COORDINADOR adulterados, con sesión y token CSRF válidos",
      "then": "la identidad del servidor prevalece: A-001 recibe 403 por rol prohibido y B-001 recibe
404 por organización ajena; ninguna solicitud, stock o evento de éxito cambia"
    },
    {
      "id": "AC-01-08",
      "requirements": ["RF01"],
      "kind": "negativo",
      "given": "una credencial cerrada con logout",
      "when": "se reutiliza en cualquier operación",
      "then": "recibe 401; la revocación está persistida y no se ejecuta ninguna operación de negocio"
    },
    {
      "id": "AC-01-09",
      "requirements": ["RF02", "RNF01"],
      "kind": "permiso",
      "given": "usuarios autenticados de ORG-A y recursos sembrados de ORG-B",
      "when": "ejecutan dos lecturas cruzadas, por ejemplo detalle de B-001 y su auditoría, y dos
escrituras cruzadas, por ejemplo reservar y despachar B-001",
      "then": "las cuatro reciben 404; solicitudes, inventario y auditoría de ORG-B quedan idénticos
según snapshot antes y después"
    },
    {
      "id": "AC-01-10",
      "requirements": ["RNF01", "RNF06"],
      "kind": "fallo",
      "given": "respuestas y logs producidos por login correcto, login fallido, 401, 403, 404 y un
error interno controlado",
      "when": "se inspeccionan",
      "then": "los logs son estructurados con correlationId y ni logs ni respuestas contienen
contraseñas, hashes, tokens ni secretos"
    },
    {
      "id": "AC-01-11",
      "requirements": ["RF01"],
      "kind": "negativo",
      "given": "la interfaz web y la API sin sesión iniciada",
      "when": "se intenta entrar al flujo eligiendo un rol o llamando a una operación sin credencial",
      "then": "la interfaz solo ofrece inicio de sesión con credenciales y no existe selector de rol
que conceda acceso; la API responde 401"
    },
    {
      "id": "AC-01-12",
      "requirements": ["RF01"],
      "kind": "negativo",
      "given": "el repositorio en el commit evaluado",
      "when": "se ejecuta la detección de secretos documentada en CI",
      "then": "no se encuentran claves privadas, contraseñas reales ni secretos; solo existe
configuración de ejemplo sin secretos"
    },
    {
      "id": "AC-01-13",
      "requirements": ["RNF05"],
      "kind": "positivo",
      "given": "la pantalla de inicio y cierre de sesión a 390 y 1366 px de ancho",
      "when": "se opera solo con teclado, incluido un intento con credenciales erróneas",
      "then": "no hay desbordamiento horizontal; los campos tienen etiqueta; el error queda asociado al
 formulario y visible; la verificación manual se registra con navegador y fecha sin afirmar conformidad
 WCAG total"
    },
    {
      "id": "AC-01-14",
```

```
      "requirements": ["RF01", "RNF01"],
      "kind": "negativo",
      "given": "sesión cookie válida y solicitud propia BORRADOR; token CSRF ausente o inválido",
      "when": "intenta editar por PATCH o enviar por POST sin CSRF válido; repite con token válido y
datos correctos",
      "then": "sin token válido recibe 419 sin cambio de solicitud/inventario/eventos; con token válido
 supera CSRF y se aplican validación/autorización normales; también login/logout y escrituras IA exigen
 CSRF"
    }
  ]
}
```


<!-- spec-data:end -->

Decisiones y aclaraciones

- Precedencia de respuestas resuelta por el enunciado §2: 401 sin identidad; 404 para recurso inexistente o de otra organización; 403 para acción prohibida sobre recurso de su organización. Por eso se resuelve primero el recurso dentro de la organización y después el permiso del rol.

- Matriz de permisos tomada del enunciado; sustituye la matriz propuesta en 0.2 (ver diferencias D-01 y D-02 del cotejo).

- Pendientes: CL-14 (equipo); fecha/canal y evidencia original de CL-16/17/18, cuya respuesta afirmativa fue reportada por el coordinador. Cambio de permisos requiere nueva revisión.

Riesgos y plan de prueba

- R-02 acceso interorganización: AC-01-02, AC-01-07 y AC-01-09 con snapshots de base.

- Pruebas previstas: API con base real para 401/403/404, inspección de logs, detección de secretos en CI y revisión manual de teclado y anchos.

Cambios de versión

- 0.1: borrador inicial (commit 1aeacbf).

- 0.2-draft: ampliación a 10 AC sin fuente oficial.

- 0.3.1-draft: cotejo con el enunciado oficial; matriz oficial de permisos; formato del anexo 13 con entradas tipadas y AC dado/cuando/entonces; nuevos AC-01-11 a AC-01-13 (selector de rol, secretos, RNF05).

Cambio 0.3.1-draft: CL-16/17/18 confirmadas según reporte del coordinador; sin aprobación humana de esta nueva versión. Otros hallazgos G1 siguen pendientes.

Actualización 0.4-draft por Codex a solicitud del coordinador: hallazgos H-V/H-E atendidos documentalmente; los AC nuevos no son pruebas ejecutadas. Revisión humana sobre nuevo SHA PENDIENTE.

specs/SPEC-02.md

SPEC-02: Creación y envío de solicitudes

- Versión: 0.3-draft — no aprobada para implementar.

- Fuente vinculante: docs/examen-oficial/originales/Examen_Estudiantes_SDD_IA.pdf §2 (p. 3), §3 RF03–RF04 (p. 4), §5 RNF01/RNF05 (p. 6), §8 ejemplo AC-RF03-01 (p. 9); anexos 16_ejemplo_sdd.md y fixture-scenarios.json.

- Estado y aprobación: versión 0.3 elaborada con asistencia de IA a solicitud de Castro Edier (registro docs/evidence/ai-log/AI-001-cotejo-oficial-g1.md). Revisor humano distinto del autor: PENDIENTE. Fecha UTC y commit revisado: PENDIENTE.

El bloque siguiente es la fuente única. specs/generated/SPEC-02.json se genera con python scripts/export_specs.py; no editarlo a mano. Los AC son resultados esperados: ninguna prueba de producto se ha ejecutado.

<!-- spec-data:start -->


```
{
  "id": "SPEC-02",
  "version": "0.3-draft",
  "name": "Creación y envío de solicitudes",
  "status": "Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente",
  "story": {
    "id": "HU-02",
    "as": "solicitante de una organización",
    "want": "crear, editar y enviar una solicitud de kits válida",
    "soThat": "el coordinador pueda evaluarla y reservar existencias sin datos incompletos ni
inválidos"
  },
  "requirements": ["RF03", "RF04", "RF09", "RNF01", "RNF05"],
  "description": "Registro de solicitudes con código generado por el sistema, zona, prioridad NORMAL o
ALTA, fecha requerida, observaciones opcionales y de 1 a 10 líneas con SKU activos distintos y
cantidades enteras de 1 a 500; edición exclusiva del borrador por su dueño y transición BORRADOR a
ENVIADA auditada. Enunciado §3.",
  "actors": [
    "Solicitante dueño de la solicitud",
    "Coordinador, Bodega y Auditor: sin permiso para crear, editar ni enviar"
  ],
  "scope": [
    "Crear borrador con cabecera y líneas",
    "Editar el borrador propio",
    "Enviar: transición BORRADOR a ENVIADA con evento de auditoría",
    "Validaciones RF03 en el servidor y mensajes de error por campo"
  ],
  "exclusions": [
    "Reserva, despacho, entrega y cancelación (SPEC-03)",
    "Listados, filtros y tablero (SPEC-04)",
    "Eliminación de borradores (no exigida por el enunciado)"
  ],
  "inputs": [
    {
      "field": "zona",
      "type": "string de catálogo",
      "validation": ["Obligatoria", "Debe pertenecer al catálogo de zonas definido en CL-01 (propuesta:
 NORTE, SUR y CENTRO, valores del anexo)", "Zona desconocida produce 422"]
    },
    {
      "field": "prioridad",
      "type": "enum NORMAL o ALTA",
      "validation": ["Obligatoria", "Cualquier otro valor produce 422"]
    },
    {
      "field": "fechaRequerida",
      "type": "string fecha y hora RFC 3339 en UTC, como en el anexo fixture-scenarios.json (supuesto
CL-02)",
      "validation": ["Obligatoria", "Formato inválido produce 422", "Al enviar no puede ser anterior al
 instante de envío del servidor; igual o posterior se acepta"]
    },
    {
      "field": "observaciones",
      "type": "string opcional, texto plano",
      "validation": ["Máximo 1000 caracteres (supuesto CL-03)", "Se trata como dato no confiable y se
escapa al mostrarse"]
    },
    {
      "field": "lineas",
      "type": "array de objetos con sku y cantidad",
      "validation": ["Entre 1 y 10 elementos", "Sin SKU repetidos"]
    },
    {
      "field": "lineas.sku",
      "type": "string",
      "validation": ["SKU activo del inventario de la organización autenticada", "Repetido, inactivo,
inexistente o de otra organización produce 422"]
```

```
    },
    {
      "field": "lineas.cantidad",
      "type": "integer",
      "validation": ["Entero entre 1 y 500 inclusive", "Cero, negativo, decimal, texto o ausente
produce 422"]
    },
    {
      "field": "codigo, solicitante, organizationId, estado",
      "type": "generados por el servidor",
      "validation": ["Si el cliente los envía la petición se rechaza con 422 y nunca se reasignan"]
    }
  ],
  "process": [
    "Autenticar y autorizar según SPEC-01: solo el rol Solicitante crea borradores",
    "Validar esquema y reglas RF03 de cabecera y líneas; si falla responder 422 con el error asociado a
 cada campo, sin persistir nada",
    "Persistir cabecera y líneas en una transacción como BORRADOR con código único generado,
solicitante y organización tomados de la identidad",
    "Editar: comprobar dueño y estado BORRADOR, revalidar y reemplazar cabecera y líneas de forma
atómica",
    "Enviar: en una transacción bloquear la solicitud, comprobar dueño y estado BORRADOR, revalidar
RF03 incluida fechaRequerida contra el instante de envío, cambiar a ENVIADA y registrar el evento de
auditoría",
    "Responder con el estado confirmado; enviar no modifica el inventario"
  ],
  "outputs": [
    {"condition": "Creación válida", "result": "201 con id, código, estado BORRADOR y líneas
persistidas; inventario sin cambios"},
    {"condition": "Edición válida del borrador propio", "result": "200 con el borrador actualizado"},
    {"condition": "Envío válido", "result": "200 con estado ENVIADA; un evento de auditoría; existencia
 física y reservada sin cambios"},
    {"condition": "Datos inválidos", "result": "422 con el campo inválido; ninguna cabecera, línea ni
evento persistido"},
    {"condition": "Edición o envío por un rol distinto de Solicitante o por otro solicitante de su
organización", "result": "403 sin cambios"},
    {"condition": "Solicitud inexistente o de otra organización", "result": "404"},
    {"condition": "Edición o envío fuera de BORRADOR", "result": "409 sin cambios"}
  ],
  "businessRules": [
    "RF03: la solicitud contiene código generado, solicitante, organización, zona, prioridad NORMAL o
ALTA, fecha requerida, observaciones opcionales y de 1 a 10 líneas distintas",
    "Cada línea usa un SKU activo y una cantidad entera de 1 a 500; no se aceptan SKU repetidos,
negativos, decimales ni una fecha anterior al momento de envío",
    "Solo el borrador es editable y solo su dueño lo edita y lo envía",
    "Enviar no reserva inventario; la reserva pertenece a SPEC-03",
    "La validación ocurre en el servidor aunque la interfaz también valide",
    "El envío exitoso registra un evento de auditoría con los campos de RF09 en la misma transacción"
  ],
  "edgeCases": [
    "0, 1, 10 y 11 líneas",
    "Cantidades 0, 1, 500, 501, -1, 2.5, el texto 5 y cantidad ausente",
    "SKU repetido, inactivo, inexistente y de ORG-B",
    "Zona desconocida y prioridad MEDIA",
    "fechaRequerida con formato inválido, anterior, igual y posterior al instante de envío",
    "Observaciones de 1000 y 1001 caracteres",
    "Cuerpo con codigo, organizationId, estado o solicitante",
    "Doble envío de la misma solicitud"
  ],
  "assumptions": [
    "Los borradores se validan al crear, al editar y de nuevo al enviar",
    "Formato de fecha y zona horaria de visualización (America/Bogota) según CL-02, decisión del
equipo",
    "Límite de observaciones de 1000 caracteres según CL-03, decisión del equipo",
    "Formato del código generado según CL-10, decisión del equipo"
  ],
  "openQuestions": [
    "CL-01: catálogo definitivo de zonas y tratamiento de zona desconocida (decisión del equipo)",
    "CL-02: formato de fecha y visualización horaria (decisión del equipo)"
  ],
  "dependencies": [
    "SPEC-01: identidad y permisos",
    "Catálogo de SKU activos por organización sembrado (anexo fixture-scenarios.json)",
    "SPEC-04: estructura del evento de auditoría"
  ],
  "acceptanceCriteria": [
    {
      "id": "AC-02-01",
      "requirements": ["RF03"],
      "kind": "positivo",
      "given": "un solicitante de ORG-A autenticado y los SKU KIT-ALIMENTO y KIT-AGUA activos",
      "when": "crea un borrador con zona NORTE, prioridad ALTA, fechaRequerida futura y dos líneas
distintas con cantidades válidas",
      "then": "recibe 201; la base contiene la cabecera en BORRADOR y ambas líneas; el inventario no
cambia"
    },
    {
      "id": "AC-02-02",
      "requirements": ["RF03", "RNF01"],
      "kind": "negativo",
      "given": "un solicitante de ORG-A autenticado y un SKU activo",
      "when": "crea, edita o envía una solicitud cuya línea tiene cantidad 0",
      "then": "recibe 422 con un error asociado a la cantidad; el borrador conserva su estado previo,
```

```
no existe una solicitud ENVIADA nueva y el inventario y la auditoría de transiciones no cambian"
    },
    {
      "id": "AC-02-03",
      "requirements": ["RF04"],
      "kind": "negativo",
      "given": "una solicitud propia en ENVIADA",
      "when": "el solicitante dueño intenta editarla",
      "then": "recibe 409; cabecera, líneas y estado no cambian"
    },
    {
      "id": "AC-02-04",
      "requirements": ["RF03"],
      "kind": "limite",
      "given": "un borrador válido, el reloj de prueba en 2030-01-10T14:00:00Z y fechaRequerida
2030-01-10T13:59:59Z",
      "when": "el dueño lo envía",
      "then": "recibe 422 asociado a fechaRequerida; la solicitud sigue en BORRADOR y no se registra
evento"
    },
    {
      "id": "AC-02-05",
      "requirements": ["RF03"],
      "kind": "positivo",
      "given": "un solicitante de ORG-A autenticado",
      "when": "crea dos borradores válidos",
      "then": "cada uno recibe un código distinto generado por el sistema; solicitante es la cuenta
autenticada y organización es ORG-A en ambos"
    },
    {
      "id": "AC-02-06",
      "requirements": ["RF03", "RNF01"],
      "kind": "negativo",
      "given": "un solicitante de ORG-A autenticado",
      "when": "crea o envía con 0 u 11 líneas, SKU repetido, inactivo, inexistente o de ORG-B, cantidad
 -1, 501, 2.5 o texto, zona desconocida, prioridad MEDIA, observaciones de 1001 caracteres, o incluye
codigo, organizationId, estado o solicitante en el cuerpo",
      "then": "cada caso recibe 422 con el campo inválido; no quedan cabeceras ni líneas parciales, no
hay evento de éxito y el inventario no cambia"
    },
    {
      "id": "AC-02-07",
      "requirements": ["RF03", "RNF01"],
      "kind": "limite",
      "given": "un solicitante de ORG-A autenticado",
      "when": "crea borradores con 1 línea y con 10 líneas distintas, cantidades 1 y 500 y
observaciones vacías y de 1000 caracteres",
      "then": "todos se aceptan con 201 y se persisten completos"
    },
    {
      "id": "AC-02-08",
      "requirements": ["RF04", "RF09"],
      "kind": "positivo",
      "given": "un borrador válido propio con fechaRequerida igual o posterior al instante de envío",
      "when": "el dueño lo envía",
      "then": "recibe 200; la solicitud queda en ENVIADA con exactamente un evento de envío que
registra identidad, organización, recurso, acción, fecha UTC y correlationId; existencia física y
reservada no cambian"
    },
    {
      "id": "AC-02-09",
      "requirements": ["RF04"],
      "kind": "permiso",
      "given": "un borrador del solicitante de ORG-A",
      "when": "el coordinador, la bodega o el auditor de ORG-A intentan editarlo o enviarlo",
      "then": "cada intento recibe 403; cabecera, líneas y estado se conservan"
    },
    {
      "id": "AC-02-10",
      "requirements": ["RF04"],
      "kind": "negativo",
      "given": "solicitudes propias en ENVIADA, RESERVADA y DESPACHADA",
      "when": "el dueño reenvía la ENVIADA o intenta editar las demás",
      "then": "cada intento recibe 409, sin segundo evento de envío ni cambios de datos o inventario"
    },
    {
      "id": "AC-02-11",
      "requirements": ["RNF05"],
      "kind": "positivo",
      "given": "el formulario de creación y edición a 390 y 1366 px de ancho",
      "when": "se completa y envía solo con teclado, provocando también un error de validación",
      "then": "no hay desbordamiento horizontal; cada campo tiene etiqueta; los errores quedan
asociados a su campo y el foco es visible; la verificación manual se registra sin afirmar conformidad
WCAG total"
    }
  ]
}
```


<!-- spec-data:end -->

Decisiones y aclaraciones

- Prioridad oficial NORMAL o ALTA (RF03); la propuesta 0.2 ALTA/MEDIA/BAJA queda retirada (diferencia D-03).

- fechaRequerida como instante UTC para alinear con «momento de envío» (RF03) y con el anexo de datos; el equipo debe confirmar el supuesto CL-02 (diferencia D-13).

- AC-02-02 adopta la granularidad del ejemplo oficial AC-RF03-01.

Riesgos y plan de prueba

- Pruebas de dominio para límites RF03; API con base real para persistencia y ausencia de efectos parciales; E2E del envío; revisión manual de teclado y anchos.

- Oráculo del ejemplo oficial: antes y después del rechazo, estado BORRADOR, físico 10, reservado 0 y mismo número de eventos.

Cambios de versión

- 0.1: borrador inicial (commit 1aeacbf).

- 0.2-draft: ampliación a 11 AC sin fuente oficial.

- 0.3-draft: cotejo con el enunciado; prioridades oficiales, fecha como instante, entradas tipadas, AC dado/cuando/entonces, vínculo de RNF01 y del evento RF09.

specs/SPEC-03.md

SPEC-03: Inventario y transiciones

- Versión: 0.4-draft — no aprobada para implementar.

- Fuente vinculante: docs/examen-oficial/originales/Examen_Estudiantes_SDD_IA.pdf §2 (p. 3), §3 RF04–RF07 y condiciones de consistencia (p. 4), §4 RF09 (p. 5), §5 RNF02/RNF05 (p. 6), §11 (p. 12); anexos acceptance-oracles.md y fixture-scenarios.json.

- Estado y aprobación: versión 0.3 elaborada con asistencia de IA a solicitud de Castro Edier (registro docs/evidence/ai-log/AI-001-cotejo-oficial-g1.md). Revisor humano distinto del autor: PENDIENTE. Fecha UTC y commit revisado: PENDIENTE.

El bloque siguiente es la fuente única. specs/generated/SPEC-03.json se genera con python scripts/export_specs.py; no editarlo a mano. Los AC son resultados esperados: ninguna prueba de producto se ha ejecutado.

<!-- spec-data:start -->


```
{
  "id": "SPEC-03",
  "version": "0.4-draft",
  "name": "Inventario y transiciones",
  "status": "Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente",
  "story": {
    "id": "HU-03",
    "as": "coordinador, encargado de bodega o solicitante dueño de una organización",
    "want": "reservar, despachar, registrar la entrega y cancelar solicitudes mediante transiciones
controladas",
    "soThat": "el inventario nunca quede negativo ni se prometa dos veces la misma existencia"
  },
  "requirements": ["RF02", "RF04", "RF05", "RF06", "RF07", "RF09", "RNF02", "RNF05"],
  "description": "Transiciones ENVIADA a RESERVADA a DESPACHADA a ENTREGADA y cancelación desde ENVIADA
 o RESERVADA, con inventario por organización y SKU, reserva atómica de todas las líneas, idempotencia
con Idempotency-Key y auditoría confirmada en la misma transacción. Enunciado §3.",
  "actors": ["Coordinador: reserva ENVIADA y registra ENTREGADA sobre DESPACHADA", "Bodega: despacha
RESERVADA", "Solicitante dueño: cancela sus solicitudes en ENVIADA o RESERVADA", "Auditor: sin permiso
de transición"],
  "scope": ["Reserva total o nula con Idempotency-Key y control de concurrencia", "Despacho, entrega y
cancelación con sus efectos exactos sobre el inventario", "Rechazo 409 de toda transición no indicada,
sin efectos", "Evento de auditoría y resultado idempotente confirmados junto con estado e inventario"],
  "exclusions": ["Ajustes manuales de existencia física: no hay API de ajuste; el stock inicial
proviene del seed (CL-06)", "Devoluciones, rutas y GPS (fuera del alcance, enunciado §1)",
"Idempotencia de operaciones distintas de la reserva (no exigida; CL-11)"],
  "inputs": [
    {
      "field": "requestId",
      "type": "string en la ruta",
      "validation": ["Debe existir en la organización autenticada; si no, 404"]
    },
    {
      "field": "operación",
      "type": "enum RESERVAR, DESPACHAR, ENTREGAR o CANCELAR (una ruta por operación según el contrato
G2)",
      "validation": ["Determina el rol permitido y el estado de origen", "Rol no permitido sobre
recurso de su organización produce 403"]
    },
    {
      "field": "Idempotency-Key",
      "type": "encabezado string de 1 a 128 caracteres imprimibles (supuesto CL-11)",
      "validation": ["Obligatorio en RESERVAR; ausente o inválido produce 422 sin escritura
(supuesto)", "Se procesa solo después de autenticar y autorizar"]
    },
    {
      "field": "cuerpo de la reserva",
      "type": "objeto JSON según el contrato G2; puede ser vacío",
      "validation": ["Su forma canónica junto con requestId forma la huella de contenido de la clave"]
    },
    {
      "field": "inventario por SKU",
      "type": "onHand entero no negativo, reserved entero no negativo; disponible derivado igual a
onHand menos reserved",
      "validation": ["reserved nunca supera onHand", "Pertenece a una sola organización"]
    }
  ],
  "process": ["Autenticar; resolver la solicitud dentro de la organización (404 si no existe en ella);
autorizar el rol para la operación (403 si no)", "RESERVAR: tras autorizar, buscar la clave en el
ámbito clave, usuario, organización y operación; si existe con la misma huella devolver el código y
cuerpo almacenados sin nuevos efectos; si la huella difiere responder 409", "Abrir transacción;
bloquear la solicitud y las filas de inventario de sus SKU en orden estable por SKU", "Verificar el
estado de origen; si la transición no está indicada en RF04 responder 409 sin cambios", "RESERVAR desde
 ENVIADA: comprobar disponible mayor o igual que la cantidad en todas las líneas; si alguna falla
responder 409 y revertir todo; si todas cumplen, aumentar reserved de cada línea y pasar a RESERVADA",
"DESPACHAR desde RESERVADA: disminuir onHand y reserved en las cantidades de la solicitud y pasar a
```

```
DESPACHADA", "ENTREGAR desde DESPACHADA: pasar a ENTREGADA sin tocar el inventario", "CANCELAR desde
ENVIADA o RESERVADA por el solicitante dueño: si estaba RESERVADA disminuir reserved exactamente en sus
 cantidades sin tocar onHand; pasar a CANCELADA", "Registrar el evento de auditoría y, en la reserva,
el resultado idempotente dentro de la misma transacción; confirmar; cualquier fallo antes del commit
revierte todo", "Responder con el estado y las cantidades confirmados"],
  "outputs": [
    {
      "condition": "Transición válida",
      "result": "200 con estado y cantidades confirmados; un evento de auditoría"
    },
    {
      "condition": "Repetición con la misma clave y el mismo contenido dentro de la retención",
      "result": "El mismo código y cuerpo originales, sin nueva reserva ni nuevo evento"
    },
    {
      "condition": "Misma clave con contenido distinto",
      "result": "409 sin efectos"
    },
    {
      "condition": "Alguna línea sin disponibilidad suficiente",
      "result": "409; ninguna línea ni el estado cambian"
    },
    {
      "condition": "Transición no indicada, incluida una segunda reserva con otra clave",
      "result": "409 conservando datos e inventario"
    },
    {
      "condition": "Rol no autorizado para la operación sobre recurso de su organización",
      "result": "403 sin efectos y sin almacenar la clave"
    },
    {
      "condition": "Solicitud de otra organización o inexistente",
      "result": "404 sin efectos"
    }
  ],
  "businessRules": ["RF04: flujo base BORRADOR, ENVIADA, RESERVADA, DESPACHADA, ENTREGADA; ENVIADA y
RESERVADA pueden pasar a CANCELADA por el solicitante dueño; toda transición no indicada se rechaza con
 409 y conserva datos e inventario", "RF05: la reserva cubre todas las líneas o ninguna; solo desde
ENVIADA; disponible igual a existencia física menos reservada; las tres cantidades no negativas",
"RF06: cancelar una RESERVADA libera exactamente su reserva sin cambiar la existencia física; despachar
 disminuye física y reservada en las cantidades de la solicitud; ENTREGADA no altera inventario;
cancelar una ENVIADA no altera inventario", "RF07: cada petición de reserva incluye Idempotency-Key;
misma clave, usuario, organización, operación y contenido repiten el resultado sin duplicar efectos;
misma clave con contenido diferente devuelve 409; el resultado se conserva al menos 24 horas", "La
clave se procesa después de autenticar y autorizar y no permite recuperar la respuesta de otro
usuario", "Dos peticiones simultáneas que compiten por existencias insuficientes no pueden producir dos
 reservas exitosas; un error antes del commit no deja reserva parcial", "Estado, inventario, evento de
auditoría y resultado idempotente se confirman juntos", "Cada operación afecta solo el inventario de su
 organización"],
  "edgeCases": ["Disponible exactamente igual a la cantidad pedida", "Una línea suficiente y otra
insuficiente en la misma solicitud", "A-001 y A-002 reservadas a la vez, 7 unidades cada una de KIT-
ALIMENTO con existencia física 10", "Doble despacho de la misma solicitud", "Entregar una RESERVADA;
cancelar BORRADOR, DESPACHADA o ENTREGADA; cualquier salida de CANCELADA o ENTREGADA", "Repetición de
clave a las 23 h 59 min y a las 24 h", "Misma clave textual usada por otro usuario u otra
organización", "Reserva sin Idempotency-Key", "Fallo inducido antes del commit", "Rol incorrecto para
cada operación"],
  "assumptions": ["Retención de la clave exactamente 24 horas desde su creación; en ese instante deja
de repetir (CL-11, decisión del equipo)", "Se almacenan las respuestas completadas de la reserva,
incluido el 409 de negocio; no se almacenan 401, 403, 422 ni 500, que pueden reintentarse con la misma
clave (CL-04; debe fijarse en el contrato G2)", "Clave ausente produce 422 (decisión del equipo)", "No
existe API de ajuste de stock (CL-06)"],
  "openQuestions": ["CL-04 y CL-11: confirmar en el contrato OpenAPI la política de errores
almacenados, reintentos y expiración"],
  "dependencies": ["SPEC-01: identidad y matriz de permisos", "SPEC-02: solicitudes en ENVIADA",
"SPEC-04: estructura del evento de auditoría", "Base relacional con transacciones y bloqueo de filas
(ADR de transacciones e idempotencia, G2)"],
  "acceptanceCriteria": [
    {
      "id": "AC-03-01",
      "requirements": ["RF05", "RNF02"],
      "kind": "positivo",
      "given": "el seed restablecido: KIT-ALIMENTO de ORG-A con físico 10 y reservado 0, A-001 ENVIADA
con 7 unidades y el coordinador de ORG-A autenticado",
      "when": "reserva A-001 con una Idempotency-Key nueva",
      "then": "recibe 200; A-001 queda RESERVADA; KIT-ALIMENTO queda con físico 10, reservado 7 y
disponible 3; hay un evento de reserva; el inventario de ORG-B no cambia"
    },
    {
      "id": "AC-03-02",
      "requirements": ["RF05", "RNF02"],
      "kind": "negativo",
      "given": "una solicitud ENVIADA de ORG-A con una línea suficiente de 5 KIT-AGUA (físico 20) y
otra insuficiente de 9 KIT-HIGIENE (físico 8)",
      "when": "el coordinador la reserva",
      "then": "recibe 409; el estado sigue ENVIADA; reservado de ambos SKU sin cambios; no hay evento
de éxito ni resultado parcial"
    },
    {
      "id": "AC-03-03",
      "requirements": ["RF05", "RF07", "RNF02"],
      "kind": "fallo",
      "given": "dos solicitudes ENVIADA que compiten por existencias insuficientes del mismo SKU",
      "when": "se reservan simultáneamente con claves distintas mediante una barrera de sincronización,
```

```
 repitiendo el escenario limpio al menos 20 veces",
      "then": "en ninguna repetición se confirman ambas; reservado nunca supera físico y ninguna
cantidad queda negativa"
    },
    {
      "id": "AC-03-04",
      "requirements": ["RF07", "RNF02"],
      "kind": "negativo",
      "given": "A-001 reservada con la clave K1",
      "when": "el mismo coordinador repite K1 con el mismo contenido y después repite K1 con otro
requestId o cuerpo",
      "then": "la repetición idéntica devuelve el mismo código y cuerpo, reservado sigue en 7 y hay un
solo evento; la repetición con contenido distinto recibe 409 sin efectos"
    },
    {
      "id": "AC-03-05",
      "requirements": ["RF04", "RF06", "RNF02"],
      "kind": "positivo",
      "given": "A-001 RESERVADA con KIT-ALIMENTO en físico 10 y reservado 7, en dos escenarios
limpios",
      "when": "en el primero el solicitante dueño cancela; en el segundo la bodega despacha y luego el
coordinador registra la entrega",
      "then": "la cancelación deja CANCELADA con físico 10, reservado 0 y disponible 10; el despacho
deja DESPACHADA con físico 3, reservado 0 y disponible 3; la entrega deja ENTREGADA con las mismas
cantidades; un evento por transición"
    },
    {
      "id": "AC-03-06",
      "requirements": ["RF04", "RF06"],
      "kind": "negativo",
      "given": "A-002 ENVIADA",
      "when": "el solicitante dueño la cancela y luego repite la cancelación",
      "then": "la primera deja CANCELADA con un evento y sin cambios de físico o reservado; la segunda
recibe 409 sin efectos"
    },
    {
      "id": "AC-03-07",
      "requirements": ["RF04", "RNF02"],
      "kind": "negativo",
      "given": "solicitudes en cada estado del flujo",
      "when": "se intenta cada transición no indicada en RF04: reservar BORRADOR o RESERVADA, despachar
 ENVIADA, entregar RESERVADA, cancelar BORRADOR, DESPACHADA o ENTREGADA y cualquier transición desde
CANCELADA o ENTREGADA",
      "then": "cada intento recibe 409; los snapshots de solicitud, líneas, inventario y auditoría de
éxito son idénticos antes y después"
    },
    {
      "id": "AC-03-08",
      "requirements": ["RF05", "RF07", "RNF02"],
      "kind": "fallo",
      "given": "el seed restablecido con KIT-ALIMENTO de ORG-A en físico 10 y A-001 y A-002 ENVIADA con
 7 unidades cada una",
      "when": "se reservan simultáneamente con claves distintas",
      "then": "una recibe 200 y la otra 409, sin fijar cuál; KIT-ALIMENTO queda con físico 10,
reservado 7 y disponible 3; existe exactamente un evento de reserva"
    },
    {
      "id": "AC-03-09",
      "requirements": ["RF05", "RF09", "RNF02"],
      "kind": "fallo",
      "given": "A-001 ENVIADA y un fallo inducido al escribir el evento de auditoría antes del commit",
      "when": "el coordinador reserva A-001",
      "then": "recibe 500 con correlationId sanitizado; la transacción revierte estado, stock y
auditoría; no se conserva resultado idempotente, permitiendo reintento con la misma clave"
    },
    {
      "id": "AC-03-10",
      "requirements": ["RF07"],
      "kind": "limite",
      "given": "una reserva exitosa con K1 creada en el instante t0 del reloj de prueba",
      "when": "el mismo coordinador repite K1 con el mismo contenido en t0 más 23 h 59 min, y luego con
 otro requestId",
      "then": "la repetición idéntica devuelve la respuesta original con un único evento; la variante
con otro requestId recibe 409"
    },
    {
      "id": "AC-03-11",
      "requirements": ["RF07"],
      "kind": "limite",
      "given": "K1 creada en t0 para A-001, que ya está RESERVADA",
      "when": "se reutiliza K1 en t0 más 24 h, con la retención vencida según el supuesto CL-11",
      "then": "no hay repetición del resultado; la operación se reevalúa y recibe 409 porque A-001 ya
no está ENVIADA; reservado no cambia"
    },
    {
      "id": "AC-03-12",
      "requirements": ["RF07", "RF02"],
      "kind": "permiso",
      "given": "una reserva con K1 hecha por el coordinador de ORG-A",
      "when": "el coordinador de ORG-B usa K1 para reservar B-001, y aparte llega una reserva sin
Idempotency-Key",
      "then": "K1 en ORG-B se trata como clave independiente y nunca devuelve la respuesta de ORG-A; la
 reserva sin clave recibe 422 sin escritura"
```

```
    },
    {
      "id": "AC-03-13",
      "requirements": ["RF04", "RF06", "RNF02"],
      "kind": "negativo",
      "given": "A-001 RESERVADA con KIT-ALIMENTO en físico 10 y reservado 7",
      "when": "la bodega la despacha dos veces y después el coordinador registra la entrega",
      "then": "el primer despacho recibe 200 y el segundo 409; físico y reservado disminuyen una sola
vez hasta físico 3 y reservado 0; la entrega solo cambia el estado y añade un evento"
    },
    {
      "id": "AC-03-14",
      "requirements": ["RF07", "RF04"],
      "kind": "negativo",
      "given": "A-001 RESERVADA mediante la clave K1",
      "when": "el coordinador intenta reservar A-001 con otra clave K2",
      "then": "recibe 409 porque el estado ya no es ENVIADA; reservado sigue en 7 y K2 no produce
efectos"
    },
    {
      "id": "AC-03-15",
      "requirements": ["RF02", "RF04", "RF07"],
      "kind": "permiso",
      "given": "A-001 en ENVIADA, RESERVADA o DESPACHADA según el caso, en escenarios limpios de
ORG-A",
      "when": "la bodega o el solicitante intentan reservar, el coordinador o el auditor intentan
despachar, la bodega intenta registrar la entrega y el coordinador intenta cancelar",
      "then": "cada intento recibe 403 sin cambios de estado, inventario ni auditoría; la Idempotency-
Key enviada en un intento no autorizado no se almacena ni permite recuperar respuestas"
    },
    {
      "id": "AC-03-16",
      "requirements": ["RNF05"],
      "kind": "positivo",
      "given": "las pantallas con las acciones reservar, despachar, entregar y cancelar a 390 y 1366 px
 de ancho",
      "when": "cada rol ejecuta su acción solo con teclado, provocando también un rechazo 409",
      "then": "no hay desbordamiento horizontal; los controles tienen nombre visible; el rechazo se
muestra asociado a la acción; la verificación manual se registra sin afirmar conformidad WCAG total"
    },
    {
      "id": "AC-03-17",
      "requirements": ["RF04", "RF06", "RNF02", "RF09"],
      "kind": "fallo",
      "given": "A-001 RESERVADA, físico 10/reservado 7/disponible 3, dos procesos PostgreSQL reales y
barrera",
      "when": "Bodega despacha y Solicitante dueño cancela simultáneamente la misma solicitud",
      "then": "una petición recibe 200 y la otra 409; si gana despacho queda DESPACHADA con 3/0/3, si
gana cancelación queda CANCELADA con 10/0/10; exactamente un evento exitoso nuevo, sin efectos
parciales"
    }
  ]
}
```


<!-- spec-data:end -->

Decisiones y aclaraciones

- Actores por transición tomados del enunciado §2: la cancelación es del solicitante dueño y la entrega la registra el coordinador (diferencias D-01 y D-02 frente a la matriz 0.2).

- Oráculos de cantidades copiados del anexo acceptance-oracles.md; restablecer el seed antes de cada escenario.

- Supuestos del equipo: CL-04, CL-06 y CL-11. No requieren decisión del cliente, pero deben fijarse en el contrato G2 y probarse.

Riesgos y plan de prueba

- R-01 reserva duplicada, R-03 reutilización de clave y R-11 auditoría divergente.

- Pruebas previstas: integración con PostgreSQL real (sin mocks de inventario), concurrencia con barrera de sincronización, reloj controlado para la frontera de 24 h, fallo inducido antes del commit y comparación de snapshots. Oráculos escritos antes de ejecutar y sin reutilizar el algoritmo de producción.

Cambios de versión

- 0.1: borrador inicial (commit 1aeacbf).

- 0.2-draft: ampliación a 13 AC sin fuente oficial.

- 0.3-draft: cotejo con el enunciado; actores oficiales por transición, oráculos del anexo, AC-03-14 (segunda reserva con otra clave), AC-03-15 (permisos e idempotencia tras autorizar) y AC-03-16 (RNF05).

Actualización 0.4-draft por Codex a solicitud del coordinador: hallazgos H-V/H-E atendidos documentalmente; los AC nuevos no son pruebas ejecutadas. Revisión humana sobre nuevo SHA PENDIENTE.

specs/SPEC-04.md

SPEC-04: Consultas y auditoría

- Versión: 0.3.2-draft — no aprobada para implementar.

- Fuente vinculante: docs/examen-oficial/originales/Examen_Estudiantes_SDD_IA.pdf §1 objetivos observables (p. 2), §2 (p. 3), §4 RF08–RF09 (p. 5), §5 RNF03–RNF06 (p. 6), §11 operación (p. 12), §12 ejecución reproducible (p. 13).

- Estado y aprobación: versión 0.3 elaborada con asistencia de IA a solicitud de Castro Edier (registro docs/evidence/ai-log/AI-001-cotejo-oficial-g1.md). Revisor humano distinto del autor: PENDIENTE. Fecha UTC y commit revisado: PENDIENTE.

El bloque siguiente es la fuente única. specs/generated/SPEC-04.json se genera con python scripts/export_specs.py; no editarlo a mano. Los AC son resultados esperados: ninguna prueba de producto se ha ejecutado.

<!-- spec-data:start -->


```
{
  "id": "SPEC-04",
  "version": "0.3.2-draft",
  "name": "Consultas y auditoría",
  "status": "Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente",
  "story": {
    "id": "HU-04",
    "as": "solicitante, coordinador, encargado de bodega o auditor de una organización",
    "want": "consultar solicitudes, tablero, inventario e historial de auditoría dentro de mi alcance",
    "soThat": "pueda dar seguimiento y demostrar quién realizó cada operación sin ver datos de otra
organización"
  },
  "requirements": ["RF02", "RF08", "RF09", "RNF03", "RNF04", "RNF05", "RNF06"],
  "description": "Listados paginados con filtros, tablero de cantidades por estado e inventario,
historial de auditoría inmutable vía API y condiciones operativas de consulta: rendimiento, arranque
reproducible, logs con correlationId y health y readiness. Enunciado §4 y §5.",
  "actors": [
    "Solicitante: solo sus solicitudes",
    "Coordinador: solicitudes, inventario e historial de su organización (CL-16/17 reportadas); Bodega:
 solicitudes e inventario sin auditoría",
    "Auditor: solicitudes, inventario y auditoría de su organización",
    "Operador o evaluador: arranque, health y readiness"
  ],
  "scope": [
    "Listados paginados con máximo 100 elementos y filtros por estado, prioridad y zona",
    "Tablero con cantidades por estado y cantidades físicas, reservadas y disponibles",
    "Escritura y consulta del historial de auditoría sin edición ni borrado por API",
    "Logs estructurados con correlationId, health y readiness diferenciados",
    "Rendimiento de listados y tablero y arranque desde clon limpio"
  ],
  "exclusions": [
    "Exportaciones, reportes adicionales y búsqueda de texto libre (no exigidos)",
    "Rendimiento del asistente de IA (excluido de RNF03)"
  ],
  "inputs": [
    {
      "field": "page",
      "type": "integer",
      "validation": ["Mayor o igual que 1; valor por defecto 1", "Inválido produce 422"]
    },
    {
      "field": "pageSize",
      "type": "integer",
      "validation": ["Entre 1 y 100; valor por defecto 20 (supuesto)", "0, 101 o no entero produce
422"]
    },
    {
      "field": "estado",
      "type": "enum BORRADOR, ENVIADA, RESERVADA, DESPACHADA, ENTREGADA o CANCELADA; opcional",
      "validation": ["Otro valor produce 422"]
    },
    {
      "field": "prioridad",
      "type": "enum NORMAL o ALTA; opcional",
      "validation": ["Otro valor produce 422"]
    },
    {
      "field": "zona",
      "type": "string del catálogo de CL-01; opcional",
      "validation": ["Zona desconocida produce 422 (supuesto)"]
    },
    {
      "field": "requestId del historial",
      "type": "string",
      "validation": ["Debe existir en la organización autenticada; si no, 404"]
    },
    {
```

```
      "field": "X-Correlation-Id",
      "type": "encabezado string opcional (supuesto: UUID)",
      "validation": ["Si falta o es inválido el servidor genera uno", "Nunca se registra sin
sanitizar"]
    }
  ],
  "process": [
    "Autenticar y determinar el alcance: Solicitante, solo sus solicitudes; Coordinador, Bodega y
Auditor, su organización según la matriz de SPEC-01",
    "Aplicar el alcance antes de filtros, conteos y paginación; ordenar de forma estable por fecha de
creación e identificador",
    "Tablero: contar solicitudes por estado y calcular físico, reservado y disponible por SKU con el
mismo alcance",
    "Auditoría: los módulos de SPEC-02, SPEC-03 y SPEC-05 escriben el evento en la misma transacción
del cambio con identidad, organización, recurso, acción, fecha UTC y correlationId; la consulta
devuelve eventos en orden temporal",
    "Registrar logs técnicos estructurados con correlationId para cada petición, incluidos los
rechazos, sin secretos",
    "Health responde si el proceso está vivo; readiness comprueba la base de datos y las migraciones
aplicadas; el proveedor de IA no forma parte de readiness"
  ],
  "outputs": [
    {"condition": "Listado válido", "result": "200 con items, page, pageSize y total del alcance; una
página fuera de rango devuelve items vacío"},
    {"condition": "Tablero", "result": "200 con conteos por estado y cantidades de inventario según el
rol"},
    {"condition": "Historial de una solicitud", "result": "200 con los eventos en orden temporal"},
    {"condition": "Parámetros inválidos", "result": "422"},
    {"condition": "Sin identidad, rol no permitido o recurso ajeno", "result": "401, 403 o 404 según
SPEC-01; nunca conteos de otra organización"},
    {"condition": "Health y readiness", "result": "Health 200 si el proceso vive; readiness 200 solo
con base disponible y migraciones aplicadas, 503 en otro caso"}
  ],
  "businessRules": [
    "RF08: listados paginados con máximo 100 elementos por página, filtros por estado, prioridad y zona
 y tablero con cantidades por estado; el solicitante ve solo sus solicitudes",
    "El tablero permite observar solicitudes por estado y cantidades disponibles y reservadas
(objetivos del cliente, §1)",
    "RF09: se registra cada transición exitosa y cada aprobación de resumen con identidad,
organización, recurso, acción, fecha UTC y correlationId; no hay edición ni borrado por API; un rechazo
 solo genera log técnico",
    "RF02: listados, auditoría y consultas agregadas respetan el límite de organización",
    "RNF03: p95 menor o igual a 700 ms y errores menores al 1 % con 20 usuarios virtuales durante 60 s
tras 5 s de calentamiento, sobre 2.000 solicitudes sembradas, sin IA; reportar hardware y herramienta",
    "RNF04: iniciar desde un clon limpio en 15 min o menos con versiones fijadas, migraciones, seed y
un comando documentado; la descarga inicial se reporta aparte",
    "RNF06: logs estructurados con correlationId sin secretos; health y readiness diferenciados",
    "El seed pequeño y el seed de carga de 2.000 solicitudes son independientes (enunciado §12)"
  ],
  "edgeCases": [
    "Página fuera de rango y filtros combinados sin coincidencias",
    "pageSize 0, 1, 100 y 101",
    "Empates de fecha de creación en la ordenación",
    "correlationId malicioso o excesivamente largo",
    "Solicitante sin solicitudes",
    "Auditor de ORG-A con el identificador de un evento o solicitud de ORG-B",
    "Base detenida durante la comprobación de readiness"
  ],
  "assumptions": [
    "pageSize por defecto 20 y orden por fecha de creación e identificador (decisión del equipo)",
    "Formato UUID para correlationId (decisión del equipo)",
    "RNF03, RNF04 y health y readiness se ubican en esta SPEC porque cubren consultas y operación;
ninguna otra SPEC trata la operación"
  ],
  "openQuestions": [
    "CL-16: respuesta afirmativa docente reportada por el coordinador; evidencia original pendiente",
    "CL-17: Coordinador consulta historial de su organización y Solicitante de sus solicitudes según
respuesta reportada; evidencia original pendiente",
    "CL-18: tablero propio sin inventario para Solicitante según respuesta reportada; evidencia
original pendiente",
    "CL-15: retención de auditoría y de logs técnicos (equipo)"
  ],
  "dependencies": [
    "SPEC-01: alcance por rol y organización",
    "SPEC-02, SPEC-03 y SPEC-05: producen los eventos de auditoría",
    "Seed de carga con 2.000 solicitudes y herramienta de carga k6 o equivalente"
  ],
  "acceptanceCriteria": [
    {
      "id": "AC-04-01",
      "requirements": ["RF08", "RF02"],
      "kind": "permiso",
      "given": "un solicitante de ORG-A con solicitudes propias y existen solicitudes de otro
solicitante de ORG-A y de ORG-B",
      "when": "lista solicitudes",
      "then": "solo recibe las propias; total cuenta solo las propias; pageSize nunca supera 100"
    },
    {
      "id": "AC-04-02",
      "requirements": ["RF08", "RF02"],
      "kind": "permiso",
      "given": "solicitudes de ORG-A y ORG-B en varios estados",
      "when": "el coordinador, la bodega y el auditor de ORG-A filtran por estado, prioridad y zona y
```

```
consultan el tablero",
      "then": "resultados y conteos incluyen solo solicitudes de ORG-A"
    },
    {
      "id": "AC-04-03",
      "requirements": ["RF09"],
      "kind": "positivo",
      "given": "una transición exitosa de cada tipo (envío, reserva, despacho, entrega y cancelación) y
 una aprobación de resumen",
      "when": "cada operación se confirma",
      "then": "existe exactamente un evento por operación con identidad, organización, recurso, acción,
 fecha UTC y correlationId, confirmado en la misma transacción que el cambio de estado o inventario"
    },
    {
      "id": "AC-04-04",
      "requirements": ["RF09"],
      "kind": "negativo",
      "given": "el contrato OpenAPI publicado y una operación rechazada con 409, 403 o 422",
      "when": "se revisan las rutas y se consulta la auditoría después del rechazo",
      "then": "no existe ruta que edite o borre auditoría; el rechazo deja como máximo un log técnico y
 ningún evento de transición exitosa"
    },
    {
      "id": "AC-04-05",
      "requirements": ["RF08"],
      "kind": "limite",
      "given": "un usuario autorizado",
      "when": "pide pageSize 0, 101 o no entero, page 0 o un estado desconocido, y después una página
fuera de rango",
      "then": "los parámetros inválidos reciben 422; la página fuera de rango recibe 200 con items
vacío y sin datos ajenos"
    },
    {
      "id": "AC-04-06",
      "requirements": ["RF08"],
      "kind": "positivo",
      "given": "datos conocidos de ORG-A sembrados para la prueba",
      "when": "un usuario de la organización combina filtros de estado, prioridad y zona",
      "then": "items contiene solo las coincidencias autorizadas; total y tablero coinciden con una
consulta directa a la base con el mismo alcance, calculada de forma independiente"
    },
    {
      "id": "AC-04-07",
      "requirements": ["RF09", "RNF06"],
      "kind": "positivo",
      "given": "una transición enviada con un X-Correlation-Id válido",
      "when": "se completa",
      "then": "el mismo correlationId aparece en la respuesta, en el log estructurado y en el evento;
actor y organización son correctos y la fecha está en UTC"
    },
    {
      "id": "AC-04-08",
      "requirements": ["RF09"],
      "kind": "negativo",
      "given": "eventos de auditoría existentes",
      "when": "se envían PUT, PATCH y DELETE a las rutas de auditoría",
      "then": "reciben 404 o 405 y el contenido de la auditoría es idéntico antes y después"
    },
    {
      "id": "AC-04-09",
      "requirements": ["RNF03"],
      "kind": "positivo",
      "given": "el seed de carga con 2.000 solicitudes y la IA excluida",
      "when": "k6 o una herramienta equivalente ejecuta 20 usuarios virtuales sobre listados y tablero,
 descarta 5 s de calentamiento y mide 60 s",
      "then": "p95 es menor o igual a 700 ms por endpoint y la tasa de errores menor al 1 %; se
conservan la salida real, el hardware, la herramienta y su versión"
    },
    {
      "id": "AC-04-10",
      "requirements": ["RF08", "RF02"],
      "kind": "permiso",
      "given": "inventario sembrado de ORG-A y ORG-B",
      "when": "bodega, auditor y coordinador de ORG-A consultan inventario, y el solicitante de ORG-A
intenta consultarlo y consulta su tablero",
      "then": "bodega, auditor y coordinador ven físico, reservado y disponible consistentes solo de
ORG-A; disponible igual a físico menos reservado; el solicitante recibe 403 en inventario y su tablero
muestra solo conteos de solicitudes propias, sin inventario ni conteos ajenos (CL-16/18 reportadas)"
    },
    {
      "id": "AC-04-11",
      "requirements": ["RF09", "RF02"],
      "kind": "permiso",
      "given": "eventos de auditoría de ORG-A y de ORG-B",
      "when": "auditor y coordinador de ORG-A consultan historial; solicitante consulta historial
propio y ajeno; bodega consulta historial; todos intentan acceder al historial de una solicitud de
ORG-B",
      "then": "auditor y coordinador ven solo eventos de ORG-A; solicitante solo eventos de sus
solicitudes y obtiene 403 para una solicitud de otro dueño de ORG-A; bodega recibe 403 para recurso de
ORG-A; identificadores inexistentes o de ORG-B reciben 404 sin datos (CL-17 y semántica oficial del
apartado 2)"
    },
    {
```

```
      "id": "AC-04-12",
      "requirements": ["RNF04"],
      "kind": "positivo",
      "given": "un clon limpio del commit evaluado con versiones fijadas y configuración de ejemplo sin
 secretos",
      "when": "se ejecuta el comando único documentado en el runbook",
      "then": "las migraciones y el seed pequeño quedan aplicados y la aplicación responde en 15 min o
menos medidos sin contar la descarga inicial, que se reporta aparte; se conservan tiempos, comando y
entorno"
    },
    {
      "id": "AC-04-13",
      "requirements": ["RNF06"],
      "kind": "fallo",
      "given": "la aplicación levantada",
      "when": "se consultan health y readiness con la base disponible y luego con la base detenida",
      "then": "health responde 200 en ambos casos; readiness responde 200 con base disponible y 503 sin
 base; el estado del proveedor de IA no afecta readiness"
    },
    {
      "id": "AC-04-14",
      "requirements": ["RNF05"],
      "kind": "positivo",
      "given": "listados, filtros, tablero e historial a 390 y 1366 px de ancho",
      "when": "se navegan y filtran solo con teclado, provocando también un filtro inválido",
      "then": "no hay desbordamiento horizontal; los controles tienen etiqueta; el error queda asociado
 al filtro; la verificación manual se registra sin afirmar conformidad WCAG total"
    }
  ]
}
```


<!-- spec-data:end -->

Decisiones y aclaraciones

- RNF04 corresponde a arranque reproducible y no a rendimiento: AC-04-09 cubre solo RNF03 y AC-04-12 cubre RNF04 (diferencia D-06).

- Campos del evento según RF09, incluido «recurso» (diferencia D-11). Aislamiento de auditoría explícito en AC-04-11 (diferencia D-12).

- CL-16/17/18: respuesta afirmativa reportada por Conde José; evidencia original pendiente. Permisos y AC-04-10/11 modificados requieren nueva revisión sobre nuevo SHA.

Riesgos y plan de prueba

- R-10 rendimiento y accesibilidad; R-11 auditoría y negocio divergentes.

- Pruebas previstas: API con base real para alcance y conteos con oráculo independiente, prueba de carga con seed separado, clon limpio cronometrado, health y readiness con base detenida, revisión manual de teclado y anchos.

Cambios de versión

- 0.1: borrador inicial (commit 1aeacbf).

- 0.2-draft: ampliación a 10 AC sin fuente oficial.

- 0.3.1-draft: cotejo con el enunciado; corrección de RNF04, campos RF09, AC-04-11 a AC-04-14 (auditoría aislada, arranque, health y readiness, RNF05).

Cambio 0.3.1-draft: CL-16/17/18 confirmadas según reporte del coordinador; sin aprobación humana de esta nueva versión. Otros hallazgos G1 siguen pendientes.

Cambio 0.3.2-draft: R-V02 corregido en AC-04-11; 403 para otro dueño dentro de la organización y 404 para inexistente/interorganización. Nueva revisión humana pendiente.

specs/SPEC-05.md

SPEC-05: Asistente IA

- Versión: 0.4-draft — no aprobada para implementar.

- Fuente vinculante: docs/examen-oficial/originales/Examen_Estudiantes_SDD_IA.pdf §1 (p. 2), §4 RF10–RF12 (p. 5), §5 RNF01/RNF06 (p. 6), §10 IA dentro del producto (p. 11), §11 familia IA (p. 12); anexos ai-output.schema.json, ai-provider-fixtures.json, untrusted-observation.txt y fixture-scenarios.json.

- Estado y aprobación: versión 0.3 elaborada con asistencia de IA a solicitud de Castro Edier (registro docs/evidence/ai-log/AI-001-cotejo-oficial-g1.md). Revisor humano distinto del autor: PENDIENTE. Fecha UTC y commit revisado: PENDIENTE.

El bloque siguiente es la fuente única. specs/generated/SPEC-05.json se genera con python scripts/export_specs.py; no editarlo a mano. Los AC son resultados esperados: ninguna prueba de producto se ha ejecutado.

<!-- spec-data:start -->

```
{
  "id": "SPEC-05",
  "version": "0.4-draft",
  "name": "Asistente IA",
  "status": "Borrador cotejado con el enunciado oficial; pendiente de revisión humana independiente",
  "story": {
    "id": "HU-05",
    "as": "coordinador de una organización",
    "want": "seleccionar hasta 20 solicitudes ENVIADA de mi organización y obtener un resumen con
recomendaciones validadas que pueda aprobar",
    "soThat": "oriente mi revisión sin que el modelo decida, cambie prioridades ni mueva inventario"
  },
  "requirements": ["RF02", "RF09", "RF10", "RF11", "RF12", "RNF01", "RNF06"],
  "description": "Resumen asistido por IA de hasta 20 solicitudes ENVIADA elegidas por el coordinador,
con proyección de campos autorizados, adaptador de proveedor intercambiable, validación estructural y
de pertenencia, degradación determinista y aprobación humana auditada. Enunciado §4 y §10.",
  "actors": ["Coordinador: solicita y aprueba resúmenes de su organización", "Proveedor de IA: externo
y no confiable; real, local, reproducción declarada o fixture", "Sistema: adaptador, validador y
generador del resumen alternativo", "Auditor, Bodega y Solicitante: sin acceso al asistente"],
  "scope": ["Selección por identificador de 1 a 20 solicitudes ENVIADA de la organización", "Proyección
 de los seis campos autorizados por RF10", "Adaptador intercambiable con plazo de 5 s", "Validación
contra ai-output.schema.json y de pertenencia de identificadores", "Resumen determinista alternativo
ante salida inválida, timeout o fallo", "Borrador identificado como asistencia de IA y aprobación
auditada"],
  "exclusions": ["Ejecutar acciones sugeridas por el modelo o cambiar prioridad, reserva o despacho
desde el asistente", "Exigir al modelo explicar su razonamiento interno o usar su confianza declarada
como evidencia", "Uso de más modelos o proveedores de pago (opcional, sin puntos extra)"],
  "inputs": [
    {
      "field": "requestIds",
      "type": "array de string",
      "validation": ["Entre 1 y 20 identificadores únicos; vacío, más de 20 o repetidos produce 422 sin
 llamar al proveedor", "Cada uno debe ser de la organización del coordinador; si no, 404", "Cada uno
debe estar en ENVIADA; si no, 409 (supuesto CL-19)"]
    },
    {
      "field": "payload al adaptador",
      "type": "lista de objetos con requestId, zona, prioridad, fechaRequerida, estado y
observaciones",
      "validation": ["Solo esos seis campos (RF10)", "Nunca contraseñas, sesiones, nombre del
solicitante, líneas ni datos de otra organización", "Observaciones delimitadas como dato no confiable"]
    },
    {
      "field": "salida del proveedor",
      "type": "texto que debe contener un objeto JSON",
      "validation": ["Conforme a ai-output.schema.json: sin propiedades adicionales en ningún nivel,
summary de 1 a 600 caracteres, recommendations de 0 a 5", "Cada recomendación con requestId del
conjunto enviado, reason de 1 a 240 caracteres y evidenceFields de 1 a 3 claves únicas entre zona,
prioridad, fechaRequerida y observaciones", "requestId sin duplicados entre recomendaciones"]
    },
    {
      "field": "summaryId para aprobar",
      "type": "string",
      "validation": ["Borrador de la organización del coordinador; si no, 404"]
    }
  ],
  "process": ["Autenticar; solo el Coordinador puede solicitar o aprobar; Auditor, Bodega y Solicitante
 reciben 403", "Validar la selección y resolver cada identificador en la organización y en estado
ENVIADA", "Proyectar solo los seis campos autorizados y marcar las observaciones como dato no
confiable", "Invocar el adaptador con un plazo de 5 s; el modelo no recibe herramientas, credenciales
ni acceso a la base", "Validar la respuesta contra el esquema y comprobar en código que cada requestId
pertenece al conjunto enviado y no se repite", "Si es válida, guardar el borrador con su origen
(proveedor y modelo, reproducción declarada o fixture) y la etiqueta de asistencia de IA", "Si la
salida es inválida, vence el plazo o falla el proveedor, devolver un mensaje controlado y un resumen
determinista alternativo con origen fallback; el resto del sistema sigue funcionando", "Mostrar summary
```

```
 y reason como texto escapado; nunca ejecutar marcado ni instrucciones", "Aprobar: registrar aprobación
 y evento de auditoría en una transacción sin cambiar prioridad, inventario ni estado"],
  "outputs": [
    {
      "condition": "Salida válida",
      "result": "200 con borrador identificado como asistencia de IA, summary, recommendations y
origen"
    },
    {
      "condition": "Salida inválida, timeout de 5 s o fallo del proveedor",
      "result": "200 con mensaje controlado, resumen determinista, recommendations vacío (CL-08) y
origen fallback"
    },
    {
      "condition": "Selección vacía, mayor de 20 o con repetidos",
      "result": "422 sin llamar al proveedor"
    },
    {
      "condition": "Identificador de otra organización o inexistente",
      "result": "404 sin llamar al proveedor"
    },
    {
      "condition": "Solicitud seleccionada fuera de ENVIADA",
      "result": "409 sin llamar al proveedor (supuesto CL-19)"
    },
    {
      "condition": "Rol distinto de Coordinador",
      "result": "403"
    },
    {
      "condition": "Aprobación válida",
      "result": "200 con aprobador y fecha UTC; un evento de auditoría"
    }
  ],
  "businessRules": ["RF10: el coordinador solicita un resumen de hasta 20 solicitudes ENVIADA de su
organización seleccionadas por identificador; el adaptador recibe solo requestId, zona, prioridad,
fecha requerida, estado y observaciones", "RF11: summary hasta 600 caracteres; hasta cinco
recomendaciones con requestId válido del conjunto recibido, reason hasta 240 caracteres y de una a tres
 evidenceFields permitidas; sin IDs duplicados o ajenos ni propiedades adicionales; el texto es
contenido no confiable y nunca se ejecuta", "RF12: el resumen es un borrador identificable como
asistencia de IA; solo el coordinador lo aprueba y deja constancia; aprobar no reserva, despacha ni
cambia prioridad; salida inválida, timeout de 5 s o fallo del proveedor devuelven mensaje controlado y
resumen determinista alternativo", "La prioridad proviene de la solicitud, no del modelo; la validación
 de pertenencia, estado y formato se hace en código, un prompt restrictivo no basta", "Interfaz de
proveedor intercambiable; CI usa los fixtures deterministas del anexo sin servicios de pago", "Debe
demostrarse una salida de un LLM real por API, modelo local o reproducción declarada con entrada,
salida y origen, pasando por el mismo adaptador y validador; no se hardcodean recomendaciones ni se
afirma una invocación en vivo que no ocurrió", "La aprobación se audita con los campos de RF09",
"Decisiones propuestas G2: selección se valida formato 422 → pertenencia 404 → estado 409 antes de
proveedor; fallback aprobable sin cambiar negocio; segunda aprobación 409. Timeout proveedor 5s,
tolerancia de observación fallback ≤250ms. Nueva revisión humana requerida."],
  "edgeCases": ["Selección de 0, 1, 20 y 21 identificadores", "Identificador repetido, B-001 de ORG-B y
 una solicitud RESERVADA", "JSON roto (fixture AI-JSON-BAD)", "summary vacío, de 600 y de 601
caracteres", "0, 5 y 6 recomendaciones", "reason de 240 y 241 caracteres", "evidenceFields vacío, con
1, 3 y 4 claves, repetidas o con clave no permitida", "requestId duplicado o fuera del conjunto
(fixture AI-FOREIGN-ID)", "Propiedad adicional execute (fixture AI-EXTRA)", "Marcado script en summary
e instrucciones incrustadas en observaciones (fixture AI-INJECTION y untrusted-observation.txt)",
"Respuesta a los 5001 ms (fixture AI-TIMEOUT), error del proveedor (AI-ERROR) y proveedor no
configurado"],
  "assumptions": ["El resumen alternativo es determinista para la misma selección y estado de datos y
no incluye recomendaciones (CL-08, decisión del equipo)", "Se persisten borradores válidos y metadatos
sanitizados de intentos fallidos, sin prompts con secretos (CL-05, decisión del equipo)", "Solicitud
seleccionada fuera de ENVIADA produce 409 (CL-19, decisión del equipo)"],
  "openQuestions": ["CL-05: persistencia y retención de intentos de IA (equipo)", "CL-08: contenido
exacto del resumen alternativo (equipo)"],
  "dependencies": ["SPEC-01: rol Coordinador y organización", "SPEC-02: solicitudes en ENVIADA",
"SPEC-04: estructura del evento de auditoría", "Copia de trabajo de ai-output.schema.json en contracts/
 (G2) y fixtures del anexo"],
  "acceptanceCriteria": [
    {
      "id": "AC-05-01",
      "requirements": ["RF10", "RNF01"],
      "kind": "positivo",
      "given": "el coordinador de ORG-A autenticado y A-001 y A-002 en ENVIADA",
      "when": "solicita un resumen seleccionando ambas",
      "then": "el payload capturado en el adaptador contiene solo esas dos solicitudes y solo
requestId, zona, prioridad, fechaRequerida, estado y observaciones"
    },
    {
      "id": "AC-05-02",
      "requirements": ["RF11", "RNF01"],
      "kind": "negativo",
      "given": "los fixtures AI-FOREIGN-ID y AI-EXTRA y una salida con requestId repetido",
      "when": "el adaptador devuelve cada una",
      "then": "se rechazan; se muestran mensaje controlado y resumen alternativo; no aparece ningún
dato de ORG-B y nada se ejecuta"
    },
    {
      "id": "AC-05-03",
      "requirements": ["RF12", "RNF06"],
      "kind": "fallo",
      "given": "los fixtures AI-TIMEOUT con 5001 ms y AI-ERROR",
      "when": "el coordinador solicita un resumen",
```

```
      "then": "el adaptador corta la espera del proveedor a los 5 segundos; test instrumental permite
hasta 250 ms adicionales de procesamiento del fallback (no ampliar timeout del proveedor); mensaje
controlado y fallback determinista; listar/reservar/despachar siguen funcionando"
    },
    {
      "id": "AC-05-04",
      "requirements": ["RF12"],
      "kind": "positivo",
      "given": "un borrador válido de ORG-A",
      "when": "el coordinador de ORG-A lo aprueba",
      "then": "el borrador queda aprobado; prioridades, estados e inventario son idénticos antes y
después según snapshot"
    },
    {
      "id": "AC-05-05",
      "requirements": ["RF10", "RF02", "RNF01"],
      "kind": "limite",
      "given": "el coordinador de ORG-A autenticado",
      "when": "selecciona 21 identificadores, una lista vacía, identificadores repetidos, B-001 de
ORG-B o una solicitud RESERVADA, y después 20 identificadores válidos",
      "then": "los tres primeros casos reciben 422, B-001 recibe 404 y la RESERVADA 409, sin invocar al
 proveedor; con 20 válidos el proveedor se invoca una sola vez"
    },
    {
      "id": "AC-05-06",
      "requirements": ["RF11"],
      "kind": "negativo",
      "given": "salidas con summary vacío o de 601 caracteres, seis recomendaciones, reason de 241,
evidenceFields vacío, con cuatro claves, repetidas o con clave no permitida, y el fixture AI-JSON-BAD",
      "when": "se validan",
      "then": "cada una se rechaza con motivo sanitizado y se usa el resumen alternativo; ninguna se
guarda como borrador válido"
    },
    {
      "id": "AC-05-07",
      "requirements": ["RF11"],
      "kind": "limite",
      "given": "el fixture AI-VALID y salidas con summary de 600 caracteres, cinco recomendaciones con
identificadores únicos del conjunto, reason de 240 y evidenceFields de una y de tres claves
permitidas",
      "when": "se validan",
      "then": "se aceptan y se muestran como borrador de asistencia de IA"
    },
    {
      "id": "AC-05-08",
      "requirements": ["RF11", "RNF01"],
      "kind": "fallo",
      "given": "una solicitud de ORG-A cuyas observaciones contienen el texto de untrusted-
observation.txt y el fixture AI-INJECTION",
      "when": "el coordinador solicita el resumen",
      "then": "la instrucción incrustada no se obedece; el ID ajeno invalida la salida completa y se
usa fallback; el texto malicioso rechazado no llega a pantalla; stock, estados, prioridades y permisos
no cambian. Escape de salida válida se verifica por separado en AC-05-17"
    },
    {
      "id": "AC-05-09",
      "requirements": ["RF12", "RNF06"],
      "kind": "fallo",
      "given": "el proveedor no configurado",
      "when": "el coordinador solicita dos veces el resumen de la misma selección sin cambios en los
datos",
      "then": "ambas respuestas incluyen mensaje controlado y el mismo resumen determinista; no se
requiere ningún servicio de pago"
    },
    {
      "id": "AC-05-10",
      "requirements": ["RF12"],
      "kind": "positivo",
      "given": "una salida válida del adaptador",
      "when": "se muestra al coordinador",
      "then": "aparece identificada como asistencia de IA con su origen; la prioridad mostrada es la de
 cada solicitud y ninguna recomendación se aplica sin una operación normal posterior"
    },
    {
      "id": "AC-05-11",
      "requirements": ["RF12", "RF02"],
      "kind": "permiso",
      "given": "un borrador de ORG-A y otro de ORG-B",
      "when": "el auditor, la bodega o el solicitante de ORG-A solicitan o aprueban un resumen, y el
coordinador de ORG-A intenta aprobar el borrador de ORG-B",
      "then": "los otros roles reciben 403; el borrador de ORG-B recibe 404; ningún borrador, stock ni
prioridad cambia"
    },
    {
      "id": "AC-05-12",
      "requirements": ["RF09", "RF12"],
      "kind": "positivo",
      "given": "un borrador válido de ORG-A",
      "when": "el coordinador lo aprueba enviando un X-Correlation-Id",
      "then": "se persiste junto a la aprobación un evento con identidad, organización, recurso,
acción, fecha UTC y ese correlationId; las solicitudes y el inventario quedan idénticos"
    },
    {
```

```
      "id": "AC-05-13",
      "requirements": ["RF12"],
      "kind": "positivo",
      "given": "una respuesta real capturada de un LLM con su entrada, salida y origen declarados",
      "when": "se ejecuta mediante el adaptador de reproducción",
      "then": "pasa por el mismo adaptador y validador del producto; el origen se muestra como
reproducción con su fixture y versión y no se reporta una invocación en vivo"
    },
    {
      "id": "AC-05-14",
      "requirements": ["RNF06"],
      "kind": "positivo",
      "given": "el pipeline de CI del repositorio",
      "when": "ejecuta las pruebas del asistente",
      "then": "usa solo los siete fixtures deterministas de ai-provider-fixtures.json, sin credenciales
 ni servicios de pago, y cada resultado coincide con el campo expected del fixture"
    },
    {
      "id": "AC-05-15",
      "requirements": ["RF12", "RF09"],
      "kind": "positivo",
      "given": "borrador de ORG-A generado como fallback y coordinador autenticado con CSRF válido",
      "when": "aprueba el borrador alternativo",
      "then": "200; conserva origen fallback y registra aprobación+evento en la misma transacción, sin
cambios de solicitudes, prioridad o inventario"
    },
    {
      "id": "AC-05-16",
      "requirements": ["RF12", "RF09"],
      "kind": "negativo",
      "given": "borrador ya APROBADO en ORG-A y su evento de aprobación existente",
      "when": "el coordinador repite aprobación con CSRF válido",
      "then": "409; no cambia aprobación previa ni añade un segundo evento; solicitudes e inventario
inalterados"
    },
    {
      "id": "AC-05-17",
      "requirements": ["RF11", "RF12", "RNF01"],
      "kind": "positivo",
      "given": "salida IA válida con IDs propios y texto <script>window.__unsafe=true</script> en
summary, dentro de límites",
      "when": "se valida y se muestra el borrador",
      "then": "la salida válida se acepta, texto escapado visible, no se ejecuta script y
window.__unsafe no se establece; sin cambios de inventario, estado o prioridad"
    }
  ]
}
```


<!-- spec-data:end -->

Decisiones y aclaraciones

- Selección por identificador hecha por el coordinador, no por el servidor (RF10; diferencia D-04).

- Campos autorizados oficiales: requestId, zona, prioridad, fecha requerida, estado y observaciones; se retiran «lines» y se añade «estado» (diferencia D-05).

- Contrato de salida: anexo oficial ai-output.schema.json. Se retira la regla 0.2 «evidenceFields respaldando la razón», que no es verificable en código ni la exige el enunciado (diferencia D-17).

- Supuestos del equipo: CL-05, CL-08 y CL-19.

Riesgos y plan de prueba

- R-04 salida con ID ajeno o inyección; R-05 fallo del proveedor.

- Pruebas previstas: contrato con los siete fixtures, captura del payload del adaptador, reloj controlado para el plazo de 5 s, snapshots antes y después de generar y aprobar, reproducción declarada de una respuesta real.

Cambios de versión

- 0.1: borrador inicial (commit 1aeacbf).

- 0.2-draft: ampliación a 13 AC sin fuente oficial.

- 0.3-draft: cotejo con el enunciado y anexos; selección por identificador, campos oficiales, esquema oficial, fixtures referenciados, campos RF09 en la aprobación y AC-05-14 (CI sin servicios de pago).

Actualización 0.4-draft por Codex a solicitud del coordinador: hallazgos H-V/H-E atendidos documentalmente; los AC nuevos no son pruebas ejecutadas. Revisión humana sobre nuevo SHA PENDIENTE.

Arquitectura, datos y contratos

docs/adr/ADR-001-estructura-limites.md

ADR-001 Estructura y límites: Laravel y PostgreSQL

- Estado: propuesto; revisión G2 pendiente. No autoriza implementación mientras G1 esté pendiente.

- Fecha y versión: 2026-10-14, v0.1.

- Elaboración: Codex a solicitud de Conde José; no acredita trabajo o aprobación humana.

- Fuentes: examen oficial §§2–6, 8–12; SPEC-01 a SPEC-05 0.3-draft; ADR-004 y contrato IA de la rama docs/g2-vega-ia, commit a13aa17.

Contexto y restricciones

Dos organizaciones, cuatro roles y ocho cuentas ficticias. El sistema debe mantener consistencia de stock, reservas, estados, resultado idempotente y auditoría; demostrar aislamiento y transacciones con base real. La IA es opcional para operar, sin herramientas privilegiadas, y su aprobación no ejecuta operaciones de negocio. El usuario solicita Laravel + PostgreSQL y monolito modular. Esto sustituye la propuesta tecnológica inicial TypeScript/Express para este diseño; no se presenta como exigencia del docente.

Alternativas consideradas

| Alternativa | Beneficio | Coste / restricción |

|---|---|---|

| Laravel + PostgreSQL, monolito modular | Un despliegue, transacción local compartida, autenticación/validación del framework | Requiere disciplina de dependencias y pruebas PostgreSQL; revisar competencia PHP del equipo |

| React/Express/TypeScript + PostgreSQL | Coincide con propuesta inicial, tipos compartidos | Dos builds y mayor coordinación de sesión/frontend; alternativa válida si el equipo la prefiere |

| Microservicios | Despliegue independiente | Consistencia distribuida y complejidad innecesaria para examen y equipo |

| Laravel + MySQL | Compatible con Laravel y transacciones | Requiere adaptar oráculos/entorno; se elige un solo motor real para CI y demo |

Criterios de elección

Consistencia transaccional verificable, mínima complejidad operativa, límites claros, autorización centralizada, integración IA reemplazable y arranque reproducible RNF04. Evitar servicios pagados obligatorios y funcionalidades fuera de alcance.

Decisión y justificación

Diseñar un monolito modular Laravel, PostgreSQL único y UI Blade del mismo origen como propuesta de mínima complejidad, sin SPA adicional obligatoria. Docker Compose previsto con aplicación y PostgreSQL; versiones compatibles de PHP/Laravel/PostgreSQL se fijarán en G2 antes de implementación junto con composer.lock y lockfile de assets si aplica. No se inventan lockfiles sin resolver dependencias.

| Módulo previsto | Responsabilidad y dueño de datos | Dependencias permitidas |

|---|---|---|

| Identity | Sesiones, hash, identidad/rol/org; ocho cuentas ficticias | Infraestructura de persistencia; ADR-003 |

| Requests | Cabecera, líneas y validaciones; crear/editar/enviar borrador propio | Identity, catálogo Inventory, Audit |

| Inventory | Existencia física/reservada, reserva, despacho y liberación | Requests, Identity, Idempotency, Audit; ADR-002 |

| Queries | Listados, filtros, tablero, inventario e historial autorizado | Lecturas con alcance del servidor; sin mutación |

| Audit | Eventos append-only de transición/aprobación | Transacción compartida; sin API de edición/borrado |

| Idempotency | Ámbito usuario/org/operación, hash y resultado ≥24h | Autorización previa y transacción Inventory |

| AI | Selección, whitelist, adaptador, validación, fallback y aprobación | Identity, lectura Requests, Audit; ADR-004 |

| Operations | Health, readiness y logs estructurados sanitizados | Readiness comprueba PostgreSQL; no depende del proveedor IA |

Ubicación propuesta: app/Modules/<Module>/{Application,Domain,Infrastructure,Http}; routes/api.php y vistas Blade. Controladores delgados llaman casos de uso. No importar controladores de otro módulo ni mutar datos ajenos mediante modelos desde la UI. Queries usa proyecciones; AI no obtiene una interfaz de mutación de solicitudes/inventario. Evitar repositorios genéricos innecesarios; solo introducir interfaces en fronteras que deben sustituirse/probarse, como proveedor IA.

Una única transacción PostgreSQL confirma estado, inventario, auditoría y resultado idempotente. Bloquear solicitud y filas de stock en orden estable; ADR-002 debe concretar aislamiento, deadlocks, hash y retención. No invocar al proveedor IA dentro de una transacción de inventario. Aprobar resumen usa su propia transacción de resumen+evento sin escribir stock.

Fronteras de confianza y alcance

Navegador y observaciones no confiables; API resuelve identidad y filtra organización antes de exponer datos. PostgreSQL no es accesible al navegador. Credencial del proveedor solo en backend, sin nombres/secretos/datos ajenos en payload. Respuesta IA se valida y se presenta escapada. Sesión revocable/cookie y controles CSRF son provisionales hasta ADR-003; contrato IA conserva su esquema original.

Fuera de alcance: usuarios masivos, recuperación de contraseña, GPS/rutas, devoluciones, ajustes de stock por API y decisiones automáticas de IA. El coordinador reporta respuesta afirmativa de la profesora a CL-16/17/18: Coordinador también lee inventario e historial de su organización; Solicitante lee historial y tablero de sus propias solicitudes sin inventario. Bodega no recibe acceso a auditoría. Fecha/canal y evidencia original pendientes; la decisión se registra como reportada y las SPEC afectadas requieren nueva revisión.

Consecuencias y riesgos

Un único despliegue simplifica evaluación; el mismo motor de base se usa en demo y pruebas. Una caída del proceso afecta toda la aplicación, aceptable para este alcance y documentada en runbook futuro. El acoplamiento de modelos y escrituras cruzadas se controla mediante revisión de módulos. Las transacciones no aseguran por sí solas concurrencia/idempotencia: deben ejecutarse los oráculos. G1 pendiente y permisos aún abiertos impiden considerar final el diseño.

RF y AC afectados

RF01–RF12, RNF01–RNF06; todos los AC de SPEC-01–05 según matriz. Contrato contracts/openapi.yaml; diagramas docs/architecture/contexto.md y componentes.md. ADR-002/003 aún pendientes; ADR-004 existente no se aprueba por referencia.

Verificación de la decisión

Pruebas previstas, no ejecutadas: aislamiento 2 lecturas/2 escrituras; reserva parcial rechazada y rollback real; dos reservas competidoras PostgreSQL; replay/conflicto/TTL; evento atómico; fallo IA sin impedir transiciones; clon limpio ≤15min (descargas medidas aparte); carga RNF03 y UI RNF05. Revisar dependencias entre módulos y permisos por ruta en G2.

Apoyo técnico: [transacciones Laravel](https://laravel.com/framework/docs/database/config), [bloqueos pesimistas](https://laravel.com/framework/docs/13.x/queries). Consultados 2026-10-14; versión del producto aún por fijar. La decisión sigue siendo del equipo.

Autor y revisión humana

Revisor independiente, fecha UTC, SHA y decisión: PENDIENTES. Edier revisa límites/datos/transacción y Vega fronteras IA/seguridad, como propuestas de revisión; no se registra participación realizada.

docs/adr/ADR-002-transacciones-idempotencia.md

ADR-002 Estrategia transaccional, concurrencia e idempotencia

Formato del anexo oficial 06_adr-template.md.

- Estado: propuesto

- Fecha y versión: 2026-10-14, v0.1 (G2)

- Autor: Castro Edier, con asistencia de IA (registro AI-005)

- Depende de: ADR-001 (Laravel + PostgreSQL, monolito modular; módulos Inventory, Requests, Idempotency y Audit) y contrato contracts/openapi.yaml (rama docs/g2-architecture, e63ebf5)

Contexto y restricciones

- RF05: la reserva cubre todas las líneas o ninguna; disponible = físico − reservado; las tres cantidades nunca negativas; solo desde ENVIADA; si falta stock en una línea, 409 sin cambios.

- RF06: cancelar RESERVADA libera exactamente su reserva; despachar baja físico y reservado; ENTREGADA y cancelar ENVIADA no tocan inventario.

- RF07: reserva transaccional segura ante concurrencia, con Idempotency-Key; misma clave, usuario, organización, operación y contenido repiten el resultado; contenido distinto, 409; resultado conservado al menos 24 h.

- Condiciones de consistencia (§3): dos reservas que compiten por stock insuficiente no pueden tener éxito ambas; un fallo antes del commit no deja reserva parcial; una segunda reserva con otra clave devuelve 409; la clave se procesa después de autenticar y autorizar.

- RF09: estado, inventario y evento de auditoría se persisten de forma consistente.

- RNF02: verificado contra una base real (PostgreSQL), no con mocks.

- Oráculos oficiales (acceptance-oracles.md): con KIT-ALIMENTO de ORG-A en físico 10, reservar A-001 (7) deja 10/7/3; dos reservas simultáneas de 7 dejan una exitosa, otra 409 y 10/7/3.

Alternativas consideradas

Control de concurrencia del stock

| Opción | Cómo funciona | Ventajas | Desventajas |

|---|---|---|---|

| A. Bloqueo pesimista | SELECT … FOR UPDATE sobre la solicitud y las filas de stock en orden de SKU, en READ COMMITTED (Laravel lockForUpdate()) | Correcto con varias líneas; fácil de razonar, explicar y probar; sin reintentos en el caso normal | Las reservas del mismo SKU esperan en fila; requiere orden fijo de bloqueo para evitar deadlocks |

| B. UPDATE condicional | UPDATE … SET reservado = reservado + n WHERE fisico - reservado >= n y revisar filas afectadas | Sin bloqueos explícitos | Con varias líneas hay que deshacer las ya actualizadas; más difícil de garantizar «todas o ninguna» |

| C. Bloqueo optimista | Columna version; si cambió, reintentar | Sin esperas | Muchos reintentos cuando hay competencia, que es justo el caso a probar |

| D. SERIALIZABLE + reintentos | PostgreSQL aborta transacciones en conflicto (40001) | Garantía fuerte | Reintentos obligatorios en todo el código; errores más difíciles de diagnosticar |

Almacén de idempotencia

| Opción | Ventajas | Desventajas |

|---|---|---|

| Tabla en PostgreSQL dentro de la misma transacción | El resultado se guarda si y solo si se confirman los efectos; sin servicios extra | Requiere limpieza periódica |

| Caché externa (Redis) | Rápida | No es transaccional con la base: podría guardar un resultado sin efectos o al revés; servicio adicional |

| Middleware fuera de la transacción | Genérico | Mismo problema de consistencia que Redis |

Criterios de elección

1. Cumplir los oráculos oficiales en cualquier orden de llegada de las peticiones.

2. Atomicidad de estado, inventario, auditoría y resultado idempotente.

3. Que el mecanismo se pueda probar de forma determinista contra PostgreSQL real.

4. Mínima complejidad.

Decisión y justificación

Se adoptan el bloqueo pesimista (A) y la tabla de idempotencia en la misma transacción.

Reserva (POST /api/requests/{requestId}/reserve)

| Paso | Acción | Resultado si falla |

|---|---|---|

| 1 | Autenticar; resolver la solicitud dentro de la organización del usuario | 401 / 404 (no se guarda) |

| 2 | Autorizar rol Coordinador | 403 (no se guarda) |

| 3 | Validar cuerpo {} y cabecera Idempotency-Key (1–128 caracteres) | 422 (no se guarda) |

| 4 | BEGIN (READ COMMITTED) y SET LOCAL lock_timeout = '3s' | — |

| 5 | pg_advisory_xact_lock(hash(org, usuario, 'reserve', clave)): serializa peticiones con la misma clave | — |

| 6 | Buscar el registro de idempotencia del ámbito. Si existe y no venció: misma huella → devolver código y cuerpo guardados sin efectos; huella distinta → 409 | Replay o 409 (no se guarda de nuevo) |

| 7 | SELECT … FOR UPDATE de la solicitud | — |

| 8 | Si el estado no es ENVIADA → 409 | 409 guardado en el registro de idempotencia |

| 9 | SELECT … FOR UPDATE de las filas de inventario de sus SKU, ordenadas por SKU | — |

| 10 | Comprobar, para cada línea, SKU activo y fisico − reservado ≥ cantidad | 409 guardado; ninguna fila modificada |

| 11 | reservado += cantidad por línea; estado RESERVADA; evento de auditoría; registro de idempotencia con 200 y cuerpo | — |

| 12 | COMMIT | Cualquier excepción antes: ROLLBACK total y 500 con correlationId, sin registro (H-E01) |

Detalles:

- Huella: SHA-256 del JSON canónico {"operation":"reserve","requestId":…,"body":{}} con claves ordenadas.

- Ámbito de la clave: UNIQUE (organization_id, user_id, operation, idempotency_key). La misma clave en otra organización o de otro usuario es independiente (AC-03-12).

- Retención: expires_at = created_at + 24 h. Se repite el resultado mientras now < expires_at. Al vencer, el registro se reemplaza y la operación se reevalúa (AC-03-11, supuesto CL-11). Un comando programado borra los registros con más de 7 días.

- Respuestas guardadas (CL-04): 200 y 409 de negocio. No se guardan 401, 403, 404, 422 ni 500, que se pueden reintentar con la misma clave. Consecuencia (H-E03): un 409 por falta de stock se repite durante 24 h; para reintentar después de

liberar stock, el cliente usa una clave nueva.

- Segunda reserva con otra clave: el paso 8 la rechaza con 409 porque el estado ya no es ENVIADA (AC-03-14).

- Por qué funciona la competencia en READ COMMITTED: cuando la segunda transacción obtiene el bloqueo de la fila de stock, PostgreSQL le entrega la versión ya confirmada por la primera (reservado = 7), así que su comprobación ve disponible 3 y responde 409.

Otras transiciones

Despachar, entregar, cancelar y enviar usan la misma transacción, sin Idempotency-Key (RF07 solo la exige para reservar): bloquear la solicitud, comprobar estado y rol, bloquear el stock en orden de SKU si se modifica, actualizar, registrar el evento y confirmar.

| Transición | Actor (§2) | Efecto en stock |

|---|---|---|

| Enviar BORRADOR → ENVIADA | Solicitante dueño | Ninguno |

| Reservar ENVIADA → RESERVADA | Coordinador | reservado += cantidad |

| Despachar RESERVADA → DESPACHADA | Bodega | fisico −= cantidad y reservado −= cantidad |

| Entregar DESPACHADA → ENTREGADA | Coordinador | Ninguno |

| Cancelar ENVIADA → CANCELADA | Solicitante dueño | Ninguno |

| Cancelar RESERVADA → CANCELADA | Solicitante dueño | reservado −= cantidad |

| Cualquier otra | — | 409 sin cambios |

Una carrera entre despacho y cancelación de la misma reserva (H-E02) se resuelve con el bloqueo de la solicitud: la primera gana y la segunda ve el nuevo estado y recibe 409.

Orden de bloqueo y deadlocks

Siempre: bloqueo consultivo de la clave (solo en reservas) → fila de la solicitud → filas de stock por SKU ascendente. Con un orden único no se forman ciclos. Como defensa, DB::transaction($callback, 3) de Laravel reintenta hasta 3 veces si PostgreSQL detecta un deadlock (40P01). Si se agota el lock_timeout, la respuesta es 500 controlado, sin guardar, y se puede reintentar con la misma clave.

Restricciones en la base (defensa en profundidad)

- CHECK (fisico >= 0 AND reservado >= 0 AND reservado <= fisico) en inventario: si un error de código intentara dejar stock negativo, la base lo rechaza y la transacción se revierte.

- CHECK (cantidad BETWEEN 1 AND 500) en las líneas y CHECK del estado con los seis valores.

- Llaves foráneas compuestas con organization_id entre solicitud, líneas e inventario: una línea no puede apuntar a stock de otra organización.

- Auditoría append-only: un trigger rechaza UPDATE y DELETE en audit_events.

Detalle en [datos](../architecture/datos.md), [estados](../architecture/estados.md) y [secuencia de reserva concurrente](../architecture/secuencia-reserva-concurrente.md).

Consecuencias y riesgos

- (+) Los oráculos se cumplen sin importar el orden de llegada; los efectos y el resultado idempotente se confirman juntos.

- (+) Las restricciones de la base detienen errores de código antes de que corrompan el inventario.

- (−) Las reservas del mismo SKU se procesan una a la vez; aceptable para el volumen del caso. RNF03 mide listados y tablero, no reservas.

- (−) Las restricciones y el trigger dependen de PostgreSQL; las pruebas deben usar PostgreSQL real (ver docs/testing/estrategia-pruebas.md).

- Riesgo: un bloqueo mantenido demasiado tiempo → lock_timeout de 3 s y transacciones cortas, sin llamadas externas dentro (la IA nunca se invoca dentro de una transacción de inventario, ADR-001).

Coherencia con el contrato

- Idempotency-Key y la política 200/409 guardados coinciden con contracts/openapi.yaml.

- Observación para el contrato (H-E05): las descripciones de dispatch, deliver y cancel terminan con «Misma reserva con otra clave devuelve 409», que no aplica porque esas operaciones no usan clave. Conviene quitar la frase.

RF y AC afectados

RF02, RF04, RF05, RF06, RF07, RF09, RNF02; AC-03-01 a AC-03-16, AC-04-03, AC-04-08; hallazgos H-E01 a H-E03.

Verificación de la decisión

Pruebas previstas contra PostgreSQL real (oráculos escritos antes):

| Prueba | AC | Cómo |

|---|---|---|

| Reserva exitosa 10/7/3 y un evento | AC-03-01 | Seed restablecido; consulta directa a la base |

| Línea insuficiente sin cambios | AC-03-02 | Snapshot antes y después |

| Dos reservas simultáneas | AC-03-03, 03-08 | Dos procesos reales con barrera, ≥ 20 repeticiones; siempre una 200 y una 409, 10/7/3 y un evento |

| Replay y conflicto de clave | AC-03-04, 03-10 | Misma respuesta y un solo evento; otro contenido → 409 |

| Expiración a 24 h | AC-03-11 | Reloj controlado (travelTo) |

| Ámbito de la clave | AC-03-12 | Misma clave en ORG-B no devuelve la respuesta de ORG-A |

| Segunda reserva con otra clave | AC-03-14 | 409 y reservado sin cambios |

| Fallo antes del commit | AC-03-09 | Excepción inyectada al escribir el evento: estado, stock y registro de idempotencia sin cambios |

| Carrera despacho / cancelación | H-E02 | Dos procesos; estado final coherente con el que ganó |

| Restricción de stock | RNF02 | Un UPDATE directo que deje reservado > fisico falla |

| Auditoría inmutable | AC-04-08 | UPDATE o DELETE sobre audit_events falla |

Autor y revisión humana

- Autor: Castro Edier (asistido por IA, AI-005).

- Revisión humana: pendiente de una persona distinta del autor en la revisión G2.

docs/adr/ADR-003-autenticacion-aislamiento.md

ADR-003: Autenticación, Sesiones y Aislamiento Multitenant (ORG-A / ORG-B)

* Estado: Propuesto

* Fecha: 2026-10-14

* Autora: Carolina Cantillo

* Revisión Humana: Pendiente

* Requisitos: RF01, RF02, RNF01, SPEC-01 (AC-01-01 a AC-01-13)

* Atención a Hallazgos:

- H-V05: Precisión de respuestas HTTP 403 vs 404 para evitar enumeración y fuga de datos cross-tenant.

- H-V06: Protección estricta contra ataques CSRF mediante verificación de tokens y cookies SameSite/SameOrigin.

Contexto y Problema

NexoEntrega 360 requiere aislar completamente los recursos entre ORG-A y ORG-B bajo cuatro roles (Solicitante, Coordinador, Bodega, Auditor). Se deben precisar los parámetros de sesión, logout, algoritmo de hashing definitivo y protección contra vulnerabilidades CSRF.

Opciones Evaluadas

1. Laravel Sessions (Cookie HTTP-Only, SameSite=Lax/Strict) + Scope Tenant en Eloquent.

2. Tokens Sanctum SPA / API Bearer Tokens.

3. Multi-tenancy con esquemas de BD separados.

Decisión Seleccionada

Adoptamos la Opción 1: Sesiones basadas en cookies HTTP-Only con Middleware de Organización, con las siguientes precisiones técnicas definitivas:

Especificación Técnica

- Algoritmo de Hashing Definitivo: Bcrypt con factor de costo 12 para todas las contraseñas almacenadas.

- Sesión y Cookie: Duración de sesión configurable (config/session.php: lifetime = 120 minutos), expire_on_close = true, http_only = true, same_site = lax. El flag secure = true estará habilitado por entorno en producción HTTPS, manteniendo secure = false únicamente cuando la demo local corra sobre HTTP estándar.

- Logout: Invalidación explícita de sesión (Auth::logout(), session()->invalidate(), session()->regenerateToken()).

- Protección CSRF (H-V06): Verificación activa de token CSRF mediante ValidateCsrfToken en todas las peticiones de mutación HTTP (POST, PUT, PATCH, DELETE).

- Manejo de Errores 403 vs 404 (H-V05): Si un recurso existe pero pertenece a otra organización, el servidor retornará HTTP 404 Not Found en lugar de 403 Forbidden para evitar la enumeración maliciosa de identificadores.

Consecuencias y Validación

- Aislamiento multitenant robusto a nivel de backend. Evaluado contra criterios AC-01-01 a AC-01-13.

docs/adr/ADR-004-integracion-ia-degradacion.md

ADR-004 Integración del asistente de IA y degradación

Formato del anexo oficial 06_adr-template.md.

- Estado: propuesto

- Fecha y versión: 2026-10-14, v0.1 (G2)

- Autor: Vega José, con asistencia de IA (registro AI-004)

- Depende de: ADR-001 (estructura y tecnología; el equipo acordó Laravel con PostgreSQL el 2026-10-14; falta registrarlo en ADR-001) y ADR-003 (identidad y sesión)

Contexto y restricciones

El coordinador pide un resumen de hasta 20 solicitudes ENVIADA de su organización (RF10). La salida del modelo debe cumplir contracts/ai-output.schema.json y la validación de pertenencia (RF11). El resumen es un borrador que solo el coordinador aprueba, y aprobarlo no cambia inventario, estado ni prioridad (RF12). Restricciones vinculantes:

- Plazo de 5 s; salida inválida, timeout o fallo del proveedor devuelven un mensaje controlado y un resumen determinista alternativo (RF12).

- El proveedor recibe solo requestId, zona, prioridad, fecha requerida, estado y observaciones (RF10).

- El modelo no recibe capacidad de escribir inventario ni de invocar operaciones privilegiadas; un prompt que lo prohíbe no basta (§10).

- CI usa fixtures deterministas, sin servicio de pago (RNF06, AC-05-14).

- Debe demostrarse una salida de un LLM real que pase por el mismo adaptador y validador (§10). El equipo eligió una API con plan gratuito.

- Las observaciones son datos no confiables (untrusted-observation.txt, OWASP LLM01).

Alternativas consideradas

Arquitectura de la integración

| Opción | Descripción | Ventajas | Desventajas |

|---|---|---|---|

| A. Llamada directa | El controlador llama al proveedor y muestra la respuesta | Poco código | No se puede probar sin red; acopla al proveedor; validación dispersa; incumple «proveedor intercambiable» (§10) |

| B. Adaptador + validador + fallback | Interfaz AiProvider con varias implementaciones; un servicio orquesta proyección, plazo, validación y fallback | Intercambiable; CI con fixtures; validación en un único punto; degradación controlada | Más clases y pruebas |

| C. Llamada desde el navegador | El frontend llama al proveedor | Sin carga en el servidor | Expone la clave; el servidor no valida pertenencia; descartada por seguridad |

Origen de la salida de LLM real

| Opción | Ventajas | Desventajas |

|---|---|---|

| API con plan gratuito (elegida por el equipo) | Invocación real y demostrable; sin costo | Requiere clave en .env; cuotas y errores 429; los planes gratuitos cambian |

| Modelo local (Ollama) | Sin clave ni cuota | Instalación pesada; depende del hardware de cada integrante |

| Reproducción declarada | Reproducible y sin clave | No demuestra invocación en vivo |

Proveedor de la API gratuita. Gemini (modelos Flash del plan gratuito de Google AI Studio) o Groq. Ambos ofrecían plan gratuito en 2026, pero sus límites cambian: se comprueban en la consola del proveedor al implementar y no se fijan en el código.

Criterios de elección

1. Cumplir RF10–RF12 y RNF06 con pruebas deterministas.
2. Seguridad: clave fuera del repositorio y del navegador; validación en el servidor.
3. Demostrar una salida real sin depender de ella para que el sistema funcione.
4. Mínima complejidad que cumpla lo anterior.

Decisión y justificación

Se adopta la opción B con estas piezas (nombres orientativos en Laravel):

| Pieza | Responsabilidad |

|---|---|

| AiProvider (interfaz) | complete(string $prompt, int $timeoutMs): string; devuelve el texto crudo o lanza AiTimeoutException / AiProviderException |

| GeminiProvider / GroqProvider | Cliente HTTP de Laravel con timeout(5); clave leída de config('ai.key') (variable AI_API_KEY en .env) |

| FixtureProvider | Devuelve el rawOutput o simula el transport de ai-provider-fixtures.json; lo usa CI |

| ReplayProvider | Devuelve una respuesta real capturada y guardada en evidence/ai-replay/ con entrada, salida, modelo, fecha y origen |

| NullProvider | Sin proveedor configurado: lanza AiProviderException para activar el fallback |

| AiOutputValidator | 1) JSON estricto; 2) esquema ai-output.schema.json; 3) en código: cada requestId pertenece a la selección y no se repite |

| FallbackSummarizer | Resumen determinista con conteos por prioridad y zona y la fecha requerida más próxima; recommendations vacío (CL-08) |

| AiSummaryService | Orquesta: autoriza Coordinador, valida selección, proyecta seis campos, construye el prompt, llama con plazo, valida, guarda borrador u origen fallback |

El proveedor se elige con AI_PROVIDER=gemini|groq|replay|fixture|none en .env. El valor por defecto en .env.example es none, así que la demo funciona sin clave usando el fallback.

Uso del LLM real. La API gratuita se usa en una demostración manual. La respuesta obtenida se guarda además como captura de reproducción para que la evidencia sea repetible aunque la cuota o la clave no estén disponibles cuando el docente evalúe. La captura se declara como reproducción, sin afirmar una invocación en vivo (§10).

Reglas de validación de la selección (orden propuesto en H-V02, CL-19): formato de la lista 1–20 IDs únicos (422) → pertenencia a la organización (404) → estado ENVIADA (409). El proveedor no se invoca si falla cualquiera.

Construcción del prompt. Instrucciones fijas del sistema y, separado, un bloque JSON con los seis campos. Las observaciones van dentro de ese bloque como datos. Se pide responder solo JSON con el formato del esquema y, si el proveedor lo permite, se activa su modo de salida JSON. Esto reduce errores, pero no sustituye la validación en código.

Plazo. El cliente HTTP corta a los 5 s. La prueba usa reloj controlado y una tolerancia máxima propuesta de 250 ms (H-V01, por confirmar en el plan de pruebas).

Persistencia (CL-05). Tabla de resúmenes: id, organización, coordinador, IDs seleccionados, summary, recommendations, origen (tipo, proveedor, modelo, fixture), estado BORRADOR o APROBADO, aprobado por y fecha UTC. Tabla de intentos: fecha, origen, resultado (válido, inválido, timeout, error) y motivo sanitizado; nunca el prompt con secretos ni la clave.

Aprobación. En una transacción: estado APROBADO, aprobador, fecha UTC y evento de auditoría con los campos de RF09. Un resumen alternativo también se puede aprobar, conservando su origen (H-V03). Aprobar dos veces devuelve 409 sin segundo evento (H-V04).

Presentación. summary y reason se muestran con escape de Blade ({{ }}), nunca con {!! !!}. La pantalla etiqueta el borrador como «Asistencia de IA» y muestra su origen.

Consecuencias y riesgos

- (+) CI y la demo funcionan sin red ni clave (RNF06); el flujo principal no depende de la IA.
- (+) Cambiar de proveedor solo requiere otra implementación de AiProvider.
- (−) Más código y pruebas que una llamada directa.
- Riesgo: cuota agotada o error 429 del plan gratuito → fallback controlado; evidencia real en la captura de reproducción.
- Riesgo: fuga de la clave → solo en .env (ignorado por Git), detección de secretos en CI (CI-11) y nunca en logs.
- Riesgo: el plan gratuito puede usar los datos enviados para mejorar el servicio → solo se envían datos ficticios del examen.
- Riesgo: inyección de instrucciones → el modelo no tiene herramientas; la salida se valida contra el esquema y la selección; las acciones solo ocurren por operaciones normales del coordinador.

RF y AC afectados

RF02, RF09, RF10, RF11, RF12, RNF01, RNF06; AC-05-01 a AC-05-14; hallazgos H-V01 a H-V04 y H-V07.

Verificación de la decisión

Prueba prevista	AC	Cómo
Payload solo con seis campos y la selección	AC-05-01	Proveedor espía que guarda el prompt recibido
Siete fixtures oficiales	AC-05-02, 03, 06, 07, 08, 14	FixtureProvider con cada id; resultado igual a su campo expected
Selección inválida no invoca al proveedor	AC-05-05	Proveedor espía con contador de llamadas en 0
Plazo de 5 s	AC-05-03	Reloj controlado; corte ≤ 5 s + tolerancia
Marcado escapado con salida válida	AC-05-08 (V-09b)	Prueba de vista: el HTML contiene <script>
Aprobación sin efectos de negocio	AC-05-04, 05-12	Snapshot de solicitudes e inventario antes y después
Salida real por el mismo validador	AC-05-13	ReplayProvider con la captura real
CI sin red ni clave	AC-05-14	El workflow no define AI_API_KEY y usa AI_PROVIDER=fixture

Autor y revisión humana

- Autor: Vega José (asistido por IA, AI-004).
- Revisión humana: pendiente de una persona distinta del autor en la revisión G2.

docs/architecture/componentes.md

Componentes y fronteras — propuesta G2

Todos los módulos comparten proceso Laravel y una base; los bloques no son microservicios. Flechas indican llamadas o acceso autorizado. ADR-001 define dependencias; ADR-002/003 pendientes concretan transacción y sesión.

```
flowchart TB
    browser["Navegador no confiable: Blade y formularios"] -->|"HTTPS y credencial de sesión"| gateway
    subgraph backend["Proceso Laravel: frontera de aplicación"]
        gateway["Rutas, validación y autorización"] --> identity["Identity: sesión, rol y
organización"]
        gateway --> requests["Requests: borrador y envío"]
        gateway --> inventory["Inventory: reserva y transiciones"]
        gateway --> queries["Queries: filtros y agregados autorizados"]
        gateway --> ai["AI: selección y aprobación humana"]
        gateway --> operations["Operations: health, readiness y logs"]
        inventory --> requests
        inventory --> idempotency["Idempotency: ámbito y resultado"]
        requests --> audit["Audit: eventos append-only"]
        inventory --> audit
        ai --> audit
        ai -->|"Solo lectura autorizada"| requests
        ai --> adapter["Adaptador, validador y fallback"]
    end
    requests --> database[("PostgreSQL: organización en cada recurso")]
    inventory --> database
    idempotency --> database
    audit --> database
    queries --> database
    identity --> database
    ai --> database
    operations -->|"Readiness"| database
    adapter -->|"Payload permitido; deadline 5 s"| provider["Proveedor externo no confiable"]
    provider -->|"Salida sin herramientas privilegiadas"| adapter
```

La persistencia AI solo guarda resumen/aprobación/intento, no inventario. Requests/Inventory/Idempotency/Audit deben usar la misma transacción para cada transición; no llamadas HTTP internas ni colas para confirmar stock. Logs de rechazos son técnicos, no eventos de transición exitosa. Readiness no llama al LLM, por lo que un proveedor caído no impide usar el sistema. Identidad y filtros se aplican antes del replay idempotente. Texto IA se escapa en la UI.

docs/architecture/contexto.md

Contexto — propuesta G2

ADR-001; RF01–12. G1 y G2 sin aprobación. API/Blade y PostgreSQL dentro del sistema; proveedor externo sin privilegios. Datos y credenciales ficticios para demo.

```
flowchart LR
    solicitante["Solicitante de ORG-A u ORG-B"] -->|"Crear, enviar y cancelar propias"| sistema
    coordinador["Coordinador de ORG-A u ORG-B"] -->|"Reservar, entregar y revisar IA"| sistema
    bodega["Bodega de ORG-A u ORG-B"] -->|"Consultar inventario y despachar"| sistema
    auditor["Auditor de ORG-A u ORG-B"] -->|"Consultar organización e historial"| sistema
    operador["Operador o evaluador"] -->|"Health y readiness"| sistema
    subgraph limiteSistema["NexoEntrega 360"]
        sistema["Laravel: UI y API autorizada"] -->|"Transacciones y lecturas aisladas"|
postgres[("PostgreSQL")]
    end
    sistema -->|"Hasta 20 ENVIADA y seis campos autorizados"| proveedor["Proveedor LLM externo"]
    proveedor -->|"Texto no confiable: validar o fallback"| sistema
```

Toda petición lleva identidad del servidor y alcance de organización; los usuarios no acceden directamente a PostgreSQL o al proveedor. CL-16/17/18 no amplían los permisos mostrados. El evaluador consulta operación sin recibir secretos. No hay prueba de despliegue ni rendimiento asociada todavía.

docs/architecture/datos.md

Modelo de datos — G2

Vista de datos exigida por el enunciado §6. Motor: PostgreSQL (ADR-001). Restricciones transaccionales en [ADR-002](../adr/ADR-002-transacciones-idempotencia.md); tablas del asistente en [ADR-004](../adr/ADR-004-integracion-ia-degradacion.md). Nombres de tablas y columnas orientativos para las migraciones de Laravel.

```
erDiagram
    organizations ||--o{ users : "tiene"
    organizations ||--o{ inventory_items : "posee"
    organizations ||--o{ requests : "agrupa"
    users ||--o{ requests : "crea (solicitante)"
    requests ||--|{ request_lines : "contiene 1-10"
    inventory_items ||--o{ request_lines : "referenciado por"
    organizations ||--o{ audit_events : "registra"
    users ||--o{ audit_events : "actor"
    users ||--o{ idempotency_records : "envía"
    organizations ||--o{ ai_summaries : "agrupa"
    users ||--o{ ai_summaries : "coordinador"
    ai_summaries ||--o{ ai_attempts : "intentos"

    organizations {
        string id PK "ORG-A, ORG-B"
        string name
    }
    users {
        bigint id PK
        string organization_id FK
        string email UK "login ficticio"
        string password "hash"
        string role "SOLICITANTE, COORDINADOR, BODEGA, AUDITOR"
    }
    inventory_items {
        string organization_id PK "FK"
        string sku PK
        boolean active
        int fisico "CHECK >= 0"
        int reservado "CHECK >= 0 y <= fisico"
    }
    requests {
        uuid id PK
        string organization_id FK
        string codigo "UNIQUE por organizacion"
        bigint solicitante_id FK
        string estado "CHECK 6 estados"
        string zona
        string prioridad "NORMAL, ALTA"
        timestamptz fecha_requerida
        string observaciones "max 1000"
        timestamptz created_at
        timestamptz updated_at
    }
    request_lines {
        uuid request_id PK "FK"
        string sku PK
        string organization_id "FK compuesta"
        int cantidad "CHECK 1-500"
    }
    audit_events {
        uuid id PK
        string organization_id FK
        bigint actor_id FK
        string resource_type
        string resource_id
        string action
        timestamptz occurred_at "UTC"
        uuid correlation_id
        jsonb antes
        jsonb despues
    }
    idempotency_records {
        bigint id PK
        string organization_id "UK compuesta"
        bigint user_id "UK compuesta"
        string operation "UK compuesta"
        string idempotency_key "UK compuesta, 1-128"
        string request_hash "SHA-256"
        smallint response_status "200 o 409"
        jsonb response_body
        timestamptz created_at
        timestamptz expires_at "created_at + 24 h"
    }
    ai_summaries {
        uuid id PK
        string organization_id FK
```

```
        bigint coordinador_id FK
        jsonb request_ids
        string summary "max 600"
        jsonb recommendations
        jsonb origen
        string estado "BORRADOR, APROBADO"
        bigint aprobado_por
        timestamptz aprobado_at
    }
    ai_attempts {
        uuid id PK
        uuid summary_id FK
        string resultado "valido, invalido, timeout, error"
        string motivo "sanitizado"
        timestamptz created_at
    }
```

Restricciones e índices

| Tabla | Restricción | Requisito |

|---|---|---|

| inventory_items | CHECK (fisico >= 0 AND reservado >= 0 AND reservado <= fisico); disponible = fisico − reservado se calcula, no se guarda | RF05, RNF02 |

| requests | CHECK (estado IN ('BORRADOR','ENVIADA','RESERVADA','DESPACHADA','ENTREGADA','CANCELADA')); CHECK (prioridad IN ('NORMAL','ALTA')); UNIQUE (organization_id, codigo); UNIQUE (id, organization_id) para la FK compuesta | RF03, RF04 |

| request_lines | PRIMARY KEY (request_id, sku) (sin SKU repetidos); CHECK (cantidad BETWEEN 1 AND 500); FK (request_id, organization_id) → requests; FK (organization_id, sku) → inventory_items | RF02, RF03 |

| audit_events | Trigger que rechaza UPDATE y DELETE; índice (organization_id, resource_id, occurred_at) | RF09 |

| idempotency_records | UNIQUE (organization_id, user_id, operation, idempotency_key); índice en expires_at para la limpieza | RF07 |

| Todas las de negocio | organization_id obligatorio; toda consulta filtra por la organización de la identidad | RF02 |

Las restricciones no sustituyen las validaciones de la aplicación (que devuelven 422 o 409 con mensaje claro); son una segunda barrera que impide datos imposibles aunque haya un error de código.

Correspondencia con el contrato y el seed

| Contrato (openapi.yaml) | Columna |

|---|---|

| Solicitud.codigo, estado, zona, prioridad, fechaRequerida, observaciones | requests.* |

| LineaSolicitud.sku, cantidad | request_lines.* |

| InventarioItem.fisico, reservado, disponible, activo | inventory_items.* (disponible calculado) |

| EventoAuditoria.actorId, organizationId, resourceId, action, occurredAt, correlationId | audit_events.* |

El seed pequeño traduce fixture-scenarios.json: 2 organizaciones, 8 usuarios, 6 filas de inventario (por ejemplo, ORG-A KIT-ALIMENTO 10/0) y las solicitudes A-001, A-002 y B-001. El seed de carga de 2.000 solicitudes es independiente (§12).

docs/architecture/estados.md

Estados de la solicitud — G2

Vista de estados exigida por el enunciado §6. Reglas de RF04 y RF06 y actores del §2. Implementación transaccional en [ADR-002](../adr/ADR-002-transacciones-idempotencia.md).

```
stateDiagram-v2
    direction LR
    [*] --> BORRADOR: Crear (Solicitante)
    BORRADOR --> BORRADOR: Editar (Solicitante dueño)
    BORRADOR --> ENVIADA: Enviar (Solicitante dueño)
    ENVIADA --> RESERVADA: Reservar (Coordinador)<br/>reservado += cantidad
    RESERVADA --> DESPACHADA: Despachar (Bodega)<br/>fisico -= cantidad, reservado -= cantidad
    DESPACHADA --> ENTREGADA: Entregar (Coordinador)<br/>sin cambio de stock
    ENVIADA --> CANCELADA: Cancelar (Solicitante dueño)<br/>sin cambio de stock
    RESERVADA --> CANCELADA: Cancelar (Solicitante dueño)<br/>reservado -= cantidad
    ENTREGADA --> [*]
    CANCELADA --> [*]
```

Matriz de transiciones

Cualquier combinación que no aparezca como permitida responde 409 y conserva datos, inventario y auditoría (RF04). Un rol sin permiso sobre una solicitud de su organización recibe 403; una solicitud de otra organización, 404 (§2).

| Desde \ Acción | Editar | Enviar | Reservar | Despachar | Entregar | Cancelar |

|---|---|---|---|---|---|---|

| BORRADOR | □ | □ | 409 | 409 | 409 | 409 |

| ENVIADA | 409 | 409 | □ | 409 | 409 | □ |

| RESERVADA | 409 | 409 | 409 | □ | 409 | □ |

| DESPACHADA | 409 | 409 | 409 | 409 | □ | 409 |

| ENTREGADA | 409 | 409 | 409 | 409 | 409 | 409 |

| CANCELADA | 409 | 409 | 409 | 409 | 409 | 409 |

Efecto de cada transición permitida

Ejemplo con el oráculo oficial: KIT-ALIMENTO de ORG-A con físico 10 y A-001 de 7 unidades (físico / reservado / disponible).

| Transición | Actor | Antes | Después | Evento de auditoría |

|---|---|---|---|---|

| Enviar | Solicitante dueño | 10 / 0 / 10 | 10 / 0 / 10 | Sí |

| Reservar | Coordinador | 10 / 0 / 10 | 10 / 7 / 3 | Sí |

| Despachar | Bodega | 10 / 7 / 3 | 3 / 0 / 3 | Sí |

| Entregar | Coordinador | 3 / 0 / 3 | 3 / 0 / 3 | Sí |

| Cancelar desde ENVIADA | Solicitante dueño | 10 / 0 / 10 | 10 / 0 / 10 | Sí |

| Cancelar desde RESERVADA | Solicitante dueño | 10 / 7 / 3 | 10 / 0 / 10 | Sí |

Los estados ENTREGADA y CANCELADA son finales. Editar solo es posible en BORRADOR. Las pruebas de AC-03-07 recorren todas las celdas 409 de la matriz.

docs/architecture/secuencia-ia-con-fallo.md

Secuencia: consulta de IA con fallo

Diagrama exigido por el enunciado §6 («consulta de IA con fallo»). Decisión de diseño en [ADR-004](../adr/ADR-004-integracion-ia-degradacion.md). Fronteras de confianza: el navegador y el proveedor de IA son no confiables; la API y la base de datos son confiables.

```
sequenceDiagram
    autonumber
    actor C as Coordinador (ORG-A)
    box rgba(200,80,80,0.12) No confiable
        participant W as Navegador
    end
    box rgba(80,140,200,0.12) Confiable - servidor
        participant A as API Laravel<br/>AiSummaryService
        participant V as AiOutputValidator
        participant F as FallbackSummarizer
        participant DB as Base de datos
    end
    box rgba(200,80,80,0.12) No confiable - externo
        participant P as Proveedor IA<br/>(AiProvider)
    end

    C->>W: Selecciona A-001 y A-002 y pide resumen
    W->>A: POST /api/ai/summaries {requestIds}
    A->>A: Sesión válida y rol Coordinador (401 / 403)
    A->>A: 1–20 IDs únicos (422)
    A->>DB: Cargar solicitudes de ORG-A por ID
    DB-->>A: Solicitudes
    A->>A: Todas de ORG-A (404) y ENVIADA (409)
    A->>A: Proyectar solo requestId, zona, prioridad,<br/>fechaRequerida, estado, observaciones
    A->>P: complete(prompt, timeout = 5 s)

    alt Respuesta a tiempo
        P-->>A: Texto crudo
        A->>V: Validar JSON, esquema y pertenencia de IDs
        alt Salida válida
            V-->>A: OK
            A->>DB: Guardar borrador (origen proveedor y modelo) e intento válido
            A-->>W: 200 borrador «Asistencia de IA»
        else Salida inválida (JSON roto, campo extra, ID ajeno o repetido, límites)
            V-->>A: Rechazo con motivo
            A->>F: Resumen determinista de la selección
            F-->>A: summary, recommendations = []
            A->>DB: Guardar borrador (origen fallback) e intento inválido con motivo sanitizado
            A-->>W: 200 mensaje controlado + resumen alternativo
        end
    else Timeout a los 5 s o error del proveedor
        P--xA: Sin respuesta / error
        A->>F: Resumen determinista de la selección
        F-->>A: summary, recommendations = []
        A->>DB: Guardar borrador (origen fallback) e intento timeout o error
        A-->>W: 200 mensaje controlado + resumen alternativo
    end

    Note over A,DB: Ninguna rama escribe inventario, estado ni prioridad
    W-->>C: Muestra el borrador con texto escapado

    C->>W: Aprueba el borrador
    W->>A: POST /api/ai/summaries/{id}/approve
    A->>DB: Transacción: estado APROBADO + evento de auditoría (RF09)
    DB-->>A: Confirmado
    A-->>W: 200 aprobado (segunda aprobación: 409)
```

Lectura del diagrama

Paso	Requisito	Qué garantiza
3–7	RF02, RF10, CL-19	Rechazos 401, 403, 422, 404 y 409 antes de llamar al proveedor
8	RF10	El proveedor recibe solo los seis campos autorizados
9	RF12	Plazo de 5 s
Rama «salida inválida»	RF11	El esquema y la pertenencia se validan en el servidor; el texto del modelo no se ejecuta
Rama «timeout o error»	RF12, RNF06	Mensaje controlado y resumen determinista; el resto del sistema sigue funcionando

| Nota | RF12, §10 | El modelo nunca escribe inventario ni invoca operaciones privilegiadas |

| Aprobación | RF09, RF12 | Evento de auditoría en la misma transacción; sin efectos sobre el negocio |

El diagrama debe coincidir con el código entregado (§6); si la implementación cambia, se actualiza en el mismo PR.

docs/architecture/secuencia-reserva-concurrente.md

Secuencia: reserva concurrente

Diagrama exigido por el enunciado §6 («reserva concurrente»). Decisión en [ADR-002](../adr/ADR-002-transacciones-idempotencia.md). Escenario del oráculo oficial: KIT-ALIMENTO de ORG-A con físico 10 y reservado 0; A-001 y A-002, ambas ENVIADA con 7 unidades, se reservan al mismo tiempo con claves distintas K1 y K2. No se fija cuál gana; el diagrama muestra el caso en que T1 obtiene primero el bloqueo del stock.

```
sequenceDiagram
    autonumber
    participant T1 as Petición T1<br/>reservar A-001 (K1)
    participant T2 as Petición T2<br/>reservar A-002 (K2)
    participant API as API Laravel<br/>módulo Inventory
    participant DB as PostgreSQL

    par Llegan a la vez
        T1->>API: POST /api/requests/A-001/reserve (K1)
    and
        T2->>API: POST /api/requests/A-002/reserve (K2)
    end
    Note over API: Ambas: sesión, organización (404), rol Coordinador (403), cuerpo y clave (422)

    API->>DB: T1: BEGIN, lock consultivo K1, buscar K1 (no existe)
    API->>DB: T2: BEGIN, lock consultivo K2, buscar K2 (no existe)
    API->>DB: T1: SELECT A-001 FOR UPDATE (ENVIADA)
    API->>DB: T2: SELECT A-002 FOR UPDATE (ENVIADA)
    API->>DB: T1: SELECT stock KIT-ALIMENTO FOR UPDATE
    DB-->>API: T1 obtiene el bloqueo: 10 / 0
    API->>DB: T2: SELECT stock KIT-ALIMENTO FOR UPDATE
    Note over DB: T2 espera: la fila está bloqueada por T1

    API->>API: T1: disponible 10 >= 7
    API->>DB: T1: reservado = 7, A-001 RESERVADA, evento, registro K1 = 200
    API->>DB: T1: COMMIT
    API-->>T1: 200 A-001 RESERVADA

    DB-->>API: T2 obtiene el bloqueo con la versión confirmada: 10 / 7
    API->>API: T2: disponible 3 < 7
    API->>DB: T2: registro K2 = 409 (sin tocar stock ni estado), COMMIT
    API-->>T2: 409 stock insuficiente

    Note over DB: Final: físico 10, reservado 7, disponible 3, A-001 RESERVADA, A-002 ENVIADA,
exactamente un evento de reserva
```

Por qué es correcto

| Riesgo | Cómo lo evita el diseño |

|---|---|

| Ambas reservas exitosas (doble promesa de stock) | La fila de stock se bloquea con FOR UPDATE; T2 solo puede leerla después de que T1 confirma, y en READ COMMITTED recibe la versión ya actualizada (reservado 7) |

| Reserva parcial con varias líneas | Todas las filas se comprueban antes de escribir; si alguna falla, no se modifica ninguna (RF05) |

| Deadlock entre dos solicitudes con varios SKU | Todas las transacciones bloquean en el mismo orden: solicitud y luego stock por SKU ascendente |

| Mismo pedido enviado dos veces con la misma clave | El bloqueo consultivo de la clave serializa ambas; la segunda encuentra el registro y repite la respuesta sin nuevos efectos |

| Fallo a mitad de la transacción | ROLLBACK total; ni stock, ni estado, ni evento, ni registro de idempotencia (AC-03-09) |

Cómo se prueba (AC-03-03 y AC-03-08)

1. Restablecer el seed (10 / 0; A-001 y A-002 ENVIADA).

2. Lanzar dos procesos reales que esperan en una barrera y envían las dos reservas a la vez.

3. Oráculo escrito antes: una respuesta 200 y una 409 (sin importar cuál), stock 10 / 7 / 3 y un solo evento de reserva, comprobado con una consulta directa a PostgreSQL.

4. Repetir al menos 20 veces con datos limpios; cualquier repetición con dos 200 o reservado distinto de 7 es un defecto.

contracts/README.md

Contratos G2 propuestos

openapi.yaml une rutas base y openapi-ia.yaml v0.2.0, conservando exactamente rutas y componentes IA del commit 833e9b99ef97d2be23b49a8a1778f54265c99a0a de docs/g2-vega-ia (corrección CSRF de Vega). ai-output.schema.json describe salida del modelo; no sustituye el envoltorio de respuesta HTTP. No hay implementación ni revisión G2 global aprobada.

Base usa nombres de campos españoles de SPEC 0.3 (NORMAL/ALTA y fecha RFC3339), IDs string y prefijo /api. Generación y validación:

```
python -m venv .venv-docs
.\.venv-docs\Scripts\python.exe -m pip install -r contracts/requirements-docs.lock
.\.venv-docs\Scripts\python.exe scripts/build_openapi.py
.\.venv-docs\Scripts\python.exe scripts/build_openapi.py --check
.\.venv-docs\Scripts\python.exe scripts/validate_openapi.py
```

Las versiones son herramientas documentales, no dependencias del producto Laravel. Para cambiar base, editar scripts/build_openapi.py; para cambiar IA, revisar su fragmento y regenerar. No permitir colisiones silenciosas.

Pendientes antes de implementar

- ADR-002: política final de errores idempotentes (propuesta 200/409 almacenados; no 401/403/404/422/500), TTL/conservación y transacción real.

- ADR-003 propone cookie revocable y Bcrypt costo 12; revisión humana del ADR pendiente. Base y fragmento IA ya declaran X-XSRF-TOKEN obligatorio y 419 en todas las escrituras. Bootstrap /api/auth/csrf y precedencia CSRF/autenticación siguen diseño, no middleware implementado. 419 es propuesta Laravel, no decisión del docente.

- CL-16/17/18: el coordinador reporta respuesta afirmativa de la profesora. Inventario: Coordinador/Bodega/Auditor, solo su organización. Auditoría: Auditor/Coordinador de su organización; Solicitante solo sus solicitudes; Bodega sin acceso. Tablero Solicitante propio, sin inventario. Fecha/canal y mensaje original pendientes; renovar revisión del contrato/SPEC modificados.

- Validar fecha al enviar, SKU activo y distinto, pertenencia, unicidad de IDs IA y relaciones físico/reservado no se resuelve solo con JSON Schema: controles semánticos de servidor pendientes.

- Auditoría solo lectura por API; errores sanitizados y correlationId. Liveness y readiness públicas sin secretos; readiness no depende de IA.

Este documento usa [OpenAPI 3.1.1](https://spec.openapis.org/oas/v3.1.1.html). La validación del contrato no demuestra que esas rutas existan ni cumplan los RF.

Regresiones documentales: el validador detecta una omisión artificial de CSRF en una escritura IA aun si OpenAPI sigue válido, y comprueba 401/403/404 del historial. No sustituye pruebas HTTP reales.

contracts/openapi.yaml

openapi: 3.1.1

info:

title: NexoEntrega 360 — contrato integrado

version: 0.1.0-draft

description: 'Diseño G2 propuesto, no API implementada. SPEC 0.3-draft; G1/G2 pendientes.

Laravel + PostgreSQL. Sesión/CSRF pendientes ADR-003. CL-16/17/18: respuesta afirmativa

reportada por coordinador; evidencia original pendiente. Rutas y componentes IA

copiados sin cambios desde openapi-ia.yaml v0.2.0 (CSRF corregido por Vega).'

servers:

- url: http://localhost:8000

description: Ejecución local

security:

- sesion: []

paths:

/api/ai/summaries:

post:

operationId: crearResumenIA

summary: Solicitar un resumen asistido por IA

description: 'Solo el rol Coordinador. Selección de 1 a 20 solicitudes ENVIADA

de su organización (RF10).

Orden de validación: 422 (formato) → 404 (pertenencia) → 409 (estado); si

falla, el proveedor

no se invoca. Con salida inválida, timeout de 5 s o fallo del proveedor responde

200 con

mensaje controlado y resumen determinista (RF12).

'

tags:

- Asistente IA

parameters:

- $ref: '#/components/parameters/CorrelationId'

- $ref: '#/components/parameters/CsrfToken'

requestBody:

required: true

content:

application/json:

schema:

$ref: '#/components/schemas/SolicitudResumen'

example:

requestIds:

- A-001

- A-002

responses:

'200':

description: Borrador generado por el proveedor o resumen alternativo

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/BorradorResumen'

examples:

proveedor:

summary: Salida válida del proveedor

value:

id: 3f6b1c2e-0d1a-4c7e-9f00-1a2b3c4d5e6f

status: BORRADOR

aiAssisted: true

origin:

type: provider

provider: gemini

model: flash

message: null

summary: Dos solicitudes pendientes requieren revisión.

recommendations:

- requestId: A-001

reason: Prioridad ALTA y fecha requerida más próxima.

evidenceFields:

- prioridad

- fechaRequerida

requestIds:

- A-001

- A-002

createdAt: '2030-01-10T14:00:00Z'

approvedBy: null

approvedAt: null

fallback:

summary: Timeout o salida inválida

value:

id: 7a1d2e3f-4b5c-6d7e-8f90-0a1b2c3d4e5f

status: BORRADOR

aiAssisted: true

origin:

type: fallback

message: El asistente no respondió a tiempo; se muestra un resumen

automático.

summary: '2 solicitudes: 1 ALTA, 1 NORMAL; zonas NORTE y SUR;

fecha más próxima 2030-01-11.'

recommendations: []

requestIds:

- A-001

- A-002

createdAt: '2030-01-10T14:00:05Z'

approvedBy: null

approvedAt: null

'401':

$ref: '#/components/responses/NoAutenticado'

'403':

$ref: '#/components/responses/Prohibido'

'404':

$ref: '#/components/responses/NoEncontrado'

'409':

$ref: '#/components/responses/Conflicto'

'422':

$ref: '#/components/responses/Invalido'

'419':

$ref: '#/components/responses/CsrfInvalido'

/api/ai/summaries/{summaryId}/approve:

post:

operationId: aprobarResumenIA

summary: Aprobar un borrador de resumen

description: 'Solo el Coordinador de la organización del borrador. Registra

aprobador, fecha UTC y un evento

de auditoría (RF09) en la misma transacción. No reserva, no despacha ni cambia

prioridades (RF12).

Un resumen alternativo también se puede aprobar. Una segunda aprobación devuelve

409.

'

tags:

- Asistente IA

parameters:

- name: summaryId

in: path

required: true

schema:

type: string

- $ref: '#/components/parameters/CorrelationId'

- $ref: '#/components/parameters/CsrfToken'

responses:

'200':

description: Borrador aprobado

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/BorradorResumen'

'401':

$ref: '#/components/responses/NoAutenticado'

'403':

$ref: '#/components/responses/Prohibido'

'404':

$ref: '#/components/responses/NoEncontrado'

'409':

$ref: '#/components/responses/Conflicto'

'419':

$ref: '#/components/responses/CsrfInvalido'

/api/auth/csrf:

get:

operationId: bootstrapCsrf

summary: Inicializar protección CSRF

tags:

- Base

description: Emite cookie XSRF-TOKEN, sin login ni conceder rol. Ruta de diseño

pendiente ADR-003.

parameters:

- $ref: '#/components/parameters/CorrelationId'

responses:

'204':

description: Inicializar protección CSRF

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

security: []

/api/auth/login:

post:

operationId: login

summary: Iniciar sesión

tags:

- Base

description: Verificar hash, regenerar sesión y emitir nexo_session HttpOnly;

Secure bajo HTTPS y SameSite. No retorna token/hash. Parámetros pendientes

ADR-003.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- $ref: '#/components/parameters/CsrfToken'

responses:

'200':

description: Iniciar sesión

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Identidad'

'401':

$ref: '#/components/responses/Base401'

'422':

$ref: '#/components/responses/Base422'

'419':

description: Token CSRF ausente o inválido; sesión cookie propuesta.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

requestBody:

required: true

content:

application/json:

schema:

$ref: '#/components/schemas/Credenciales'

security: []

/api/auth/logout:

post:

operationId: logout

summary: Revocar sesión

tags:

- Base

description: Revocar sesión y eliminar cookie; reutilización obtiene 401. No

cambia datos de negocio.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- $ref: '#/components/parameters/CsrfToken'

responses:

'204':

description: Revocar sesión

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

'401':

$ref: '#/components/responses/Base401'

'419':

description: Token CSRF ausente o inválido; sesión cookie propuesta.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

/api/auth/me:

get:

operationId: identidadActual

summary: Consultar identidad del servidor

tags:

- Base

description: ''

parameters:

- $ref: '#/components/parameters/CorrelationId'

responses:

'200':

description: Consultar identidad del servidor

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Identidad'

'401':

$ref: '#/components/responses/Base401'

x-roles: &id001

- Solicitante

- Coordinador

- Bodega

- Auditor

/api/requests:

post:

operationId: crearSolicitud

summary: Crear borrador propio

tags:

- Base

description: Organización, dueño y código generados por servidor. SKU activo

y distinto; rechazar duplicados por validación semántica. Cabecera+líneas

atómicas; stock inalterado.

parameters:

- $ref: '#/components/parameters/CorrelationId'
- $ref: '#/components/parameters/CsrfToken'
responses:
'201':
description: Crear borrador propio
headers:
X-Correlation-Id:
$ref: '#/components/headers/CorrelationId'
content:
application/json:
schema:
$ref: '#/components/schemas/Solicitud'
'401':
$ref: '#/components/responses/Base401'
'403':
$ref: '#/components/responses/Base403'
'422':
$ref: '#/components/responses/Base422'
'500':
$ref: '#/components/responses/Base500'
'419':
description: Token CSRF ausente o inválido; sesión cookie propuesta.
headers:
X-Correlation-Id:
$ref: '#/components/headers/CorrelationId'
content:
application/json:
schema:
$ref: '#/components/schemas/Error'
requestBody:
required: true
content:
application/json:
schema:
$ref: '#/components/schemas/BorradorSolicitud'
x-roles:
- Solicitante
get:
operationId: listarSolicitudes

summary: Listar solicitudes paginadas

tags:

- Base

description: Solicitante solo propias; otros roles organización. Filtrar alcance

antes de total/paginación; orden estable createdAt+id. Máximo 100. Vacío retorna

items=[].

parameters:

- $ref: '#/components/parameters/CorrelationId'

- &id003

name: page

in: query

schema:

type: integer

minimum: 1

default: 1

- &id004

name: pageSize

in: query

schema:

type: integer

minimum: 1

maximum: 100

default: 20

- &id005

name: estado

in: query

schema: &id010

type: string

enum:

- BORRADOR

- ENVIADA

- RESERVADA

- DESPACHADA

- ENTREGADA

- CANCELADA

- &id006

name: prioridad

in: query

schema: &id009

type: string

enum:

- NORMAL

- ALTA

- &id007

name: zona

in: query

schema: &id008

type: string

minLength: 1

responses:

'200':

description: Listar solicitudes paginadas

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/PaginaSolicitudes'

'401':

$ref: '#/components/responses/Base401'

'422':

$ref: '#/components/responses/Base422'

x-roles: *id001

/api/requests/{requestId}:

get:

operationId: consultarSolicitud

summary: Consultar solicitud

tags:

- Base

description: Solicitante solo propia; búsqueda con alcance evita revelar recursos

ajenos.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- &id002

$ref: '#/components/parameters/RequestId'

responses:

'200':

description: Consultar solicitud

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Solicitud'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'404':

$ref: '#/components/responses/Base404'

'422':

$ref: '#/components/responses/Base422'

x-roles: *id001

patch:

operationId: editarSolicitud

summary: Editar borrador propio

tags:

- Base

description: Reemplazo completo de campos editables, no merge parcial; solo

BORRADOR del dueño. Nunca modificar código/dueño/org. No cambia stock.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id002

- $ref: '#/components/parameters/CsrfToken'

responses:

'200':

description: Editar borrador propio

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Solicitud'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'404':

$ref: '#/components/responses/Base404'

'409':

$ref: '#/components/responses/Base409'

'422':

$ref: '#/components/responses/Base422'

'500':

$ref: '#/components/responses/Base500'

'419':

description: Token CSRF ausente o inválido; sesión cookie propuesta.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

requestBody:

required: true

content:

application/json:

schema:

$ref: '#/components/schemas/BorradorSolicitud'

x-roles:

- Solicitante

/api/requests/{requestId}/send:

post:

operationId: enviarSolicitud

summary: send solicitud

tags:

- Base

description: BORRADOR → ENVIADA; validar fechaRequerida >= instante de envío.

No cambia stock. Cuerpo requerido {} sin propiedades extra. Rechazo sin cambios

de negocio ni evento exitoso. Audit atómico.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id002
- $ref: '#/components/parameters/CsrfToken'
responses:
'200':
description: send solicitud
headers:
X-Correlation-Id:
$ref: '#/components/headers/CorrelationId'
content:
application/json:
schema:
$ref: '#/components/schemas/Solicitud'
'401':
$ref: '#/components/responses/Base401'
'403':
$ref: '#/components/responses/Base403'
'404':
$ref: '#/components/responses/Base404'
'409':
$ref: '#/components/responses/Base409'
'422':
$ref: '#/components/responses/Base422'
'500':
$ref: '#/components/responses/Base500'
'419':
description: Token CSRF ausente o inválido; sesión cookie propuesta.
headers:
X-Correlation-Id:
$ref: '#/components/headers/CorrelationId'
content:
application/json:
schema:
$ref: '#/components/schemas/Error'
requestBody:
required: true
content:
application/json:
schema:
type: object

additionalProperties: false

required: []

properties: {}

x-roles:

- Solicitante

/api/requests/{requestId}/reserve:

post:

operationId: reservarSolicitud

summary: reserve solicitud

tags:

- Base

description: ENVIADA → RESERVADA; todas las líneas o ninguna. Disponible=físico−reservado.

Aumenta reservado; stock/estado/auditoría/resultado idempotente atómicos.

Cuerpo requerido {} sin propiedades extra. Rechazo sin cambios de negocio

ni evento exitoso. Audit atómico. Misma reserva con otra clave devuelve 409.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id002

- $ref: '#/components/parameters/IdempotencyKey'

- $ref: '#/components/parameters/CsrfToken'

responses:

'200':

description: reserve solicitud

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Solicitud'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'404':

$ref: '#/components/responses/Base404'

'409':

$ref: '#/components/responses/Base409'

'422':

$ref: '#/components/responses/Base422'

'500':

$ref: '#/components/responses/Base500'

'419':

description: Token CSRF ausente o inválido; sesión cookie propuesta.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

requestBody:

required: true

content:

application/json:

schema:

type: object

additionalProperties: false

required: []

properties: {}

x-roles:

- Coordinador

/api/requests/{requestId}/dispatch:

post:

operationId: despacharSolicitud

summary: dispatch solicitud

tags:

- Base

description: RESERVADA → DESPACHADA; disminuyen físico y reservado por las cantidades

de solicitud. Cuerpo requerido {} sin propiedades extra. Rechazo sin cambios

de negocio ni evento exitoso. Audit atómico.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id002

- $ref: '#/components/parameters/CsrfToken'

responses:

'200':

description: dispatch solicitud

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Solicitud'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'404':

$ref: '#/components/responses/Base404'

'409':

$ref: '#/components/responses/Base409'

'422':

$ref: '#/components/responses/Base422'

'500':

$ref: '#/components/responses/Base500'

'419':

description: Token CSRF ausente o inválido; sesión cookie propuesta.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

requestBody:

required: true

content:

application/json:

schema:

type: object

additionalProperties: false

required: []

properties: {}

x-roles:

- Bodega

/api/requests/{requestId}/deliver:

post:

operationId: entregarSolicitud

summary: deliver solicitud

tags:

- Base

description: DESPACHADA → ENTREGADA; sin cambio de inventario. Cuerpo requerido

{} sin propiedades extra. Rechazo sin cambios de negocio ni evento exitoso.

Audit atómico.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id002

- $ref: '#/components/parameters/CsrfToken'

responses:

'200':

description: deliver solicitud

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Solicitud'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'404':

$ref: '#/components/responses/Base404'

'409':

$ref: '#/components/responses/Base409'

'422':

$ref: '#/components/responses/Base422'

'500':

$ref: '#/components/responses/Base500'

'419':

description: Token CSRF ausente o inválido; sesión cookie propuesta.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

requestBody:

required: true

content:

application/json:

schema:

type: object

additionalProperties: false

required: []

properties: {}

x-roles:

- Coordinador

/api/requests/{requestId}/cancel:

post:

operationId: cancelarSolicitud

summary: cancel solicitud

tags:

- Base

description: Dueño únicamente. ENVIADA o RESERVADA → CANCELADA. Liberar reserva

solo desde RESERVADA; físico inalterado. Cuerpo requerido {} sin propiedades

extra. Rechazo sin cambios de negocio ni evento exitoso. Audit atómico.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id002

- $ref: '#/components/parameters/CsrfToken'

responses:

'200':

description: cancel solicitud

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Solicitud'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'404':

$ref: '#/components/responses/Base404'

'409':

$ref: '#/components/responses/Base409'

'422':

$ref: '#/components/responses/Base422'

'500':

$ref: '#/components/responses/Base500'

'419':

description: Token CSRF ausente o inválido; sesión cookie propuesta.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

requestBody:

required: true

content:

application/json:

schema:

type: object

additionalProperties: false

required: []

properties: {}

x-roles:

- Solicitante

/api/inventory:

get:

operationId: listarInventario

summary: Consultar inventario

tags:

- Base

description: Solo lectura de organización autenticada. físico/reservado/disponible

no negativos. Coordinador incluido por CL-16 según respuesta docente reportada

por coordinador.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id003

- *id004

responses:

'200':

description: Consultar inventario

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/PaginaInventario'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'422':

$ref: '#/components/responses/Base422'

x-roles:

- Coordinador

- Bodega

- Auditor

/api/catalog:

get:

operationId: catalogoSkuActivo

summary: Consultar SKU activos para el formulario

tags:

- Base

description: Solo SKU activos de la organización autenticada; no revela cantidades

de inventario. Proyección para RF03.

parameters:

- $ref: '#/components/parameters/CorrelationId'

responses:

'200':

description: Consultar SKU activos para el formulario

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

type: array

items:

type: string

'401':

$ref: '#/components/responses/Base401'

x-roles: *id001

/api/dashboard:

get:

operationId: consultarTablero

summary: Consultar cantidades por estado

tags:

- Base

description: Alcance propio para Solicitante por CL-18 reportada; organización

para otros. Sin inventario ni datos ajenos.

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id005

- *id006

- *id007

responses:

'200':

description: Consultar cantidades por estado

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Tablero'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'422':

$ref: '#/components/responses/Base422'

x-roles: *id001

/api/audit:

get:

operationId: listarAuditoria

summary: Consultar auditoría inmutable

tags:

- Base

description: 'Auditor y Coordinador: organización; Solicitante: solo eventos de sus solicitudes (CL-17). Bodega sin acceso. Sin identidad: 401; recurso inexistente o de otra organización: 404; recurso de la misma organización pero lectura prohibida por rol o dueño: 403. Listados filtran el alcance antes de paginar y contar. Orden UTC+id. Sin rutas de edición o borrado.'

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id003

- *id004

responses:

'200':

description: Consultar auditoría inmutable

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/PaginaAuditoria'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'404':

$ref: '#/components/responses/Base404'

'422':

$ref: '#/components/responses/Base422'

x-roles:

- Auditor

- Coordinador

- Solicitante

x-error-policy:

unauthenticated: 401

missingOrOtherOrganization: 404

sameOrganizationForbiddenRoleOrOwner: 403

/api/requests/{requestId}/audit:

get:

operationId: historialSolicitud

summary: Consultar auditoría inmutable

tags:

- Base

description: 'Auditor y Coordinador: organización; Solicitante: solo eventos de sus solicitudes (CL-17). Bodega sin acceso. Sin identidad: 401; recurso inexistente o de otra organización: 404; recurso de la misma organización pero lectura prohibida por rol o dueño: 403. Listados filtran el alcance antes de paginar y contar. Orden UTC+id. Sin rutas de edición o borrado.'

parameters:

- $ref: '#/components/parameters/CorrelationId'

- *id003

- *id004

- *id002

responses:

'200':

description: Consultar auditoría inmutable

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/PaginaAuditoria'

'401':

$ref: '#/components/responses/Base401'

'403':

$ref: '#/components/responses/Base403'

'404':

$ref: '#/components/responses/Base404'

'422':

$ref: '#/components/responses/Base422'

x-roles:

- Auditor

- Coordinador

- Solicitante

x-error-policy:

unauthenticated: 401

missingOrOtherOrganization: 404

sameOrganizationForbiddenRoleOrOwner: 403

/health:

get:

operationId: health

summary: Liveness del proceso

tags:

- Base

description: 200 si proceso responde; no depende de DB o LLM. Sin detalles internos.

parameters:

- $ref: '#/components/parameters/CorrelationId'

responses:

'200':

description: Liveness del proceso

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Health'

security: []

/ready:

get:

operationId: readiness

summary: Readiness de persistencia

tags:

- Base

description: 200 si PostgreSQL accesible y migraciones esperadas aplicadas;

503 en otro caso. No depende de IA; sin secretos.

parameters:

- $ref: '#/components/parameters/CorrelationId'

responses:

'200':

description: Readiness de persistencia

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Readiness'

'503':

description: Base no disponible o migraciones pendientes.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Readiness'

security: []

components:

securitySchemes:

sesion:

type: apiKey

in: cookie

name: nexo_session

description: Provisional hasta ADR-003 (sesión de servidor revocable propuesta

en CL-14).

parameters:

CsrfToken:

name: X-XSRF-TOKEN

in: header

required: true

description: Propuesta CSRF para sesión cookie; obtener cookie XSRF-TOKEN desde

bootstrap y enviar token correspondiente. Pendiente ADR-003.

schema: *id008

CorrelationId:

name: X-Correlation-Id

in: header

required: false

description: Si falta o es inválido, el servidor genera uno.

schema:

type: string

format: uuid

RequestId:

name: requestId

in: path

required: true

schema: *id008

IdempotencyKey:

name: Idempotency-Key

in: header

required: true

description: Reserva. Autenticar y autorizar antes de replay. Ámbito usuario/org/operación;

hash canónico de requestId+cuerpo. Guardar 200 y 409 de negocio al menos 24h;

no guardar 401/403/404/422/500. TTL exacto/retención pendiente ADR-002 y acuerdo

CL-04/11.

schema:

type: string

minLength: 1

maxLength: 128

headers:

CorrelationId:

description: correlationId de la petición, igual al registrado en logs y auditoría.

schema:

type: string

format: uuid

schemas:

SolicitudResumen:

type: object

additionalProperties: false

required:

- requestIds

properties:

requestIds:

type: array

minItems: 1

maxItems: 20

uniqueItems: true

items:

type: string

minLength: 1

Recomendacion:

type: object

additionalProperties: false

required:

- requestId

- reason

- evidenceFields

properties:

requestId:

type: string

minLength: 1

reason:

type: string

minLength: 1

maxLength: 240

evidenceFields:

type: array

minItems: 1

maxItems: 3

uniqueItems: true

items:

enum:

- zona

- prioridad

- fechaRequerida

- observaciones

Origen:

type: object

additionalProperties: false

required:

- type

properties:

type:

enum:

- provider

- replay

- fixture
- fallback
provider:
type:
- string
- 'null'
model:
type:
- string
- 'null'
fixtureId:
type:
- string
- 'null'
BorradorResumen:
type: object
additionalProperties: false
required:
- id
- status
- aiAssisted
- origin
- message
- summary
- recommendations
- requestIds
- createdAt
- approvedBy
- approvedAt
properties:
id:
type: string
status:
enum:
- BORRADOR
- APROBADO
aiAssisted:
const: true
origin:

$ref: '#/components/schemas/Origen'

message:

description: Mensaje controlado cuando se usa el resumen alternativo; null

en otro caso.

type:

- string

- 'null'

summary:

type: string

minLength: 1

maxLength: 600

recommendations:

type: array

maxItems: 5

items:

$ref: '#/components/schemas/Recomendacion'

requestIds:

type: array

items:

type: string

createdAt:

type: string

format: date-time

approvedBy:

type:

- string

- 'null'

approvedAt:

type:

- string

- 'null'

format: date-time

Error:

type: object

additionalProperties: false

required:

- code

- message

- correlationId

properties:

code:

type: string

message:

type: string

field:

type:

- string

- 'null'

correlationId:

type: string

LineaSolicitud:

type: object

additionalProperties: false

required:

- sku

- cantidad

properties:

sku: *id008

cantidad:

type: integer

minimum: 1

maximum: 500

Credenciales:

type: object

additionalProperties: false

required:

- login

- password

properties:

login:

type: string

format: email

password:

type: string

minLength: 1

writeOnly: true

Identidad:

type: object

additionalProperties: false

required:

- id

- organizationId

- role

properties:

id: *id008

organizationId: *id008

role:

type: string

enum:

- Solicitante

- Coordinador

- Bodega

- Auditor

BorradorSolicitud:

type: object

additionalProperties: false

required:

- zona

- prioridad

- fechaRequerida

- lineas

properties:

zona: *id008

prioridad: *id009

fechaRequerida: &id011

type: string

format: date-time

observaciones:

type: string

maxLength: 1000

lineas:

type: array

minItems: 1

maxItems: 10

items:

$ref: '#/components/schemas/LineaSolicitud'

Solicitud:

type: object

additionalProperties: false

required:

- id

- codigo

- solicitanteId

- organizationId

- estado

- zona

- prioridad

- fechaRequerida

- observaciones

- lineas

- createdAt

- updatedAt

properties:

id: *id008

codigo: *id008

solicitanteId: *id008

organizationId: *id008

estado: *id010

zona: *id008

prioridad: *id009

fechaRequerida: *id011

observaciones:

type:

- string

- 'null'

maxLength: 1000

lineas:

type: array

minItems: 1

maxItems: 10

items:

$ref: '#/components/schemas/LineaSolicitud'

createdAt: *id011

updatedAt: *id011

InventarioItem:

type: object

additionalProperties: false

required:

- sku
- activo
- fisico
- reservado
- disponible

properties:

sku: *id008

activo:

type: boolean

fisico: &id012

type: integer

minimum: 0

reservado: *id012

disponible: *id012

EventoAuditoria:

type: object

additionalProperties: false

required:

- id
- actorId
- organizationId
- resourceId
- action
- occurredAt
- correlationId

properties:

id: *id008

actorId: *id008

organizationId: *id008

resourceId: *id008

action: *id008

occurredAt: *id011

correlationId: *id008

Tablero:

type: object

additionalProperties: false

required:

- cantidadesPorEstado

properties:

cantidadesPorEstado:

type: object

additionalProperties: false

required:

- BORRADOR

- ENVIADA

- RESERVADA

- DESPACHADA

- ENTREGADA

- CANCELADA

properties:

BORRADOR: *id012

ENVIADA: *id012

RESERVADA: *id012

DESPACHADA: *id012

ENTREGADA: *id012

CANCELADA: *id012

Health:

type: object

additionalProperties: false

required:

- status

properties:

status:

const: ok

Readiness:

type: object

additionalProperties: false

required:

- status

- database

properties:

status:

enum:

- ready

- not_ready

database:

enum:

- up

- down

PaginaSolicitudes:

type: object

additionalProperties: false

required:

- items

- page

- pageSize

- total

properties:

items:

type: array

maxItems: 100

items:

$ref: '#/components/schemas/Solicitud'

page:

type: integer

minimum: 1

pageSize:

type: integer

minimum: 1

maximum: 100

total: *id012

PaginaInventario:

type: object

additionalProperties: false

required:

- items

- page

- pageSize

- total

properties:

items:

type: array

maxItems: 100

items:

$ref: '#/components/schemas/InventarioItem'

page:

type: integer

minimum: 1

pageSize:

type: integer

minimum: 1

maximum: 100

total: *id012

PaginaAuditoria:

type: object

additionalProperties: false

required:

- items

- page

- pageSize

- total

properties:

items:

type: array

maxItems: 100

items:

$ref: '#/components/schemas/EventoAuditoria'

page:

type: integer

minimum: 1

pageSize:

type: integer

minimum: 1

maximum: 100

total: *id012

responses:

NoAutenticado:

description: Sin sesión válida

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

Prohibido:

description: Rol distinto de Coordinador

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

NoEncontrado:

description: Solicitud o borrador inexistente o de otra organización (no revela

existencia)

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

Conflicto:

description: Solicitud seleccionada fuera de ENVIADA, o borrador ya aprobado

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

CsrfInvalido:

description: Token CSRF ausente o inválido; sesión cookie propuesta.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

Invalido:

description: Selección vacía, con más de 20 IDs, con IDs repetidos o con propiedades

extra

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

Base401:

description: Sin identidad válida; no revela existencia de cuenta.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

Base403:

description: Acción prohibida por rol o dueño sobre recurso de la organización.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

Base404:

description: Recurso inexistente o de otra organización; sin revelar existencia.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

Base409:

description: Estado incompatible, stock insuficiente o contenido idempotente

conflictivo; sin efectos de negocio.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

Base422:

description: Formato o datos inválidos; code/message y field cuando corresponda,

sin escrituras parciales.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

Base500:

description: Fallo interno sanitizado; rollback antes de commit.

headers:

X-Correlation-Id:

$ref: '#/components/headers/CorrelationId'

content:

application/json:

schema:

$ref: '#/components/schemas/Error'

x-status: pending-human-review

x-source-ia: contracts/openapi-ia.yaml v0.2.0; rama docs/g2-vega-ia; 833e9b9

contracts/ai-output.schema.json


```
{
"$schema": "https://json-schema.org/draft/2020-12/schema",
"type": "object",
"additionalProperties": false,
"required": [
"summary",
"recommendations"
],
"properties": {
"summary": {
"type": "string",
"minLength": 1,
"maxLength": 600
},
"recommendations": {
"type": "array",
"maxItems": 5,
"items": {
"type": "object",
"additionalProperties": false,
"required": [
"requestId",
"reason",
"evidenceFields"
],
"properties": {
"requestId": {
"type": "string",
"minLength": 1
},
"reason": {
"type": "string",
"minLength": 1,
"maxLength": 240
},
"evidenceFields": {
"type": "array",
"minItems": 1,
```

```
"maxItems": 3,
"uniqueItems": true,
"items": {
"enum": [
"zona",
"prioridad",
"fechaRequerida",
"observaciones"
]
}
}
}
}
}
}
}
```

Uso de IA y revisión

docs/evidence/ai-log/AI-001-cotejo-oficial-g1.md

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

- ID y fecha UTC: AI-001, 2026-10-14T03:29Z a 2026-10-14T04:00Z (aprox.)

- Autor: Castro Edier (202311254074), quien solicitó la intervención y entregó los archivos oficiales

- Etapa: especificación y revisión crítica (G1)

- Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai con espacio de trabajo de archivos y Python

- RF y AC: RF01–RF12 y RNF01–RNF06; todos los AC de SPEC-01 a SPEC-05

- Contexto y versiones de archivos: rama docs/g1-specifications en 6fa084c (SPEC 0.2-draft); Examen_Estudiantes_SDD_IA.pdf SHA-256 bad0b194…cc49; Anexos_Estudiantes_SDD_IA.zip SHA-256 26890046…bb3e (hashes completos en docs/examen-oficial/inventario.md)

Objetivo

Inventariar los documentos oficiales, cotejar RF01–RF12 y RNF01–RNF06 contra las cinco SPEC del PR #1, corregir los problemas documentales que no requieren decisión del cliente, dejar pendientes las que sí, y regenerar cotejo, matriz y JSON comprobando su coherencia.

Prompt enviado

Instrucción del coordinador del equipo, entregada por Edier junto con el PDF y el ZIP oficiales:

> voy a proporcionarte los documentos oficiales del examen NexoEntrega 360. Necesito que revises cada documento recibido y actualices el inventario de docs/examen-oficial/. Conserva los nombres originales y diferencia los archivos oficiales de las transcripciones o notas del equipo. Compara exhaustivamente los requisitos RF01–RF12 y RNF01–RNF06 contra las cinco SPECS del PR #1. Identifica omisiones, contradicciones, ambigüedades y criterios de aceptación insuficientes. Corrige los problemas documentales que no requieran decisiones del cliente y deja pendientes las aclaraciones que sí dependan del docente. Actualiza el cotejo oficial, la matriz de cobertura y los JSON derivados, comprobando su coherencia. No declares G1 aprobado ni fusiones el PR hasta que una persona distinta del autor revise la versión final. Cuando termines, entrégame un resumen con los requisitos cubiertos, las diferencias encontradas, las correcciones y el SHA exacto que deben revisar mis compañeros.

Salida relevante

- Originales guardados sin cambios en docs/examen-oficial/ con SHA256SUMS.txt e inventario.

- Cotejo en docs/reviews/cotejo-oficial-G1.md: en 0.2, 5 requisitos coincidían, 7 estaban incompletos, 5 contradecían el enunciado (matriz de permisos, prioridades, actores de transición, selección y campos de IA, RNF04) y 1 era ambiguo; 24 diferencias D-01 a D-24.

- SPEC 0.3-draft en el formato del anexo 13 con entradas tipadas y AC dado/cuando/entonces; 68 AC (antes 57), con requisitos y tipo de escenario por AC.

- Exportador y pruebas documentales reescritos; matriz y docs/evidence/traceability.csv generados desde la fuente única.

- Registro de aclaraciones reclasificado; CL-16, CL-17 y CL-18 requieren decisión del docente.

- Diferencias no corregidas: D-20 (CI de coincidencia JSON), D-21 (formato de la constitution) y D-22 (envío de preguntas al docente).

Decisión humana

Registrada por Edier tras revisar la salida:

| Cambio | Decisión de Edier (aceptada / corregida / descartada) | Motivo | Fecha UTC |

|---|---|---|---|

| Inventario y originales oficiales | Aceptada | Los archivos son los que descargó de la plataforma oficial | 2026-10-14 |

| Diferencias D-01 a D-24 y su clasificación | Aceptada | Revisó las diferencias contra el PDF y está de acuerdo | 2026-10-14 |

| SPEC-03 (área asignada a Edier): actores, oráculos, AC-03-14 a AC-03-16 | Aceptada | Coinciden con la p. 4 del PDF y con acceptance-oracles.md | 2026-10-14 |

| Migración de formato (D-15) y nuevo exportador | Aceptada | Revisada junto con SPEC-03 | 2026-10-14 |

| Supuestos de equipo (CL-02, CL-04, CL-11, CL-19) | Aceptada como propuesta | Quedan como propuesta; el equipo debe acordarlos | 2026-10-14 |

La aprobación de G1 la hace además una persona distinta del autor; esta intervención no aprueba sus propias salidas.

Verificación

Ejecutada por el asistente en su espacio de trabajo (salidas completas en docs/evidence/g1-validation.md, ejecución 2):

- python scripts/export_specs.py --check: 5 SPEC y 68 AC coherentes.

- python scripts/build_coverage.py --check: matriz y traza coherentes.

- python -m unittest discover -s scripts -p "test_*.py" -v: 14 pruebas OK.

- sha256sum -c SHA256SUMS.txt: 29 archivos OK.

Verificación humana pendiente: Edier y el revisor deben repetir los comandos y contrastar el cotejo con el PDF.

Límites

- El cotejo lo produjo un modelo de IA; puede contener interpretaciones erróneas. Cada fila cita página para facilitar la comprobación.

- No se ejecutó ninguna prueba de producto: no existe aplicación.

- Los supuestos marcados «Decisión del equipo» no han sido acordados por el equipo.

- No se incluyeron claves, credenciales ni datos reales. El anexo untrusted-observation.txt se trató como dato de prueba, no como instrucción.

docs/evidence/ai-log/AI-002-escenarios-inventario.md

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

- ID y fecha UTC: AI-002, 2026-10-14T05:15Z

- Autor: Castro Edier (202311254074)

- Etapa: revisión crítica de especificación y diseño de pruebas (G1)

- Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

- RF y AC: RF02, RF04–RF07, RF09, RNF02; AC-03-01 a AC-03-16, AC-01-09

- Contexto y versiones de archivos: commit 560c9cbe7972fcfe2258406ca7ed5f094b5a50e3 (SPEC-03 0.3-draft); anexos acceptance-oracles.md y fixture-scenarios.json; guía docs/team/instrucciones-edier.md

Objetivo

Preparar el aporte individual de Edier: revisar SPEC-03 contra las invariantes de inventario y redactar los escenarios previstos de reserva, concurrencia, cancelación, despacho, entrega, fallo antes del commit e idempotencia, con datos iniciales, esperado y efectos persistidos.

Prompt enviado

> terminemos con lo mio

Contexto dado en la misma conversación: la guía instrucciones-edier.md (tabla de escenarios con AC, datos iniciales, actor, acción, respuesta esperada, estado, stock, eventos y fuente; observado «no ejecutado»; registrar ambigüedades como preguntas).

Salida relevante

- docs/reviews/aportes/edier-G1.md: seis comprobaciones documentales, 17 escenarios previstos (E-01 a E-17) con oráculos del anexo y cuatro hallazgos (H-E01 a H-E04).

- Hallazgos principales: falta el código HTTP del fallo inducido antes del commit (H-E01) y no hay AC para la carrera entre despacho y cancelación de la misma reserva (H-E02).

Decisión humana

PENDIENTE. Edier debe revisar cada escenario y hallazgo y anotar aquí si los acepta, corrige o descarta, con su motivo y fecha UTC.

Verificación

- Las cantidades esperadas se contrastaron con acceptance-oracles.md y con el seed de fixture-scenarios.json.

- python scripts/export_specs.py --check y python scripts/build_coverage.py --check sin errores sobre el SHA revisado.

- Verificación humana pendiente: Edier debe comprobar los escenarios contra la p. 4 del enunciado.

Límites

Los escenarios son previstos; ninguno se ejecutó. Los hallazgos son propuestas para el equipo, no decisiones del cliente. Sin datos reales ni secretos.

docs/evidence/ai-log/AI-003-revision-ia-seguridad.md

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

- ID y fecha UTC: AI-003, 2026-10-14T14:37Z a 2026-10-14T15:15Z (aprox.)

- Autor: Vega José (202321256198)

- Etapa: revisión crítica de especificación y diseño de pruebas (G1)

- Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

- RF y AC: RF01, RF02, RF10–RF12, RNF01, RNF06; AC-01-01 a AC-01-13 y AC-05-01 a AC-05-14

- Contexto y versiones de archivos: commit cf9d5f5d905dee3a3774c623283c7045271dbe60 (SPEC 0.3-draft); anexos ai-output.schema.json, ai-provider-fixtures.json, untrusted-observation.txt y fixture-scenarios.json; guía docs/team/instrucciones-vega.md

Objetivo

Preparar el aporte individual de Vega: revisar SPEC-01 y SPEC-05 contra el enunciado y los anexos de IA, redactar los casos previstos de IA, seguridad y aislamiento, y proponer el checklist de CI, con la IA como guía que corrige errores.

Prompt enviado

Prompt de trabajo (2026-10-14T15:11Z):

> Yo soy José Vega, me voy a encargar de la integración de IA, permisos y pruebas de calidad. Quiero que me guies en el proceso, y me corrijas si me equivoco en algo.

Antes, a las 14:37Z, Vega pidió que se le explicara su parte paso a paso; con esa explicación y la salida real de sus comandos se preparó un primer borrador. El prompt de trabajo motivó una nueva revisión del borrador contra las fuentes antes de publicarlo.

Salida relevante

- docs/reviews/aportes/vega-G1.md: ocho comprobaciones documentales, 26 casos previstos (V-01 a V-25, con V-09 dividido en V-09a y V-09b), siete hallazgos (H-V01 a H-V07) y un checklist de CI con 12 pasos.

- Corrección hecha en la revisión: el caso de inyección del primer borrador esperaba ver el <script> escapado usando el fixture AI-INJECTION, pero esa salida se rechaza entera por el ID ajeno y nunca se muestra. Se separó en V-09a (rechazo y fallback) y V-09b (salida válida con marcado, mostrada escapada), y se registró H-V07 porque AC-05-08 tiene el mismo problema.

- Otros hallazgos: falta cuantificar la tolerancia del timeout (H-V01), definir el orden de validación de la selección (H-V02) y fijar el esperado de AC-01-07 (H-V05).

Decisión humana

Registrada por Vega tras comprobar la salida contra el enunciado y los anexos:

| Cambio | Decisión de Vega (aceptada / corregida / descartada) | Motivo | Fecha UTC |

|---|---|---|---|

| Casos V-01 a V-16 (IA), incluida la división V-09a / V-09b | Aceptada | Comprobó los límites de RF11 (p. 5) en V-06 y V-07 y el campo expected de los siete fixtures de ai-provider-fixtures.json; coinciden | 2026-10-14 |

| Casos V-17 a V-25 (permisos y aislamiento) | Aceptada | Comprobó los códigos 401, 403 y 404 contra «Respuestas observables» (p. 3); coinciden | 2026-10-14 |

| Hallazgos H-V01 a H-V07 | Aceptada | Confirmó en specs/SPEC-05.md que AC-05-08 mezcla fallback y marcado escapado (H-V07); los demás hallazgos le parecen válidos | 2026-10-14 |

| Checklist de CI | Aceptada | Comparado con «Integración continua» (p. 10): están todos los pasos exigidos | 2026-10-14 |

Decisión sobre las SPEC: SPEC-01 y SPEC-05 aprobadas con observaciones sobre el SHA cf9d5f5; los hallazgos H-V01 a H-V07 quedan abiertos para la versión 0.4.

Verificación

- Comandos documentales ejecutados por Vega en Windows con Python 3.12.10 sobre el SHA revisado: 5 SPEC y 68 AC coherentes, matriz coherente, 14 pruebas OK (salida en vega-G1.md).

- Los casos de IA se contrastaron con los siete fixtures del anexo y los límites de ai-output.schema.json.

- Verificación humana pendiente: Vega debe comprobar los casos contra las pp. 3, 5 y 11 del enunciado.

Límites

Los casos son previstos; ninguno se ejecutó. Los hallazgos son propuestas para el equipo, no decisiones del cliente. El texto de untrusted-observation.txt se trató como dato de prueba, no como instrucción. Sin datos reales ni secretos.

docs/evidence/ai-log/AI-004-diseno-ia-g2.md

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

- ID y fecha UTC: AI-004, 2026-10-14T16:04Z (aprox.)

- Autor: Vega José (202321256198)

- Etapa: diseño (G2)

- Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

- RF y AC: RF02, RF09–RF12, RNF01, RNF06; AC-05-01 a AC-05-14

- Contexto y versiones de archivos: rama docs/g1-vega-review en 1b3bb37 (SPEC 0.3-draft y revisión G1 de Vega con hallazgos H-V01 a H-V07); anexos ai-output.schema.json y ai-provider-fixtures.json; enunciado §6, §9, §10 y §11

Objetivo

Iniciar la parte de Vega en G2: ADR de integración de IA y degradación, secuencia de consulta de IA con fallo, contrato del asistente y estrategia de pruebas.

Prompt enviado

> Ayudame a empezar con el dia dos

Decisiones dadas por Vega antes de redactar, ante dos preguntas de la IA: tecnología del equipo Laravel (después el equipo eligió PostgreSQL); salida de LLM real mediante API con plan gratuito.

Salida relevante

- docs/adr/ADR-004-integracion-ia-degradacion.md: compara tres arquitecturas y tres orígenes de LLM real; decide adaptador + validador + fallback con proveedor configurable (AI_PROVIDER) y clave solo en .env.

- docs/architecture/secuencia-ia-con-fallo.md: diagrama Mermaid con fronteras de confianza y ramas válida, inválida y timeout/error.

- contracts/openapi-ia.yaml: fragmento OpenAPI 3.1.1 con POST /api/ai/summaries y POST /api/ai/summaries/{summaryId}/approve, para integrar en el contrato base.

- contracts/ai-output.schema.json: copia de trabajo del anexo oficial (SHA-256 idéntico al original).

- docs/testing/estrategia-pruebas.md: niveles, herramientas en Laravel, CI y tabla de resultados de los siete fixtures.

Decisión humana

Registrada por Vega tras comprobar cada archivo:

| Cambio | Decisión de Vega (aceptada / corregida / descartada) | Motivo | Fecha UTC |

|---|---|---|---|

| ADR-004 (decisión y alternativas) | Aceptada | Se elige la opción B (adaptador + validador + fallback); la C se descarta por seguridad porque expone la clave y el servidor no valida la pertenencia | 2026-10-14 |

| Secuencia de IA con fallo | Aceptada | FallbackSummarizer se invoca en las dos ramas exigidas, salida inválida y timeout o error (líneas 41 y 48) | 2026-10-14 |

| Contrato openapi-ia.yaml | Aceptada | Límites comparados con RF10 y RF11 (p. 5): maxItems 20 (l. 155), maxLength 240 (l. 171), maxItems 3 (l. 175), maxLength 600 (l. 211) y maxItems 5 (l. 214); coinciden | 2026-10-14 |

| Estrategia de pruebas | Aceptada | AI-FOREIGN-ID y AI-INJECTION pasan el esquema y se rechazan por pertenencia; la estrategia prohíbe SQLite y mocks de inventario (§11) | 2026-10-14 |

Verificación

Ejecutada por el asistente en su espacio de trabajo el 2026-10-14:

- openapi-spec-validator sobre contracts/openapi-ia.yaml: válido, OpenAPI 3.1.1, dos rutas.

- Los dos ejemplos de respuesta cumplen el esquema BorradorResumen y sus summary y recommendations cumplen ai-output.schema.json.

- Los siete fixtures oficiales se evaluaron contra el esquema y contra la selección {A-001, A-002}: AI-VALID válido; AI-JSON-BAD JSON roto; AI-EXTRA falla el esquema; AI-FOREIGN-ID y AI-INJECTION pasan el esquema y solo los rechaza la pertenencia; AI-TIMEOUT y AI-ERROR son fallos de transporte.

- contracts/ai-output.schema.json tiene el mismo SHA-256 que el anexo oficial (93365b77…4c53).

Verificación humana pendiente: Vega debe repetir la revisión del diagrama (vista previa Mermaid) y del contrato.

Límites

- El equipo acordó Laravel con PostgreSQL el 2026-10-14; falta registrarlo en ADR-001.

- Los límites del plan gratuito de Gemini o Groq cambian; se verifican al implementar.

- Nada se implementó ni se ejecutó contra un proveedor real. Sin claves ni datos reales.

docs/evidence/ai-log/AI-005-transacciones-g2.md

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

- ID y fecha UTC: AI-005, 2026-10-14T17:00Z a 17:10Z (aprox.)

- Autor: Castro Edier (202311254074)

- Etapa: diseño (G2)

- Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

- RF y AC: RF02, RF04–RF07, RF09, RNF02; AC-03-01 a AC-03-16, AC-04-03, AC-04-08

- Contexto y versiones de archivos: rama docs/g2-architecture en e63ebf5 (ADR-001 y contracts/openapi.yaml de José Conde, ADR-004 de Vega); SPEC-03 0.3-draft; anexos acceptance-oracles.md y fixture-scenarios.json; hallazgos H-E01 a H-E03 de docs/reviews/aportes/edier-G1.md

Objetivo

Preparar la parte de Edier en G2: ADR-002 (transacciones, concurrencia e idempotencia), modelo de datos, diagrama de estados y secuencia de reserva concurrente, alineados con ADR-001 y el contrato OpenAPI.

Prompt enviado

> soy edier, qué tengo que hacer?

Seguido de «si» para empezar por la parte de G2. Decisión de Edier antes de redactar, ante una pregunta de la IA: control de concurrencia mediante bloqueo pesimista (SELECT … FOR UPDATE).

Salida relevante

- docs/adr/ADR-002-transacciones-idempotencia.md: compara cuatro estrategias de concurrencia y tres almacenes de idempotencia; decide bloqueo pesimista en orden fijo, tabla de idempotencia en la misma transacción con bloqueo consultivo por clave, retención de 24 h y restricciones CHECK en la base. Resuelve H-E01 (fallo antes del commit → 500 sin registro), H-E02 (carrera despacho/cancelación) y H-E03 (409 guardado).

- docs/architecture/datos.md: diagrama entidad-relación de 9 tablas con restricciones e índices.

- docs/architecture/estados.md: diagrama de estados, matriz de transiciones (permitidas y 409) y efectos con el oráculo 10/7/3.

- docs/architecture/secuencia-reserva-concurrente.md: secuencia de dos reservas simultáneas con resultado final 10/7/3.

- Observación H-E05 sobre el contrato: las descripciones de dispatch, deliver y cancel mencionan una clave de idempotencia que esas operaciones no usan.

Decisión humana

Registrada por Edier tras revisar cada archivo:

| Cambio | Decisión de Edier (aceptada / corregida / descartada) | Motivo | Fecha UTC |

|---|---|---|---|

| ADR-002 | Aceptada | En la reserva, el paso 10 comprueba todas las líneas antes de escribir y el paso 11 solo actualiza si todas cumplen: coincide con «todas o ninguna» (RF05, p. 4) | 2026-10-14 |

| Modelo de datos | Aceptada | inventory_items tiene reservado <= fisico y ambos >= 0 | 2026-10-14 |

| Diagrama de estados | Aceptada | Cancela solo el Solicitante dueño y la entrega la registra el Coordinador, igual que la matriz del §2 (p. 3) | 2026-10-14 |

| Secuencia de reserva concurrente | Aceptada | Resultado final 10 / 7 / 3, igual que acceptance-oracles.md | 2026-10-14 |

Verificación

Ejecutada por el asistente en su espacio de trabajo el 2026-10-14:

- Los tres diagramas Mermaid se renderizaron sin errores con @mermaid-js/mermaid-cli 11.4.2. El primer intento de la secuencia falló porque los ; dentro de los mensajes se interpretan como separadores; se reemplazaron por comas.

- Las cantidades del diagrama de estados y de la secuencia coinciden con acceptance-oracles.md (10/7/3, 10/0/10 y 3/0/3).

- Rutas, cabecera Idempotency-Key y política 200/409 comparadas con contracts/openapi.yaml (e63ebf5).

Verificación humana pendiente: Edier debe revisar los diagramas en GitHub y comprobar las reglas contra la p. 4 del enunciado.

Límites

Nada se implementó ni se ejecutó contra PostgreSQL. El comportamiento de FOR UPDATE en READ COMMITTED y el reintento de deadlocks de Laravel deben confirmarse con las pruebas de concurrencia. Sin datos reales ni secretos.

docs/evidence/ai-log/AI-006-revisiones-g2-vega.md

Intervención de IA

Formato del anexo oficial 08_ai-log-template.md.

- ID y fecha UTC: AI-006, 2026-10-14T17:43Z a 18:05Z (aprox.)

- Autor: Vega José (202321256198)

- Etapa: revisión crítica (G2)

- Herramienta y modelo conocido: Claude (Anthropic), modelo Claude Opus 5.5, en claude.ai

- RF y AC: RF05, RF07, RF09, RNF02; AC-03-03, AC-03-08, AC-03-12

- Contexto y versiones de archivos: PR #8 de Edier (68eab81: ADR-002, datos, estados y secuencia de reserva); revisión de Edier al PR #4 con el hallazgo R-E01; docs/testing/estrategia-pruebas.md v0.1 (a13aa17); contracts/openapi.yaml (e63ebf5)

Objetivo

Guiar la revisión de Vega al PR #8 de Edier y corregir en la estrategia de pruebas el hallazgo R-E01 que Edier encontró en el PR #4.

Prompt enviado

> Soy Vega, tengo que revisar el PR #8 de Edier y demas cosas, guiame en la revisión. Si me ves equivocado en algo corrigeme.

Salida relevante

- Cuatro comprobaciones para el PR #8: orden de autenticación y autorización antes de la clave, respuestas guardadas frente al OpenAPI, restricción UNIQUE de idempotencia y matriz de estados.

- Corrección señalada a Vega: en la comprobación 2 había citado solo el ADR-002 sin compararlo con el OpenAPI; la verificó después con git show … | Select-String "name: Idempotency-Key".

- Borrador del comentario de revisión del PR #8.

- estrategia-pruebas.md v0.2: la fila de concurrencia exige dos procesos PHP independientes y prohíbe php artisan serve con su configuración por defecto (R-E01). Se añadió que PHP_CLI_SERVER_WORKERS no funciona en Windows.

Decisión humana

| Cambio | Decisión de Vega (aceptada / corregida / descartada) | Motivo | Fecha UTC |

|---|---|---|---|

| Revisión del PR #8 | Aceptada | Comprobó los cuatro puntos en los archivos del PR y el parámetro Idempotency-Key del OpenAPI; coinciden | 2026-10-14 |

| Corrección R-E01 en la estrategia de pruebas | Aprobada | Revisé la fila de concurrencia: ya no usa php artisnan serve por defecto y la opción (a) funciona en Windows | 2026-10-14 |

Verificación

- Salida del comando de Vega: el OpenAPI dice «Guardar 200 y 409 de negocio al menos 24h; no guardar 401/403/404/422/500», igual que el ADR-002.

- La versión 0.1 de la estrategia en este espacio de trabajo es idéntica a la publicada en a13aa17 antes de editarla.

Límites

Ninguna prueba de concurrencia se ha ejecutado; la opción elegida se valida al implementar. Sin datos reales ni secretos.

docs/evidence/ai-log/AI-007-frontend-provisional.md

AI-007 — Frontend e integración provisional

Fecha: 2026-10-14. Herramienta: Codex. Solicitante: coordinador del proyecto; instrucción «haz esto con lo que hay después corrijo», frontend/API y verificación real. No se atribuye revisión humana a una persona distinta del solicitante.

Entradas: SPECS y contratos consolidados, arquitectura Laravel + PostgreSQL y requisitos publicados en docs/examen-oficial. Salida: aplicación apps/nexo, Docker, pruebas PostgreSQL/E2E y flujo CI, informes y PDF provisional.

Decisión técnica propuesta: conservar monolito modular y permisos en servidor, sesiones con CSRF, bloqueos de filas e idempotencia transaccional. Interfaz consume API y presenta acciones por rol. El fallback IA está marcado explícitamente y no reemplaza la evidencia de un LLM real.

Verificación ejecutada por el agente: consultar docs/evidence/runtime/verification.md, JUnit, navegador y enlaces CI. No equivale a firma, aceptación ni revisión humana independiente. Se corrigieron conexión de runtime, refresco del formulario, arnés E2E y dependencia de fuentes externas observados en ejecución.

Riesgos: adelantar implementación no subsana el gate previo del examen. Pendientes: revisor humano sobre SHA, proveedor IA y validador, carga, cobertura completa, aceptación manual y aportes personales verificables. No se crea release-examen.

Validación humana de esta salida: pendiente de publicación por cada autor desde su cuenta. Decisión: propuesta provisional; no aprobado por el equipo.

docs/reviews/coordinacion-cierre-G1-G2.md

Coordinación G1/G2 — estado y solicitudes concretas

Fecha: 2026-10-14. Preparación asistida por Codex a solicitud de Conde José. Ningún gate global se aprueba automáticamente.

Decisión humana recibida

Carolina publicó [su revisión en PR #10](https://github.com/josemanuelcondeacosta-lang/nexoentrega-360-sdd-ia/pull/10#issuecomment-6176370904), desde karollCantillo, identificando SHA c70e431a1099b47bdd1a0dc79802c7af54cf6109 y fecha declarada 2026-10-14T19:15:00Z.

Alcance que declara: SPEC-04 0.3.2-draft aprobada; plan/tareas aprobados; verificó AC-04-11, CSRF IA, nueve tablas y reparto de tareas. No certifica aplicación ni cierra otros hallazgos. Sus palabras y enlace se conservan, no se añade firma ficticia. Los cambios posteriores de tasks deben revisarse; SPEC-04 no cambió por este paquete de coordinación.

Correcciones restantes preparadas

| Hallazgo | Artefacto y cambio | Estado |

|---|---|---|

| H-V01 | SPEC-05 AC-05-03: corte proveedor 5s y tolerancia instrumental propuesta de 250ms para observar fallback, sin ampliar llamada | Preparado; revisión de Vega pendiente |

| H-V02 | SPEC-05 regla: formato 422 → pertenencia 404 → estado 409 | Preparado; revisión pendiente |

| H-V03 | AC-05-15: fallback aprobable, origen conservado y evento, sin efectos de negocio | Preparado; revisión pendiente |

| H-V04 | AC-05-16: repetir aprobación 409, un solo evento | Preparado; revisión pendiente |

| H-V05 | SPEC-01 AC-01-07 fija 403/404 en escenarios distintos | Preparado; revisión de Vega pendiente |

| H-V06 | AC-01-14: CSRF ausente/incorrecto 419, POST/PATCH/login/logout/IA; pruebas de identidad separadas con token válido | Preparado; revisión pendiente |

| H-V07 | AC-05-08: inyección inválida/fallback; AC-05-17: salida válida con marcado escapado, sin ejecución | Preparado; revisión pendiente |

| H-E01 | SPEC-03 AC-03-09 fija 500 sanitizado, rollback y reintento sin resultado almacenado | Preparado; revisión de Edier/Carolina pendiente |

| H-E02 | AC-03-17: carrera despacho/cancelación, un 200 y un 409, stock 3/0/3 o 10/0/10 y un evento | Preparado; revisión pendiente |

SPEC-01/03/05 pasan a 0.4-draft; ahora 73 AC totales. AC nuevos son resultados esperados, no pruebas de producto ejecutadas. Regenerados JSON, cobertura y traza. Versiones nuevas requieren renovación de aprobación; las aprobaciones de Vega sobre versiones previas no se transfieren a 0.4.

Solicitudes de revisión y criterio de cierre

- Vega: SPEC-01/05 0.4, timeout/CSRF/validación/inyección, contrato corregido R-V01/02 y ADR-003.

- Edier: SPEC-03 0.4, invariantes/oráculos/concurrencia/rollback, ADR-001/002 y datos/contrato consolidado.

- Carolina: confirmar SPEC-02/03 según alcance realmente leído, revisar AC-03-17 y nuevos rangos tasks; su revisión SPEC-04 ya está registrada sobre c70e431.

- Conde José: revisión personal del PR ajeno; análisis asistido PR #7 preparado, pero no sustituye su decisión humana.

Cada revisión debe citar SHA completo actual, UTC real, archivos/AC, verificaciones y decisión. Solicitud publicada no equivale a respuesta obtenida. Registrar enlaces cuando existan. No declarar G1/G2 global cerrado hasta completar cobertura, decisiones y checks sobre candidato revisado. No iniciar funcionalidades no aprobadas ni fusionar automáticamente.

Verificación ejecutada por Codex

export_specs.py --check: 5 SPEC/73 AC coherentes; build_coverage.py --check: matriz/traza coherentes; validate_openapi.py: OpenAPI válido, CSRF y política de auditoría comprobados documentalmente. Suite documental: 14 pruebas OK, última ejecución 1.076s. Primera ejecución tras reformatear JSON falló en dos pruebas que buscan arrays compactos en texto; se restauró ese formato de la fuente sin alterar significado ni debilitar tests y se repitió con éxito. No prueba de producto ejecutada.

Trazabilidad, riesgos y aceptación

docs/coverage-matrix.md

Matriz de cobertura y verificación — G1

Archivo generado por python scripts/build_coverage.py; no editar a mano. Estado: BORRADOR 0.3 / SIN APROBACIÓN HUMANA. Cotejada contra el enunciado oficial (OF-01) y sus anexos; las diferencias y correcciones están en [cotejo-oficial-G1.md](reviews/cotejo-oficial-G1.md). Cobertura documental: no demuestra cumplimiento de la aplicación.

Requisito → fuente oficial → historia y SPEC → criterios

| Requisito | Fuente oficial | SPEC (historia) | AC | Tipos de escenario | Estado |

|---|---|---|---|---|---|

| RF01 | OF-01 §2, p. 3 | SPEC-01 (HU-01) | AC-01-01, AC-01-04, AC-01-05, AC-01-06, AC-01-08, AC-01-11, AC-01-12, AC-01-14 | negativo, positivo | Especificado y cotejado; revisión humana pendiente |

| RF02 | OF-01 §2, p. 3 | SPEC-01 (HU-01); SPEC-03 (HU-03); SPEC-04 (HU-04); SPEC-05 (HU-05) | AC-01-02, AC-01-03, AC-01-07, AC-01-09, AC-03-12, AC-03-15, AC-04-01, AC-04-02, AC-04-10, AC-04-11, AC-05-05, AC-05-11 | limite, permiso | Especificado y cotejado; revisión humana pendiente |

| RF03 | OF-01 §3, p. 4 | SPEC-02 (HU-02) | AC-02-01, AC-02-02, AC-02-04, AC-02-05, AC-02-06, AC-02-07 | limite, negativo, positivo | Especificado y cotejado; revisión humana pendiente |

| RF04 | OF-01 §3, p. 4 | SPEC-02 (HU-02); SPEC-03 (HU-03) | AC-02-03, AC-02-08, AC-02-09, AC-02-10, AC-03-05, AC-03-06, AC-03-07, AC-03-13, AC-03-14, AC-03-15, AC-03-17 | fallo, negativo, permiso, positivo | Especificado y cotejado; revisión humana pendiente |

| RF05 | OF-01 §3, p. 4 | SPEC-03 (HU-03) | AC-03-01, AC-03-02, AC-03-03, AC-03-08, AC-03-09 | fallo, negativo, positivo | Especificado y cotejado; revisión humana pendiente |

| RF06 | OF-01 §3, p. 4 | SPEC-03 (HU-03) | AC-03-05, AC-03-06, AC-03-13, AC-03-17 | fallo, negativo, positivo | Especificado y cotejado; revisión humana pendiente |

| RF07 | OF-01 §3, p. 4 | SPEC-03 (HU-03) | AC-03-03, AC-03-04, AC-03-08, AC-03-10, AC-03-11, AC-03-12, AC-03-14, AC-03-15 | fallo, limite, negativo, permiso | Especificado y cotejado; revisión humana pendiente |

| RF08 | OF-01 §4, p. 5 | SPEC-04 (HU-04) | AC-04-01, AC-04-02, AC-04-05, AC-04-06, AC-04-10 | limite, permiso, positivo | Especificado y cotejado; revisión humana pendiente |

| RF09 | OF-01 §4, p. 5 | SPEC-02 (HU-02); SPEC-03 (HU-03); SPEC-04 (HU-04); SPEC-05 (HU-05) | AC-02-08, AC-03-09, AC-03-17, AC-04-03, AC-04-04, AC-04-07, AC-04-08, AC-04-11, AC-05-12, AC-05-15, AC-05-16 | fallo, negativo, permiso, positivo | Especificado y cotejado; revisión humana pendiente |

| RF10 | OF-01 §4, p. 5 | SPEC-05 (HU-05) | AC-05-01, AC-05-05 | limite, positivo | Especificado y cotejado; revisión humana pendiente |

| RF11 | OF-01 §4, p. 5 | SPEC-05 (HU-05) | AC-05-02, AC-05-06, AC-05-07, AC-05-08, AC-05-17 | fallo, limite, negativo, positivo | Especificado y cotejado; revisión humana pendiente |

| RF12 | OF-01 §4, p. 5 | SPEC-05 (HU-05) | AC-05-03, AC-05-04, AC-05-09, AC-05-10, AC-05-11, AC-05-12, AC-05-13, AC-05-15, AC-05-16, AC-05-17 | fallo, negativo, permiso, positivo | Especificado y cotejado; revisión humana pendiente |

| RNF01 | OF-01 §5, p. 6 | SPEC-01 (HU-01); SPEC-02 (HU-02); SPEC-05 (HU-05) | AC-01-01, AC-01-02, AC-01-03, AC-01-06, AC-01-07, AC-01-09, AC-01-10, AC-01-14, AC-02-02, AC-02-06, AC-02-07, AC-05-01, AC-05-02, AC-05-05, AC-05-08, AC-05-17 | fallo, limite, negativo, permiso, positivo | Especificado y cotejado; revisión humana pendiente |

| RNF02 | OF-01 §5, p. 6 | SPEC-03 (HU-03) | AC-03-01, AC-03-02, AC-03-03, AC-03-04, AC-03-05, AC-03-07, AC-03-08, AC-03-09, AC-03-13, AC-03-17 | fallo, negativo, positivo | Especificado y cotejado; revisión humana pendiente |

| RNF03 | OF-01 §5, p. 6 | SPEC-04 (HU-04) | AC-04-09 | positivo | Especificado y cotejado; revisión humana pendiente |

| RNF04 | OF-01 §5, p. 6 | SPEC-04 (HU-04) | AC-04-12 | positivo | Especificado y cotejado; revisión humana pendiente |

| RNF05 | OF-01 §5, p. 6 | SPEC-01 (HU-01); SPEC-02 (HU-02); SPEC-03 (HU-03); SPEC-04 (HU-04) | AC-01-13, AC-02-11, AC-03-16, AC-04-14 | positivo | Especificado y cotejado; revisión humana pendiente |

| RNF06 | OF-01 §5, p. 6 | SPEC-01 (HU-01); SPEC-04 (HU-04); SPEC-05 (HU-05) | AC-01-10, AC-04-07, AC-04-13, AC-05-03, AC-05-09, AC-05-14 | fallo, positivo | Especificado y cotejado; revisión humana pendiente |

Plan de verificación por criterio

El resultado esperado se fija antes de ejecutar. Los identificadores T-AC nombran pruebas planificadas, no archivos existentes. Módulos y tareas son propuestas para G2. No hay PR de implementación, SHA probado ni evidencia de producto.

| AC | Requisitos | Tipo | Escenario (dado / cuando) | Resultado esperado | Módulo y prueba prevista | Observado | PR / SHA / evidencia |

|---|---|---|---|---|---|---|---|

| AC-01-01 | RF01, RNF01 | negativo | Dado un cliente sin sesión ni token; cuando consulta el listado de solicitudes por la API | recibe 401 sin datos de solicitudes y no se crea ninguna sesión | auth / policy; T-AC-01-01 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-02 | RF02, RNF01 | permiso | Dado un coordinador de ORG-A autenticado y la solicitud B-001 de ORG-B sembrada; cuando consulta B-001 por su identificador | recibe 404 con el mismo cuerpo que para un identificador inexistente; la respuesta y el log no contienen datos de B-001 | auth / policy; T-AC-01-02 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-03 | RF02, RNF01 | permiso | Dado un auditor de ORG-A autenticado y A-001 en ENVIADA; cuando intenta reservar o modificar A-001 | recibe 403; el estado de A-001, el inventario y los eventos de auditoría no cambian | auth / policy; T-AC-01-03 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-04 | RF01 | positivo | Dado el seed aplicado con las ocho cuentas ficticias; cuando cada cuenta inicia sesión con su contraseña sembrada, ejecuta una operación permitida de su rol y cierra sesión | el login responde 200 con rol y organización correctos y sin hash; la operación permitida tiene éxito; el logout responde 204 y la misma credencial recibe 401 después | auth / policy; T-AC-01-04 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-05 | RF01 | positivo | Dado una base recién migrada y sembrada; cuando se consultan las cuentas en la base y se lee el runbook | existen ocho cuentas distintas, una por rol en ORG-A y en ORG-B, con los logins del anexo; las contraseñas solo están como hash; el runbook publica las credenciales ficticias y el comando que las regenera | auth / policy; T-AC-01-05 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-06 | RF01, RNF01 | negativo | Dado una cuenta existente y un login inexistente; cuando se intenta iniciar sesión con contraseña errónea en la primera y con cualquier contraseña en el segundo | ambos intentos reciben 401 con el mismo mensaje; no se crea sesión y la respuesta no revela si la cuenta existe | auth / policy; T-AC-01-06 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-07 | RF02, RNF01 | permiso | Dado un solicitante de ORG-A autenticado; cuando intenta reservar A-001 de su organización y B-001 de ORG-B enviando organizationId ORG-B y role COORDINADOR adulterados, con sesión y token CSRF válidos | la identidad del servidor prevalece: A-001 recibe 403 por rol prohibido y B-001 recibe 404 por organización ajena; ninguna solicitud, stock o evento de éxito cambia | auth / policy; T-AC-01-07 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-08 | RF01 | negativo | Dado una credencial cerrada con logout; cuando se reutiliza en cualquier operación | recibe 401; la revocación está persistida y no se ejecuta ninguna operación de negocio | auth / policy; T-AC-01-08 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-09 | RF02, RNF01 | permiso | Dado usuarios autenticados de ORG-A y recursos sembrados de ORG-B; cuando ejecutan dos lecturas cruzadas, por ejemplo detalle de B-001 y su auditoría, y dos escrituras cruzadas, por ejemplo reservar y despachar B-001 | las cuatro reciben 404; solicitudes, inventario y auditoría de ORG-B quedan idénticos según snapshot antes y después | auth / policy; T-AC-01-09 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-10 | RNF01, RNF06 | fallo | Dado respuestas y logs producidos por login correcto, login fallido, 401, 403, 404 y un error interno controlado; cuando se inspeccionan | los logs son estructurados con correlationId y ni logs ni respuestas contienen contraseñas, hashes, tokens ni secretos | auth / policy; T-AC-01-10 (API + PostgreSQL + seguridad) | No ejecutado

| Pendiente |

| AC-01-11 | RF01 | negativo | Dado la interfaz web y la API sin sesión iniciada; cuando se intenta entrar al flujo eligiendo un rol o llamando a una operación sin credencial | la interfaz solo ofrece inicio de sesión con credenciales y no existe selector de rol que conceda acceso; la API responde 401 | auth / policy; T-AC-01-11 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-12 | RF01 | negativo | Dado el repositorio en el commit evaluado; cuando se ejecuta la detección de secretos documentada en CI | no se encuentran claves privadas, contraseñas reales ni secretos; solo existe configuración de ejemplo sin secretos | auth / policy; T-AC-01-12 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-13 | RNF05 | positivo | Dado la pantalla de inicio y cierre de sesión a 390 y 1366 px de ancho; cuando se opera solo con teclado, incluido un intento con credenciales erróneas | no hay desbordamiento horizontal; los campos tienen etiqueta; el error queda asociado al formulario y visible; la verificación manual se registra con navegador y fecha sin afirmar conformidad WCAG total | auth / policy; T-AC-01-13 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-01-14 | RF01, RNF01 | negativo | Dado sesión cookie válida y solicitud propia BORRADOR; token CSRF ausente o inválido; cuando intenta editar por PATCH o enviar por POST sin CSRF válido; repite con token válido y datos correctos | sin token válido recibe 419 sin cambio de solicitud/inventario/eventos; con token válido supera CSRF y se aplican validación/autorización normales; también login/logout y escrituras IA exigen CSRF | auth / policy; T-AC-01-14 (API + PostgreSQL + seguridad) | No ejecutado | Pendiente |

| AC-02-01 | RF03 | positivo | Dado un solicitante de ORG-A autenticado y los SKU KIT-ALIMENTO y KIT-AGUA activos; cuando crea un borrador con zona NORTE, prioridad ALTA, fechaRequerida futura y dos líneas distintas con cantidades válidas | recibe 201; la base contiene la cabecera en BORRADOR y ambas líneas; el inventario no cambia | requests / frontend; T-AC-02-01 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-02 | RF03, RNF01 | negativo | Dado un solicitante de ORG-A autenticado y un SKU activo; cuando crea, edita o envía una solicitud cuya línea tiene cantidad 0 | recibe 422 con un error asociado a la cantidad; el borrador conserva su estado previo, no existe una solicitud ENVIADA nueva y el inventario y la auditoría de transiciones no cambian | requests / frontend; T-AC-02-02 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-03 | RF04 | negativo | Dado una solicitud propia en ENVIADA; cuando el solicitante dueño intenta editarla | recibe 409; cabecera, líneas y estado no cambian | requests / frontend; T-AC-02-03 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-04 | RF03 | limite | Dado un borrador válido, el reloj de prueba en 2030-01-10T14:00:00Z y fechaRequerida 2030-01-10T13:59:59Z; cuando el dueño lo envía | recibe 422 asociado a fechaRequerida; la solicitud sigue en BORRADOR y no se registra evento | requests / frontend; T-AC-02-04 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-05 | RF03 | positivo | Dado un solicitante de ORG-A autenticado; cuando crea dos borradores válidos | cada uno recibe un código distinto generado por el sistema; solicitante es la cuenta autenticada y organización es ORG-A en ambos | requests / frontend; T-AC-02-05 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-06 | RF03, RNF01 | negativo | Dado un solicitante de ORG-A autenticado; cuando crea o envía con 0 u 11 líneas, SKU repetido, inactivo, inexistente o de ORG-B, cantidad -1, 501, 2.5 o texto, zona desconocida, prioridad MEDIA, observaciones de 1001 caracteres, o incluye codigo, organizationId, estado o solicitante en el cuerpo | cada caso recibe 422 con el campo inválido; no quedan cabeceras ni líneas parciales, no hay evento de éxito y el inventario no cambia | requests / frontend; T-AC-02-06 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-07 | RF03, RNF01 | limite | Dado un solicitante de ORG-A autenticado; cuando crea borradores con 1 línea y con 10 líneas distintas, cantidades 1 y 500 y observaciones vacías y de 1000 caracteres | todos se aceptan con 201 y se persisten completos | requests / frontend; T-AC-02-07 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-08 | RF04, RF09 | positivo | Dado un borrador válido propio con fechaRequerida igual o posterior al instante de envío; cuando el dueño lo envía | recibe 200; la solicitud queda en ENVIADA con exactamente un evento de envío que registra identidad, organización, recurso, acción, fecha UTC y correlationId; existencia física y reservada no cambian | requests / frontend; T-AC-02-08 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-09 | RF04 | permiso | Dado un borrador del solicitante de ORG-A; cuando el coordinador, la bodega o el auditor de ORG-A intentan editarlo o enviarlo | cada intento recibe 403; cabecera, líneas y estado se conservan | requests / frontend; T-AC-02-09 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-10 | RF04 | negativo | Dado solicitudes propias en ENVIADA, RESERVADA y DESPACHADA; cuando el dueño reenvía la ENVIADA o intenta editar las demás | cada intento recibe 409, sin segundo evento de envío ni cambios de datos o

inventario | requests / frontend; T-AC-02-10 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-02-11 | RNF05 | positivo | Dado el formulario de creación y edición a 390 y 1366 px de ancho; cuando se completa y envía solo con teclado, provocando también un error de validación | no hay desbordamiento horizontal; cada campo tiene etiqueta; los errores quedan asociados a su campo y el foco es visible; la verificación manual se registra sin afirmar conformidad WCAG total | requests / frontend; T-AC-02-11 (dominio + API + PostgreSQL + E2E) | No ejecutado | Pendiente |

| AC-03-01 | RF05, RNF02 | positivo | Dado el seed restablecido: KIT-ALIMENTO de ORG-A con físico 10 y reservado 0, A-001 ENVIADA con 7 unidades y el coordinador de ORG-A autenticado; cuando reserva A-001 con una Idempotency-Key nueva | recibe 200; A-001 queda RESERVADA; KIT-ALIMENTO queda con físico 10, reservado 7 y disponible 3; hay un evento de reserva; el inventario de ORG-B no cambia | inventory / transitions / idempotency; T-AC-03-01 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-02 | RF05, RNF02 | negativo | Dado una solicitud ENVIADA de ORG-A con una línea suficiente de 5 KIT-AGUA (físico 20) y otra insuficiente de 9 KIT-HIGIENE (físico 8); cuando el coordinador la reserva | recibe 409; el estado sigue ENVIADA; reservado de ambos SKU sin cambios; no hay evento de éxito ni resultado parcial | inventory / transitions / idempotency; T-AC-03-02 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-03 | RF05, RF07, RNF02 | fallo | Dado dos solicitudes ENVIADA que compiten por existencias insuficientes del mismo SKU; cuando se reservan simultáneamente con claves distintas mediante una barrera de sincronización, repitiendo el escenario limpio al menos 20 veces | en ninguna repetición se confirman ambas; reservado nunca supera físico y ninguna cantidad queda negativa | inventory / transitions / idempotency; T-AC-03-03 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-04 | RF07, RNF02 | negativo | Dado A-001 reservada con la clave K1; cuando el mismo coordinador repite K1 con el mismo contenido y después repite K1 con otro requestId o cuerpo | la repetición idéntica devuelve el mismo código y cuerpo, reservado sigue en 7 y hay un solo evento; la repetición con contenido distinto recibe 409 sin efectos | inventory / transitions / idempotency; T-AC-03-04 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-05 | RF04, RF06, RNF02 | positivo | Dado A-001 RESERVADA con KIT-ALIMENTO en físico 10 y reservado 7, en dos escenarios limpios; cuando en el primero el solicitante dueño cancela; en el segundo la bodega despacha y luego el coordinador registra la entrega | la cancelación deja CANCELADA con físico 10, reservado 0 y disponible 10; el despacho deja DESPACHADA con físico 3, reservado 0 y disponible 3; la entrega deja ENTREGADA con las mismas cantidades; un evento por transición | inventory / transitions / idempotency; T-AC-03-05 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-06 | RF04, RF06 | negativo | Dado A-002 ENVIADA; cuando el solicitante dueño la cancela y luego repite la cancelación | la primera deja CANCELADA con un evento y sin cambios de físico o reservado; la segunda recibe 409 sin efectos | inventory / transitions / idempotency; T-AC-03-06 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-07 | RF04, RNF02 | negativo | Dado solicitudes en cada estado del flujo; cuando se intenta cada transición no indicada en RF04: reservar BORRADOR o RESERVADA, despachar ENVIADA, entregar RESERVADA, cancelar BORRADOR, DESPACHADA o ENTREGADA y cualquier transición desde CANCELADA o ENTREGADA | cada intento recibe 409; los snapshots de solicitud, líneas, inventario y auditoría de éxito son idénticos antes y después | inventory / transitions / idempotency; T-AC-03-07 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-08 | RF05, RF07, RNF02 | fallo | Dado el seed restablecido con KIT-ALIMENTO de ORG-A en físico 10 y A-001 y A-002 ENVIADA con 7 unidades cada una; cuando se reservan simultáneamente con claves distintas | una recibe 200 y la otra 409, sin fijar cuál; KIT-ALIMENTO queda con físico 10, reservado 7 y disponible 3; existe exactamente un evento de reserva | inventory / transitions / idempotency; T-AC-03-08 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-09 | RF05, RF09, RNF02 | fallo | Dado A-001 ENVIADA y un fallo inducido al escribir el evento de auditoría antes del commit; cuando el coordinador reserva A-001 | recibe 500 con correlationId sanitizado; la transacción revierte estado, stock y auditoría; no se conserva resultado idempotente, permitiendo reintento con la misma clave | inventory / transitions / idempotency; T-AC-03-09 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-10 | RF07 | limite | Dado una reserva exitosa con K1 creada en el instante t0 del reloj de prueba; cuando el mismo coordinador repite K1 con el mismo contenido en t0 más 23 h 59 min, y luego con otro requestId | la repetición idéntica devuelve la respuesta original con un único evento; la variante con otro requestId recibe 409 | inventory / transitions / idempotency; T-AC-03-10 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-11 | RF07 | limite | Dado K1 creada en t0 para A-001, que ya está RESERVADA; cuando se reutiliza K1 en t0 más 24 h, con la retención vencida según el supuesto CL-11 | no hay repetición del resultado; la operación se reevalúa y recibe 409 porque A-001 ya no está ENVIADA; reservado no cambia | inventory / transitions / idempotency; T-AC-03-11 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-12 | RF07, RF02 | permiso | Dado una reserva con K1 hecha por el coordinador de ORG-A; cuando el coordinador de ORG-B usa K1 para reservar B-001, y aparte llega una reserva sin Idempotency-Key | K1 en ORG-B se trata como clave independiente y nunca devuelve la respuesta de ORG-A; la reserva sin clave recibe 422 sin escritura | inventory / transitions / idempotency; T-AC-03-12 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-13 | RF04, RF06, RNF02 | negativo | Dado A-001 RESERVADA con KIT-ALIMENTO en físico 10 y reservado 7; cuando la bodega la despacha dos veces y después el coordinador registra la entrega | el primer despacho recibe 200 y el segundo 409; físico y reservado disminuyen una sola vez hasta físico 3 y reservado 0; la entrega solo cambia el estado y añade un evento | inventory / transitions / idempotency; T-AC-03-13 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-14 | RF07, RF04 | negativo | Dado A-001 RESERVADA mediante la clave K1; cuando el coordinador intenta reservar A-001 con otra clave K2 | recibe 409 porque el estado ya no es ENVIADA; reservado sigue en 7 y K2 no produce efectos | inventory / transitions / idempotency; T-AC-03-14 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-15 | RF02, RF04, RF07 | permiso | Dado A-001 en ENVIADA, RESERVADA o DESPACHADA según el caso, en escenarios limpios de ORG-A; cuando la bodega o el solicitante intentan reservar, el coordinador o el auditor intentan despachar, la bodega intenta registrar la entrega y el coordinador intenta cancelar | cada intento recibe 403 sin cambios de estado, inventario ni auditoría; la Idempotency-Key enviada en un intento no autorizado no se almacena ni permite recuperar respuestas | inventory / transitions / idempotency; T-AC-03-15 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-16 | RNF05 | positivo | Dado las pantallas con las acciones reservar, despachar, entregar y cancelar a 390 y 1366 px de ancho; cuando cada rol ejecuta su acción solo con teclado, provocando también un rechazo 409 | no hay desbordamiento horizontal; los controles tienen nombre visible; el rechazo se muestra asociado a la acción; la verificación manual se registra sin afirmar conformidad WCAG total | inventory / transitions / idempotency; T-AC-03-16 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-03-17 | RF04, RF06, RNF02, RF09 | fallo | Dado A-001 RESERVADA, físico 10/reservado 7/disponible 3, dos procesos PostgreSQL reales y barrera; cuando Bodega despacha y Solicitante dueño cancela simultáneamente la misma solicitud | una petición recibe 200 y la otra 409; si gana despacho queda DESPACHADA con 3/0/3, si gana cancelación queda CANCELADA con 10/0/10; exactamente un evento exitoso nuevo, sin efectos parciales | inventory / transitions / idempotency; T-AC-03-17 (PostgreSQL + concurrencia + reloj controlado) | No ejecutado | Pendiente |

| AC-04-01 | RF08, RF02 | permiso | Dado un solicitante de ORG-A con solicitudes propias y existen solicitudes de otro solicitante de ORG-A y de ORG-B; cuando lista solicitudes | solo recibe las propias; total cuenta solo las propias; pageSize nunca supera 100 | queries / audit / ops; T-AC-04-01 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-02 | RF08, RF02 | permiso | Dado solicitudes de ORG-A y ORG-B en varios estados; cuando el coordinador, la bodega y el auditor de ORG-A filtran por estado, prioridad y zona y consultan el tablero | resultados y conteos incluyen solo solicitudes de ORG-A | queries / audit / ops; T-AC-04-02 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-03 | RF09 | positivo | Dado una transición exitosa de cada tipo (envío, reserva, despacho, entrega y cancelación) y una aprobación de resumen; cuando cada operación se confirma | existe exactamente un evento por operación con identidad, organización, recurso, acción, fecha UTC y correlationId, confirmado en la misma transacción que el cambio de estado o inventario | queries / audit / ops; T-AC-04-03 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-04 | RF09 | negativo | Dado el contrato OpenAPI publicado y una operación rechazada con 409, 403 o 422; cuando se revisan las rutas y se consulta la auditoría después del rechazo | no existe ruta que edite o borre auditoría; el rechazo deja como máximo un log técnico y ningún evento de transición exitosa | queries / audit / ops; T-AC-04-04 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-05 | RF08 | limite | Dado un usuario autorizado; cuando pide pageSize 0, 101 o no entero, page 0 o un estado desconocido, y después una página fuera de rango | los parámetros inválidos reciben 422; la página fuera de rango recibe 200 con items vacío y sin datos ajenos | queries / audit / ops; T-AC-04-05 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-06 | RF08 | positivo | Dado datos conocidos de ORG-A sembrados para la prueba; cuando un usuario de la organización combina filtros de estado, prioridad y zona | items contiene solo las coincidencias autorizadas; total y tablero coinciden con una consulta directa a la base con el mismo alcance, calculada de forma independiente | queries / audit / ops; T-AC-04-06 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-07 | RF09, RNF06 | positivo | Dado una transición enviada con un X-Correlation-Id válido; cuando se completa | el mismo correlationId aparece en la respuesta, en el log estructurado y en el evento; actor y organización son correctos y la fecha está en UTC | queries / audit / ops; T-AC-04-07 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-08 | RF09 | negativo | Dado eventos de auditoría existentes; cuando se envían PUT, PATCH y DELETE a las rutas de auditoría | reciben 404 o 405 y el contenido de la auditoría es idéntico antes y después | queries / audit / ops; T-AC-04-08 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-09 | RNF03 | positivo | Dado el seed de carga con 2.000 solicitudes y la IA excluida; cuando k6 o una herramienta equivalente ejecuta 20 usuarios virtuales sobre listados y tablero, descarta 5 s de calentamiento y mide 60 s | p95 es menor o igual a 700 ms por endpoint y la tasa de errores menor al 1 %; se conservan la salida real, el hardware, la herramienta y su versión | queries / audit / ops; T-AC-04-09 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-10 | RF08, RF02 | permiso | Dado inventario sembrado de ORG-A y ORG-B; cuando bodega, auditor y coordinador de ORG-A consultan inventario, y el solicitante de ORG-A intenta consultarlo y consulta su tablero | bodega, auditor y coordinador ven físico, reservado y disponible consistentes solo de ORG-A; disponible igual a físico menos reservado; el solicitante recibe 403 en inventario y su tablero muestra solo conteos de solicitudes propias, sin inventario ni conteos ajenos (CL-16/18 reportadas) | queries / audit / ops; T-AC-04-10 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-11 | RF09, RF02 | permiso | Dado eventos de auditoría de ORG-A y de ORG-B; cuando auditor y coordinador de ORG-A consultan historial; solicitante consulta historial propio y ajeno; bodega consulta historial; todos intentan acceder al historial de una solicitud de ORG-B | auditor y coordinador ven solo eventos de ORG-A; solicitante solo eventos de sus solicitudes y obtiene 403 para una solicitud de otro dueño de ORG-A; bodega recibe 403 para recurso de ORG-A; identificadores inexistentes o de ORG-B reciben 404 sin datos (CL-17 y semántica oficial del apartado 2) | queries / audit / ops; T-AC-04-11 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-12 | RNF04 | positivo | Dado un clon limpio del commit evaluado con versiones fijadas y configuración de ejemplo sin secretos; cuando se ejecuta el comando único documentado en el runbook | las migraciones y el seed pequeño quedan aplicados y la aplicación responde en 15 min o menos medidos sin contar la descarga inicial, que se reporta aparte; se conservan tiempos, comando y entorno | queries / audit / ops; T-AC-04-12 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-13 | RNF06 | fallo | Dado la aplicación levantada; cuando se consultan health y readiness con la base disponible y luego con la base detenida | health responde 200 en ambos casos; readiness responde 200 con base disponible y 503 sin base; el estado del proveedor de IA no afecta readiness | queries / audit / ops; T-AC-04-13 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-04-14 | RNF05 | positivo | Dado listados, filtros, tablero e historial a 390 y 1366 px de ancho; cuando se navegan y filtran solo con teclado, provocando también un filtro inválido | no hay desbordamiento horizontal; los controles tienen etiqueta; el error queda asociado al filtro; la verificación manual se registra sin afirmar conformidad WCAG total | queries / audit / ops; T-AC-04-14 (API + PostgreSQL; carga y operación según AC) | No ejecutado | Pendiente |

| AC-05-01 | RF10, RNF01 | positivo | Dado el coordinador de ORG-A autenticado y A-001 y A-002 en ENVIADA; cuando solicita un resumen seleccionando ambas | el payload capturado en el adaptador contiene solo esas dos solicitudes y solo requestId, zona, prioridad, fechaRequerida, estado y observaciones | ai-adapter / review; T-AC-05-01 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-02 | RF11, RNF01 | negativo | Dado los fixtures AI-FOREIGN-ID y AI-EXTRA y una salida con requestId repetido; cuando el adaptador devuelve cada una | se rechazan; se muestran mensaje controlado y resumen alternativo; no aparece ningún dato de ORG-B y nada se ejecuta | ai-adapter / review; T-AC-05-02 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-03 | RF12, RNF06 | fallo | Dado los fixtures AI-TIMEOUT con 5001 ms y AI-ERROR; cuando el coordinador solicita un resumen | el adaptador corta la espera del proveedor a los 5 segundos; test instrumental permite hasta 250 ms adicionales de procesamiento del fallback (no ampliar timeout del proveedor); mensaje controlado y fallback determinista; listar/reservar/despachar siguen funcionando | ai-adapter / review; T-AC-05-03 (contrato + fixtures + API + PostgreSQL) | No

ejecutado | Pendiente |

| AC-05-04 | RF12 | positivo | Dado un borrador válido de ORG-A; cuando el coordinador de ORG-A lo aprueba | el borrador queda aprobado; prioridades, estados e inventario son idénticos antes y después según snapshot | ai-adapter / review; T-AC-05-04 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-05 | RF10, RF02, RNF01 | limite | Dado el coordinador de ORG-A autenticado; cuando selecciona 21 identificadores, una lista vacía, identificadores repetidos, B-001 de ORG-B o una solicitud RESERVADA, y después 20 identificadores válidos | los tres primeros casos reciben 422, B-001 recibe 404 y la RESERVADA 409, sin invocar al proveedor; con 20 válidos el proveedor se invoca una sola vez | ai-adapter / review; T-AC-05-05 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-06 | RF11 | negativo | Dado salidas con summary vacío o de 601 caracteres, seis recomendaciones, reason de 241, evidenceFields vacío, con cuatro claves, repetidas o con clave no permitida, y el fixture AI-JSON-BAD; cuando se validan | cada una se rechaza con motivo sanitizado y se usa el resumen alternativo; ninguna se guarda como borrador válido | ai-adapter / review; T-AC-05-06 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-07 | RF11 | limite | Dado el fixture AI-VALID y salidas con summary de 600 caracteres, cinco recomendaciones con identificadores únicos del conjunto, reason de 240 y evidenceFields de una y de tres claves permitidas; cuando se validan | se aceptan y se muestran como borrador de asistencia de IA | ai-adapter / review; T-AC-05-07 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-08 | RF11, RNF01 | fallo | Dado una solicitud de ORG-A cuyas observaciones contienen el texto de untrusted-observation.txt y el fixture AI-INJECTION; cuando el coordinador solicita el resumen | la instrucción incrustada no se obedece; el ID ajeno invalida la salida completa y se usa fallback; el texto malicioso rechazado no llega a pantalla; stock, estados, prioridades y permisos no cambian. Escape de salida válida se verifica por separado en AC-05-17 | ai-adapter / review; T-AC-05-08 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-09 | RF12, RNF06 | fallo | Dado el proveedor no configurado; cuando el coordinador solicita dos veces el resumen de la misma selección sin cambios en los datos | ambas respuestas incluyen mensaje controlado y el mismo resumen determinista; no se requiere ningún servicio de pago | ai-adapter / review; T-AC-05-09 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-10 | RF12 | positivo | Dado una salida válida del adaptador; cuando se muestra al coordinador | aparece identificada como asistencia de IA con su origen; la prioridad mostrada es la de cada solicitud y ninguna recomendación se aplica sin una operación normal posterior | ai-adapter / review; T-AC-05-10 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-11 | RF12, RF02 | permiso | Dado un borrador de ORG-A y otro de ORG-B; cuando el auditor, la bodega o el solicitante de ORG-A solicitan o aprueban un resumen, y el coordinador de ORG-A intenta aprobar el borrador de ORG-B | los otros roles reciben 403; el borrador de ORG-B recibe 404; ningún borrador, stock ni prioridad cambia | ai-adapter / review; T-AC-05-11 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-12 | RF09, RF12 | positivo | Dado un borrador válido de ORG-A; cuando el coordinador lo aprueba enviando un X-Correlation-Id | se persiste junto a la aprobación un evento con identidad, organización, recurso, acción, fecha UTC y ese correlationId; las solicitudes y el inventario quedan idénticos | ai-adapter / review; T-AC-05-12 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-13 | RF12 | positivo | Dado una respuesta real capturada de un LLM con su entrada, salida y origen declarados; cuando se ejecuta mediante el adaptador de reproducción | pasa por el mismo adaptador y validador del producto; el origen se muestra como reproducción con su fixture y versión y no se reporta una invocación en vivo | ai-adapter / review; T-AC-05-13 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-14 | RNF06 | positivo | Dado el pipeline de CI del repositorio; cuando ejecuta las pruebas del asistente | usa solo los siete fixtures deterministas de ai-provider-fixtures.json, sin credenciales ni servicios de pago, y cada resultado coincide con el campo expected del fixture | ai-adapter / review; T-AC-05-14 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-15 | RF12, RF09 | positivo | Dado borrador de ORG-A generado como fallback y coordinador autenticado con CSRF válido; cuando aprueba el borrador alternativo | 200; conserva origen fallback y registra aprobación+evento en la misma transacción, sin cambios de solicitudes, prioridad o inventario | ai-adapter / review; T-AC-05-15 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-16 | RF12, RF09 | negativo | Dado borrador ya APROBADO en ORG-A y su evento de aprobación existente; cuando el coordinador repite aprobación con CSRF válido | 409; no cambia aprobación previa ni añade un segundo evento; solicitudes e inventario inalterados | ai-adapter / review; T-AC-05-16 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

| AC-05-17 | RF11, RF12, RNF01 | positivo | Dado salida IA válida con IDs propios y texto <script>window.__unsafe=true</script> en summary, dentro de límites; cuando se valida y se muestra el borrador | la salida válida se acepta, texto escapado visible, no se ejecuta script y window.__unsafe no se establece; sin cambios de inventario, estado o prioridad | ai-adapter / review; T-AC-05-17 (contrato + fixtures + API + PostgreSQL) | No ejecutado | Pendiente |

Dependencias y responsables propuestos

| Tarea | Dependencias obligatorias | Responsable principal propuesto |

|---|---|---|

| TASK-01 Identidad | SPEC-01 aprobada + G2 revisado | José Conde; revisión de otro integrante |

| TASK-02 Solicitudes/UI | TASK-01 + SPEC-02 aprobada | José Conde; Carolina revisa trazabilidad |

| TASK-03 Inventario | TASK-01/02 + SPEC-03 aprobada | Edier; revisión de otro integrante |

| TASK-04 Consultas/auditoría | SPEC-04 aprobada; auditoría integrada en TASK-02/03 | Edier; revisión de otro integrante |

| TASK-05 IA | TASK-01/02/04 + SPEC-05 aprobada | José Vega; revisión de otro integrante |

| Validación y CI | Contratos G2 y módulos revisados | José Vega; todos aportan pruebas reales |

Carolina coordina el cotejo de requisitos y SPEC. Ninguna fila acredita autoría, trabajo o revisión ya realizada.

docs/evidence/runtime/spec-vs-code.csv

spec,ac,requirements,code,verification_status,evidence

SPEC-01,AC-01-01,RF01;RNF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-02,RF02;RNF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-03,RF02;RNF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-04,RF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-05,RF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-06,RF01;RNF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-07,RF02;RNF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-08,RF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-09,RF02;RNF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-10,RNF01;RNF06,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-11,RF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-12,RF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-13,RNF05,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-01,AC-01-14,RF01;RNF01,Identity; RequireIdentity; ApiContext,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-01,RF03,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-02,RF03;RNF01,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-03,RF04,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-04,RF03,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-05,RF03,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-06,RF03;RNF01,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-07,RF03;RNF01,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-08,RF04;RF09,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-09,RF04,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-10,RF04,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-02,AC-02-11,RNF05,Requests/RequestService; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-01,RF05;RNF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-02,RF05;RNF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-03,RF05;RF07;RNF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-04,RF07;RNF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-05,RF04;RF06;RNF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-06,RF04;RF06,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-07,RF04;RNF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-08,RF05;RF07;RNF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-09,RF05;RF09;RNF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-10,RF07,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-11,RF07,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-12,RF07;RF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-13,RF04;RF06;RNF02,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-14,RF07;RF04,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-15,RF02;RF04;RF07,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-16,RNF05,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-03,AC-03-17,RF04;RF06;RNF02;RF09,Inventory/TransitionController,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-01,RF08;RF02,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-02,RF08;RF02,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-03,RF09,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-04,RF09,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-05,RF08,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-06,RF08,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-07,RF09;RNF06,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-08,RF09,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-09,RNF03,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-10,RF08;RF02,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-11,RF09;RF02,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-12,RNF04,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-13,RNF06,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-04,AC-04-14,RNF05,Queries/QueryController; public/app.js,NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-01,RF10;RNF01,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-02,RF11;RNF01,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-03,RF12;RNF06,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-04,RF12,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-05,RF10;RF02;RNF01,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-06,RF11,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-07,RF11,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-08,RF11;RNF01,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-09,RF12;RNF06,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-10,RF12,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-11,RF12;RF02,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-12,RF09;RF12,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-13,RF12,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-14,RNF06,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-15,RF12;RF09,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-16,RF12;RF09,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

SPEC-05,AC-05-17,RF11;RF12;RNF01,AI/AiController (fallback only),NOT_VERIFIED_IN_FULL,See verification.md for observed subset; no full AC claim

docs/risks/risk-register.md

Registro inicial de riesgos — BORRADOR

ID	Riesgo	Impacto	Probabilidad	Control propuesto	Responsable	Evidencia de control	Residual
R-01	Reserva duplicada por concurrencia	Alta	Alta	Bloqueo/transacción y test con dos usuarios simultáneos	Por asignar	Pendiente	Por evaluar
R-02	Acceso interorganización	Alta	Alta	Filtro de servidor y 2 lecturas + 2 escrituras cruzadas	Por asignar	Pendiente	Por evaluar
R-03	Reutilización indebida de idempotencia	Alta	Media	Scope por usuario/organización/operación/hash y tests	Por asignar	Pendiente	Por evaluar
R-04	Respuesta IA con ID ajeno/inyección	Alta	Media	Schema estricto, whitelist IDs, texto no ejecutable	Por asignar	Pendiente	Por evaluar
R-05	Fallo de proveedor de IA	Media	Alta	Timeout 5 s, resumen alternativo determinista	Por asignar	Pendiente	Por evaluar
R-06	Entrega irreproducible	Alta	Media	Lockfiles, migraciones y clon limpio verificado	Por asignar	Pendiente	Por evaluar
R-07	Ausencia de enunciado y anexos	Alta	Baja (fuente recibida 2026-10-14)	Originales en docs/examen-oficial/ con SHA-256; cotejo en cotejo-oficial-G1.md	Carolina (propuesto)	Inventario y cotejo 0.3; revisión humana pendiente	Bajo; vigilar versiones nuevas del docente
R-08	Implementar antes de revisión humana	Alta	Media	Gate con SHA y autor/revisor distintos; no merge automático	Equipo (propuesto)	G1 no aprobado	Alto hasta revisión
R-09	Métricas o contribuciones ficticias	Alta	Media	Evidencia real, observado separado de esperado; no suplantar identidades	Equipo (propuesto)	Matriz preparada sin resultados	Por evaluar
R-10	Accesibilidad y rendimiento insuficientes	Media	Media	Teclado, 390/1366px y carga 20VU/60s con 2.000 solicitudes	José Vega (propuesto)	Pruebas no ejecutadas	Por evaluar
R-11	Auditoría y negocio divergen	Alta	Media	Misma transacción y fallo inducido antes del commit	Edier (propuesto)	AC-03-09 previsto	Por evaluar
R-12	Permisos no definidos por la matriz oficial (CL-16, CL-17, CL-18) sin respuesta del docente	Media	Media	Enviar preguntas; aplicar supuesto provisional registrado y aislar su impacto en AC-04-10 y E2E	Conde José (propuesto, envío)	Preguntas registradas, no enviadas	Medio hasta respuesta

Los responsables son propuestas de coordinación. Ningún control de aplicación se ha verificado aún ni se atribuye trabajo real a esas personas.

docs/delivery/aceptacion-provisional.md

Acta provisional: entrega no aceptada como final

La implementación de esta rama se adelantó por instrucción expresa del coordinador «haz esto con lo que hay, después corrijo». Esto no equivale a aprobación G1/G2 ni elimina la exigencia de revisión previa del examen. La brecha de proceso se mantiene visible y el código requiere revisión independiente antes de integración.

Alcance: frontend y API locales para ocho cuentas ficticias, solicitudes, flujo de stock, consultas y auditoría. Asistente actualmente con fallback determinista declarado; no se atribuye una invocación a LLM real.

Estado de aceptación: PROVISIONAL / NO ACEPTADO COMO ENTREGA FINAL. El informe de ejecución consigna qué pruebas se ejecutaron y sus resultados. Revisor independiente, fecha de aceptación, firmas y decisiones finales: pendientes.

Brechas antes de release-examen: proveedor/reproducción real y validación completa IA, pruebas por todos los AC, carga exigida, escenarios adicionales de concurrencia/fallos/TTL, restauración y aceptación manual, aportes personales de código/pruebas de todos, convergencia y revisión humana final. Ya existen suite PostgreSQL, E2E responsive, un escenario concurrente, revisión automatizada limitada de secretos/dependencias y CI remoto correctos sobre el candidato indicado en verification.md; no prueban todos los requisitos. No generar aprobación ficticia ni tag release-examen para esconder brechas.

El PDF consolidado provisional permite revisar el estado; los cuatro deben entregar el mismo PDF final después de corregir y verificar esas brechas, no cuatro versiones distintas.

docs/delivery/checklist-entrega.md

Coordinación de la entrega

Paquete actual: provisional; PR #12 en borrador. Cualquier aprobación debe identificar el SHA revisado y venir de la persona que revisó.

| Responsable propuesto | Acción ejecutable | Evidencia requerida |

|---|---|---|

| Conde José | Abrir runbook, levantar Docker, recorrer desde solicitud hasta entrega y probar rechazo; revisar aporte ajeno | Comentario propio con SHA, pasos, resultado y decisión; PR de su corrección o prueba real |

| Carolina | Contrastar formularios, estados y errores contra las cinco SPECS, comprobar teclado y 390/1366 | Hallazgos reproducibles y revisión personal del SHA; prueba/corrección propia |

| Edier | Revisar bloqueos, transacciones, reserva parcial, idempotencia/TTL, aislamiento y restauración | Tests PostgreSQL adicionales, resultados y revisión del código de otro integrante |

| Vega | Completar LLM real y validación estricta con evidencias, revisar seguridad/CI/carga | PR con pruebas de salida válida/inválida, fallo/fallback, carga y CI real; revisión cruzada |

1. Publicar correcciones en PR separados; cada integrante aporta código o pruebas y revisa un aporte ajeno, sin autoaprobarse.

2. Registrar cierre G1/G2 y decisiones sobre SHA exactos. Resolver la brecha de proceso ante el equipo; no inventar revisión previa.

3. Ejecutar en entorno limpio dedicado el mismo candidato: suite PostgreSQL, E2E, concurrencia, validación IA real, carga exigida, dependencias/secretos, backup/restauración y aceptación manual. Guardar resultados, entorno y fallos.

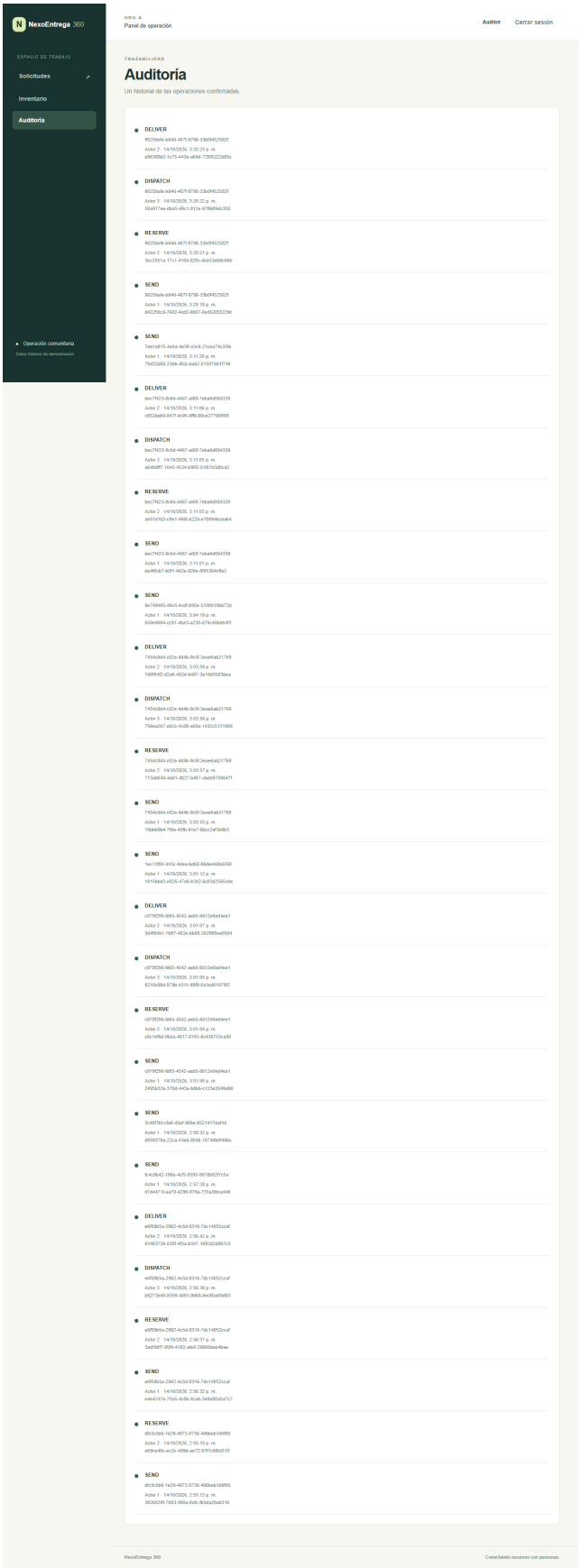
4. Completar comparación de los 73 AC contra código y evidencia. Un enlace a una prueba planificada no acredita que haya pasado.

5. Regenerar el PDF común desde el candidato: cinco historias/SPECS, arquitectura/modelo/contratos, IA/verificación humana, trazabilidad/riesgos, pruebas/CI/ejecución/aceptación y contribuciones reales. Revisar el contenido completo con anexo 09 y la rúbrica.

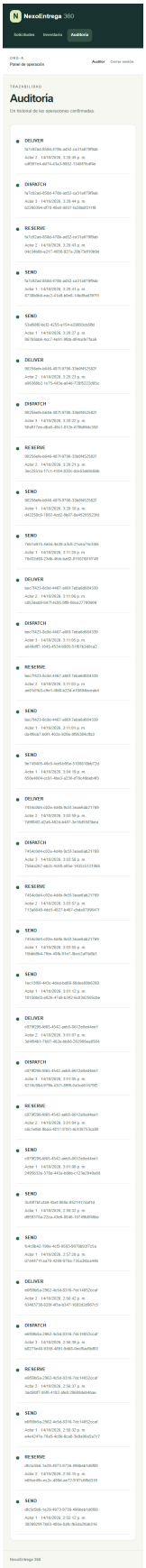
6. Solo tras aceptación real, registrar SHA final, crear y publicar release-examen apuntando a ese commit; comprobar remotamente el tag. Verificar hash SHA-256 del PDF y que los cuatro adjunten el mismo archivo Examen_SDD_IA_Equipo_NexoEntrega360.pdf al aula.

Generación provisional reproducible: instalar docs/delivery/requirements-pdf.lock y ejecutar python scripts/export_delivery_pdf.py --sha <SHA-candidato>. El documento se rotula provisional. No sustituye la revisión final ni publica nada en el aula.

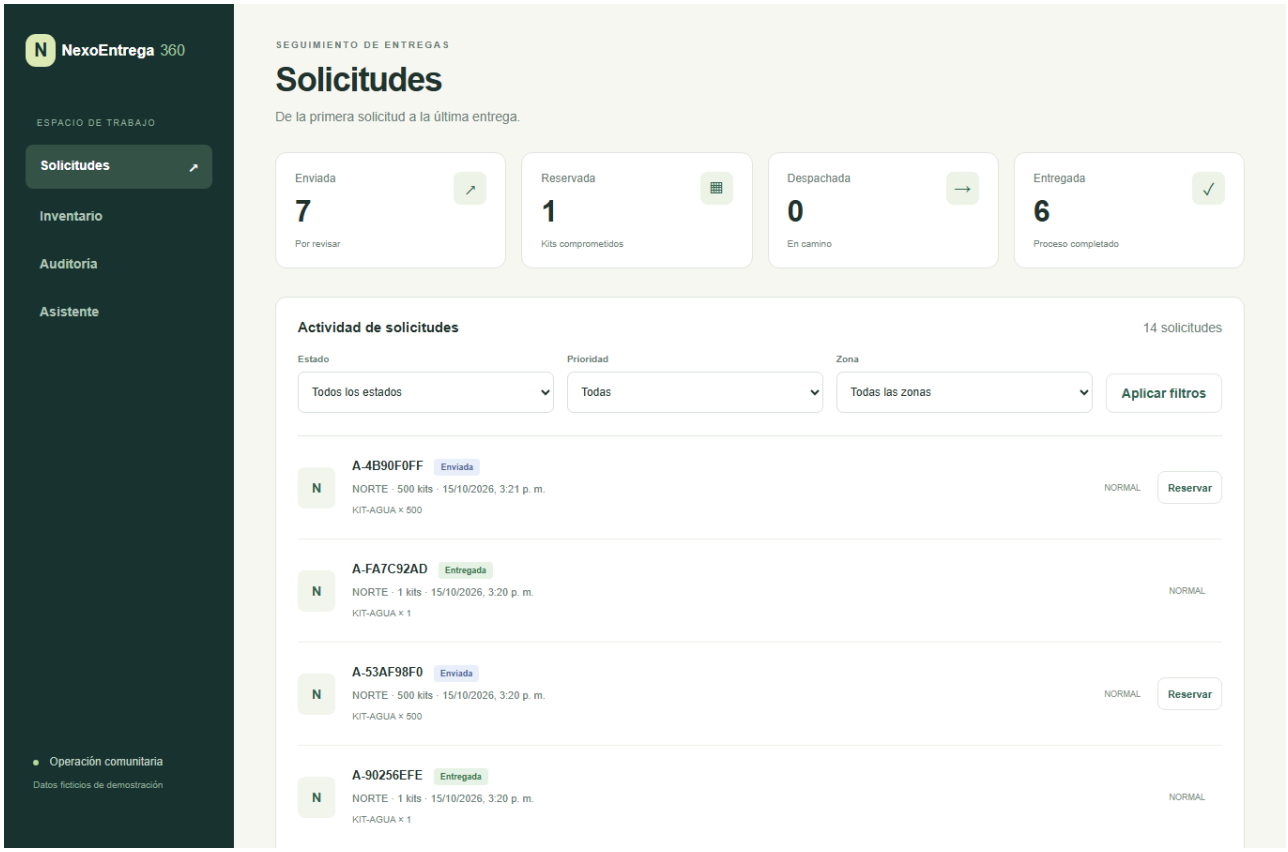
Captura: flujo-desktop.png



Captura: flujo-mobile.png



Captura: solicitudes-desktop.png



Captura: solicitudes-mobile.png

